
ISO/IEC 27001:2022

Plain-Language Control and Audit Guide

What every requirement means, why it exists, how to audit it, what evidence to collect, how to document it, and how to report it.

Coverage

Clauses 4 through 10, the management system requirements.
Annex A, all 93 controls across the four themes.

Audience

Internal auditors, control owners, compliance analysts, and anyone who has to explain a security requirement to somebody who does not work in security.

Before You Use This Document

This is a companion guide, not a copy of the standard.

ISO/IEC 27001:2022 is a copyrighted publication of ISO and IEC. Nothing in this document reproduces the text of the standard. Every requirement here is described in original wording, using the official clause and control numbering as reference points only. Your organization still needs licensed copies of ISO/IEC 27001:2022 and, for implementation guidance, ISO/IEC 27002:2022. Where this guide and the standard appear to differ, the standard governs.

What this guide does

It takes each requirement in ISO/IEC 27001:2022 and answers six questions about it, in the same order every time:

1. **What the control asks for.** The requirement in ordinary language, with no assumed background.
2. **Why it exists.** The failure it is there to prevent. Auditors who understand intent write better findings than auditors who only know the wording.
3. **How to audit it.** Specific test steps, in the order you would actually perform them.
4. **Evidence to collect.** Named artifacts. Not “documentation” but the actual thing to request.
5. **How to document it.** What belongs in the workpaper so a reviewer can follow your reasoning without re-performing your work.
6. **Executive summary treatment.** Suggested language if the item fails or rates high risk, written for an audience that does not read control numbers.

On vocabulary

Technical terms are defined the first time they appear, shown like [this](#), and collected in the glossary. If you hit a term that is not defined, that is a defect in this document; note it and it will be fixed in the next revision.

Navigating this document

Each part opens with a quick-reference table. Every reference number and title in those tables is a live link to the full entry, so the tables work as a jump menu rather than just a contents list. Entries also appear in the PDF bookmark panel, and the index at the back links back into the text.

Link colour carries meaning:

Blue

Governance, personnel, and physical-facility requirements.

Orange, marked CYB

Controls whose subject matter is specifically cybersecurity: defending against, detecting, or responding to technical attack, or the security of the technology itself.

Orange, marked AI

Requirements that are direct attachment points for AI system governance — where ISO/IEC 42001, the NIST AI RMF, or EU AI Act obligations land when an ISMS is extended to cover AI systems. ISO/IEC 27001:2022 contains no AI-specific controls; these are the hooks, not the coverage.

Orange, marked CYB/AI

Both of the above.

The marker letters are printed as well as coloured, so the distinction survives greyscale printing and does not depend on colour vision. The classification is a judgment, not something the standard states; it is held in a single file in the source and can be re-scoped without touching any content.

One entry, one page

Every clause and control begins at the top of a fresh page and is complete before the next one starts. This wastes some paper and makes the document longer than it needs to be. It also means you can print a single control and hand it to the person who owns it, which is what these documents actually get used for.

On the audit steps

The steps assume a first-party or second-party audit, meaning an internal audit or a customer auditing a supplier. If you are preparing for a certification audit by an accredited certification body, the tests are the same but the certification body will sample more lightly and will focus harder on Clauses 4 through 10. Most organizations over-prepare Annex A and under-prepare the management system clauses. That is backwards, and it is the most common reason for a surprise at stage two.

Three definitions you need before anything else**Control**

A measure that changes risk. It might be a technology, a process, a rule, or a person doing something on a schedule. In this standard a control is not necessarily a piece of software.

Nonconformity

A failure to meet a requirement. A *major* nonconformity means a requirement is absent, or a failure is widespread, or it puts the reliability of the whole system in doubt. A *minor* nonconformity is an isolated lapse in a system that otherwise works. Certification is normally blocked by a major and not by a minor.

Documented information

The standard's umbrella term for both documents, which say what is supposed to happen, and records, which show what did happen. When you see this phrase, ask yourself which of the two is actually being required.

How to read the executive summary sections

Every entry ends with suggested reporting language. It is deliberately written to avoid three habits that get security findings ignored: control numbers in the first sentence, adjectives about maturity, and recommendations that amount to “do it better.” Each one names a specific consequence and, where possible, attaches a number. Adapt the wording; keep the structure.

Contents

Before You Use This Document	ii
1 The Management System: Clauses 4 to 10	1
4.1 Understanding the organization and its context	3
4.2 Understanding the needs and expectations of interested parties	5
4.3 Determining the scope of the information security management system	6
4.4 Information security management system	7
5.1 Leadership and commitment	8
5.2 Policy	9
5.3 Organizational roles, responsibilities and authorities	10
6.1.1 Actions to address risks and opportunities: general	11
6.1.2 Information security risk assessment	12
6.1.3 Information security risk treatment	13
6.2 Information security objectives and planning to achieve them	14
6.3 Planning of changes	15
7.1 Resources	16
7.2 Competence	17
7.3 Awareness	18
7.4 Communication	19
7.5.1 Documented information: general	20
7.5.2 Creating and updating documented information	21
7.5.3 Control of documented information	22
8.1 Operational planning and control	23
8.2 Performing information security risk assessment	24
8.3 Performing information security risk treatment	25
9.1 Monitoring, measurement, analysis and evaluation	26
9.2 Internal audit	27
9.3 Management review	29
10.1 Continual improvement	30
10.2 Nonconformity and corrective action	31
2 Annex A.5: Organizational Controls	32
A.5.1 Policies for information security	34
A.5.2 Information security roles and responsibilities	35
A.5.3 Segregation of duties	36
A.5.4 Management responsibilities	37
A.5.5 Contact with authorities	38
A.5.6 Contact with special interest groups	39
A.5.7 Threat intelligence	40
A.5.8 Information security in project management	41

A.5.9	Inventory of information and other associated assets	42
A.5.10	Acceptable use of information and other associated assets	43
A.5.11	Return of assets	44
A.5.12	Classification of information	45
A.5.13	Labelling of information	46
A.5.14	Information transfer	47
A.5.15	Access control	48
A.5.16	Identity management	49
A.5.17	Authentication information	50
A.5.18	Access rights	51
A.5.19	Information security in supplier relationships	52
A.5.20	Addressing information security within supplier agreements	53
A.5.21	Managing information security in the ICT supply chain	54
A.5.22	Monitoring, review and change management of supplier services	55
A.5.23	Information security for use of cloud services	56
A.5.24	Information security incident management planning and preparation	57
A.5.25	Assessment and decision on information security events	58
A.5.26	Response to information security incidents	59
A.5.27	Learning from information security incidents	60
A.5.28	Collection of evidence	61
A.5.29	Information security during disruption	62
A.5.30	ICT readiness for business continuity	63
A.5.31	Legal, statutory, regulatory and contractual requirements	64
A.5.32	Intellectual property rights	65
A.5.33	Protection of records	66
A.5.34	Privacy and protection of personally identifiable information	67
A.5.35	Independent review of information security	69
A.5.36	Compliance with policies, rules and standards for information security	70
A.5.37	Documented operating procedures	71
3	Annex A.6: People Controls	72
A.6.1	Screening	73
A.6.2	Terms and conditions of employment	74
A.6.3	Information security awareness, education and training	75
A.6.4	Disciplinary process	76
A.6.5	Responsibilities after termination or change of employment	77
A.6.6	Confidentiality or non-disclosure agreements	78
A.6.7	Remote working	79
A.6.8	Information security event reporting	81
4	Annex A.7: Physical Controls	82
A.7.1	Physical security perimeters	84
A.7.2	Physical entry	85
A.7.3	Securing offices, rooms and facilities	86
A.7.4	Physical security monitoring	87
A.7.5	Protecting against physical and environmental threats	88
A.7.6	Working in secure areas	89
A.7.7	Clear desk and clear screen	90
A.7.8	Equipment siting and protection	91

A.7.9	Security of assets off-premises	92
A.7.10	Storage media	93
A.7.11	Supporting utilities	94
A.7.12	Cabling security	95
A.7.13	Equipment maintenance	96
A.7.14	Secure disposal or re-use of equipment	97
5	Annex A.8: Technological Controls	98
A.8.1	User endpoint devices	100
A.8.2	Privileged access rights	101
A.8.3	Information access restriction	102
A.8.4	Access to source code	103
A.8.5	Secure authentication	104
A.8.6	Capacity management	105
A.8.7	Protection against malware	106
A.8.8	Management of technical vulnerabilities	107
A.8.9	Configuration management	109
A.8.10	Information deletion	110
A.8.11	Data masking	111
A.8.12	Data leakage prevention	112
A.8.13	Information backup	113
A.8.14	Redundancy of information processing facilities	114
A.8.15	Logging	115
A.8.16	Monitoring activities	116
A.8.17	Clock synchronization	117
A.8.18	Use of privileged utility programs	118
A.8.19	Installation of software on operational systems	119
A.8.20	Networks security	120
A.8.21	Security of network services	121
A.8.22	Segregation of networks	122
A.8.23	Web filtering	123
A.8.24	Use of cryptography	124
A.8.25	Secure development life cycle	125
A.8.26	Application security requirements	126
A.8.27	Secure system architecture and engineering principles	127
A.8.28	Secure coding	128
A.8.29	Security testing in development and acceptance	129
A.8.30	Outsourced development	130
A.8.31	Separation of development, test and production environments	132
A.8.32	Change management	133
A.8.33	Test information	134
A.8.34	Protection of information systems during audit testing	135
	Glossary	136
	Index of Terms and Concepts	139

CHAPTER 1

The Management System: Clauses 4 to 10

These are the requirements that build and run the management system itself. They are not optional and none of them can be excluded. Certification audits fail here far more often than they fail on Annex A, because organizations treat these clauses as paperwork around the real controls. They are not. They are the machinery that makes the controls stay working after the project that installed them ends.

A note on numbering: this guide follows the standard's clause numbering exactly, so 6.1.2 here is 6.1.2 in the standard. Sub-clauses that carry no independently auditable requirement are folded into their parent.

Quick reference: Clauses 4 to 10

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
4.1	Understanding the organization and its context	Context analysis document, current version, with revision history
4.2	Understanding the needs and expectations of interested parties	Interested party and requirements register, current version
4.3	Determining the scope of the information security management system	Scope statement, approved and dated
4.4	Information security management system	ISMS manual or equivalent describing the system and its processes
5.1	Leadership and commitment	Management review minutes showing decisions and assigned actions
5.2	Policy	Approved information security policy with approver, approval date, and version
5.3	Organizational roles, responsibilities and authorities	Role and responsibility matrix or RACI, current version
6.1.1	Actions to address risks and opportunities: general	Register or section covering ISMS-level risks and opportunities
6.1.2^{AI}	Information security risk assessment	Documented risk assessment methodology including acceptance criteria
6.1.3^{AI}	Information security risk treatment	Statement of Applicability, approved, versioned, covering all Annex A controls
6.2	Information security objectives and planning to achieve them	Documented objectives at corporate and functional levels
6.3	Planning of changes	Change plans for ISMS-level changes, dated before implementation
7.1	Resources	Resourcing analysis or capacity assessment for the security function
7.2	Competence	Competence requirements defined per security-relevant role

Ref	Title	Primary evidence
7.3	Awareness	Awareness programme content covering the three required elements
7.4	Communication	Communication plan or matrix covering internal and external audiences
7.5.1	Documented information: general	Master document register or index of the ISMS documentation set
7.5.2	Creating and updating documented information	Sampled documents with visible metadata
7.5.3	Control of documented information	Access control lists for the documentation repository
8.1	Operational planning and control	Operational procedures for security processes with stated frequencies
8.2 AI	Performing information security risk assessment	Risk assessment schedule and records of actual performance with dates
8.3	Performing information security risk treatment	Risk treatment plan with original and current target dates
9.1	Monitoring, measurement, analysis and evaluation	Measurement plan naming metrics, methods, frequencies, and responsible parties
9.2	Internal audit	Internal audit programme covering the full cycle
9.3	Management review	Management review schedule and actual meeting dates
10.1	Continual improvement	Improvement register or log with triggers and outcomes
10.2	Nonconformity and corrective action	Nonconformity and corrective action register covering all sources

4.1 Understanding the organization and its context

WHAT THE CONTROL ASKS FOR

You have to write down what your organization does, what world it operates in, and what outside and inside forces could help or hurt your ability to keep information safe. Outside forces include laws, regulators, customers, competitors, and threat actors. Inside forces include your staffing levels, your technology debt, your funding, and your culture. This is not a one-time exercise. When the business changes, the context record changes with it.

WHY IT EXISTS

Every later decision in the system depends on this. If you never wrote down that you handle regulated health data in three countries, your risk assessment will miss it, your controls will be sized wrong, and your auditors will find the gap for you. The clause exists to stop organizations from building a security program that answers questions nobody actually asked.

HOW TO AUDIT IT

1. Ask for the document where context is recorded. It may be called a context analysis, a SWOT, a business environment register, or it may sit inside the ISMS manual. What it is called does not matter; whether it exists does.
2. Read it against reality. Compare the listed business lines, locations, and data types to the company website, the org chart, and the asset inventory. Unlisted items are your finding.
3. Check the date and the revision history. A context record last touched three years ago in a company that acquired two businesses since then is stale by definition.
4. Interview a senior leader who is not in the security function. Ask them to describe the top three external pressures on the business. If their answer does not appear in the document, the document is decorative.
5. Trace forward. Pick two context items and confirm each one shows up somewhere in the risk assessment. Context that leads nowhere is not being used.

EVIDENCE TO COLLECT

- Context analysis document, current version, with revision history
- Meeting minutes or workshop notes showing who contributed and when
- Org chart and legal entity list for comparison
- Register of applicable laws and regulations
- Any strategic plan, board deck, or annual report used as an input
- Change records showing context was revisited after a major business change

HOW TO DOCUMENT IT

Record the document name, version, date, and owner. Note the specific method used to produce it, such as a facilitated workshop or a leadership survey. List the context items you traced forward into the risk assessment, and name where each one landed. If you found stale or missing content, state plainly what changed in the business and when, and show that the context record did not follow. Cross-reference this workpaper to your findings on scope (4.3) and risk assessment (6.1.2), because context failures almost always surface again there.

EXECUTIVE SUMMARY TREATMENT

Frame it as a targeting problem, not a paperwork problem. Suggested language: the organization has not maintained a current record of the business conditions that drive its security decisions, which means the security program may be defending against last year's business. Name the specific missed item, such as a new jurisdiction or a new product line, and state the downstream effect: risks in that area were never assessed

and therefore were never treated.

4.2 Understanding the needs and expectations of interested parties

WHAT THE CONTROL ASKS FOR

Identify everyone who has a stake in how you handle information, and write down what each of them requires from you. Interested parties include customers, regulators, employees, shareholders, suppliers, and sometimes the public. You then decide which of their requirements you will actually meet through the security program. The output is a register that pairs each party with its specific, concrete requirements.

WHY IT EXISTS

Security obligations arrive from many directions at once and most of them are not written in your own policies. They sit in customer contracts, regulator guidance, and employment law. Without a consolidated register, obligations get discovered during an incident or a customer audit rather than during planning. This clause forces the discovery to happen early, on your schedule.

HOW TO AUDIT IT

1. Obtain the interested party register and confirm it lists both the party and the specific requirement, not just the party name. A list of stakeholder names with no obligations attached does not satisfy the clause.
2. Sample three to five customer contracts and check whether their security clauses appear in the register. Contractual security commitments are the most commonly omitted category.
3. Sample the regulatory obligations. Confirm each named law is matched to what it actually requires of the organization, not merely cited by name.
4. Ask how the register is refreshed and who owns it. Look for a defined trigger, such as new contract signature or regulatory change monitoring.
5. Trace two requirements through to a control or a risk. An obligation that no control addresses is either an accepted gap or an oversight; make the organization say which.

EVIDENCE TO COLLECT

- Interested party and requirements register, current version
- Sample of customer contracts with security or data protection clauses
- Register of applicable laws, regulations, and industry codes
- Supplier agreements containing security obligations
- Evidence of periodic review, such as a dated review log or approval record
- Mapping from requirements to controls or risk entries

HOW TO DOCUMENT IT

List the register version and owner. Record your sample: which contracts, which regulations, and which parties you tested, and the result for each. Where you traced a requirement forward, name the control or risk it landed on. For gaps, state the specific unrecorded obligation and its source document, including the clause or section number, so the finding is verifiable without re-performing your work.

EXECUTIVE SUMMARY TREATMENT

Lead with contractual and legal exposure because that is what leadership responds to. Suggested language: security obligations the organization has already agreed to in customer contracts are not tracked in any central register, so there is no reliable way to confirm they are being met. Quantify where possible by naming the number of affected contracts or the revenue they represent.

4.3 Determining the scope of the information security management system

WHAT THE CONTROL ASKS FOR

Write down exactly what the **ISMS** covers. An ISMS, or information security management system, is the set of policies, processes, people, and controls you use to manage information security in a coordinated way. The scope statement must name the boundaries: which business units, which locations, which services, which technologies. It must also justify anything left out. The scope has to be available as documented information.

WHY IT EXISTS

Scope is the single most consequential sentence in the whole system. It defines what your certificate actually means and what your auditors are allowed to look at. Vague or artificially narrow scopes let real risk sit just outside the line while the organization claims coverage. This clause exists so that customers reading your certificate know what they are getting.

HOW TO AUDIT IT

1. Read the scope statement and test it for precision. Can you tell from the words alone whether a given system, office, or team is in or out? If not, it is too vague.
2. Test exclusions hard. For every excluded unit or location, ask what interfaces exist between it and the in-scope environment. Shared identity systems, shared networks, and shared administrators usually mean the exclusion is not defensible.
3. Compare the scope to the asset inventory and network diagrams. Look for in-scope services that depend on out-of-scope infrastructure.
4. Confirm the scope is available as documented information and that the version in use matches the version referenced on the certificate or in the ISMS manual.
5. Ask sales or account management what they tell customers the scope covers. Divergence between the marketed scope and the documented scope is a reportable issue.

EVIDENCE TO COLLECT

- Scope statement, approved and dated
- Justification for each exclusion
- Network and data flow diagrams showing boundaries
- Asset inventory filtered by in-scope and out-of-scope
- Certificate or registration document, if already certified
- Customer-facing materials describing certification coverage

HOW TO DOCUMENT IT

Reproduce the scope statement verbatim in your workpaper, then record your boundary tests one by one: the interface examined, what you found, and your conclusion. Where an exclusion fails, state the specific dependency that breaks it. Note any mismatch between documented scope and customer-facing claims, and preserve the customer-facing wording as evidence.

EXECUTIVE SUMMARY TREATMENT

This one belongs in the executive summary whenever it fails, because it undermines every other assurance the organization gives. Suggested language: the certified scope excludes systems that in-scope services depend on, which means the certificate overstates the coverage the organization can demonstrate. Flag the commercial risk directly, since misrepresenting certification scope to customers is a contractual and reputational exposure, not just an audit finding.

4.4 Information security management system

WHAT THE CONTROL ASKS FOR

Establish the ISMS, run it, keep it running, and keep making it better. This clause also requires you to understand the processes inside the system and how they connect to each other. It is the umbrella requirement that the rest of Clauses 5 through 10 fill in. In practice it is tested by asking whether the system behaves like a system rather than a pile of unconnected documents.

WHY IT EXISTS

Organizations routinely produce every individual artifact the standard asks for while operating no coherent system at all. Policies exist but nobody follows them; risk assessments exist but never change anything. This clause gives the auditor authority to fail that pattern even when every separate box is ticked.

HOW TO AUDIT IT

1. Map the ISMS processes and their handoffs. Ask the ISMS owner to walk you through how a newly identified risk travels from discovery to treatment to verification, naming the person responsible at each step.
2. Test one full cycle end to end. Pick a risk raised nine to twelve months ago and follow it through treatment, implementation, and effectiveness check.
3. Look for orphan processes. Common examples are a risk register nobody reviews and an internal audit programme whose findings never reach management review.
4. Confirm the system is maintained continually rather than reconstructed before each audit. Compare document modification dates. A cluster of edits in the six weeks before every audit is a strong signal.
5. Assess improvement. Ask what the ISMS does differently this year compared to last year, and ask for the evidence behind the answer.

EVIDENCE TO COLLECT

- ISMS manual or equivalent describing the system and its processes
- Process map or narrative showing interactions between ISMS processes
- Document metadata showing edit and approval dates over time
- One traced risk with its full lifecycle record
- Evidence of improvements made and their triggers

HOW TO DOCUMENT IT

Document the end to end trace as a timeline: date raised, owner, treatment decision, implementation date, verification date, and current status. This single trace is often the most persuasive workpaper in the entire engagement. Record the document date clustering analysis with actual dates. Where processes are orphaned, name the process, its stated output, and the process that was supposed to consume that output.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the security management system produces the required documents but does not function as a connected process, so identified risks do not reliably result in action. Support it with the traced example, using real dates. Executives find a single concrete timeline far more convincing than a maturity score.

5.1 Leadership and commitment

WHAT THE CONTROL ASKS FOR

Top management must actively lead the security program, not merely approve it. Specifically they must make sure the security policy and objectives fit the business strategy, that security requirements are built into normal business processes, that the program has the resources it needs, that people understand why it matters, and that they support other managers in leading it. Top management means the people who direct and control the organization at the highest level.

WHY IT EXISTS

Security programs fail most often from lack of authority, not lack of knowledge. When leadership treats the program as a compliance chore delegated downward, the security function ends up issuing requests it cannot enforce. This clause makes leadership engagement itself an auditable requirement so that its absence becomes a formal finding rather than an unspoken frustration.

HOW TO AUDIT IT

1. Interview two or three members of top management separately. Ask what the security objectives are and how the program supports business strategy. Rehearsed or vague answers are themselves evidence.
2. Test resourcing. Compare the resources the security function requested against what was approved, over at least two budget cycles. Chronic under-funding against documented need is a leadership finding.
3. Look for integration into business processes. Check whether security requirements appear in the project intake process, procurement, and change management, or whether they are bolted on afterward.
4. Review management review records for evidence of decisions, not just attendance. Minutes that record presence but no directives indicate ceremonial engagement.
5. Ask the security lead where they lack authority to enforce a requirement, then verify whether that gap was escalated to management and what management did.

EVIDENCE TO COLLECT

- Management review minutes showing decisions and assigned actions
- Budget requests and approvals for the security function across two or more cycles
- Project intake, procurement, and change management procedures showing security gates
- Communications from leadership on security, with dates and audiences
- Objectives documents signed or approved by top management
- Escalation records where authority gaps were raised

HOW TO DOCUMENT IT

Record interviews by role rather than name where confidentiality matters, but keep the date and the questions asked. Present the resourcing comparison as a simple table of requested versus approved by cycle. For integration testing, name the specific process document and the clause within it that does or does not include a security gate. Avoid characterizing leadership attitude; document behavior and let the pattern speak.

EXECUTIVE SUMMARY TREATMENT

This is delicate because the audience is the subject. Keep it behavioral and specific. Suggested language: security requirements are not built into the processes where business decisions get made, so the security function reviews decisions after they are final rather than shaping them. Pair it with the resourcing table. Avoid words like commitment or tone at the top, which invite argument; describe what does and does not happen.

5.2 Policy

WHAT THE CONTROL ASKS FOR

Top management must establish an information security policy that suits the organization, either states security objectives or provides the framework for setting them, commits to meeting applicable requirements, and commits to continual improvement. The policy must be documented, communicated inside the organization, and made available to outside parties where appropriate.

WHY IT EXISTS

The policy is the organization's formal statement of intent. It is what gives every subordinate standard and procedure its authority. Without it, security requirements are one team's opinion. The specific required commitments exist because policies that promise nothing measurable cannot be audited or enforced.

HOW TO AUDIT IT

1. Read the policy against the four required elements: suitability to the organization, objectives or an objective-setting framework, a commitment to satisfy applicable requirements, and a commitment to continual improvement. Missing any one is a nonconformity.
2. Confirm approval by top management, with evidence of who approved and when. An unsigned or undated policy fails.
3. Test communication rather than publication. Sample staff across functions and ask whether they know the policy exists and where to find it. Publication to an intranet nobody visits is not communication.
4. Check availability to interested parties where relevant. If customers are told a policy exists, confirm the mechanism by which they can obtain it.
5. Verify the review cycle. Confirm a defined review frequency and evidence the most recent review actually happened on schedule.

EVIDENCE TO COLLECT

- Approved information security policy with approver, approval date, and version
- Evidence of top management approval, such as signed minutes
- Communication records: intranet posting, all-hands slides, onboarding materials, acknowledgement logs
- Acknowledgement statistics showing coverage across the workforce
- External availability mechanism, such as a trust portal entry
- Review log showing the last review date and outcome

HOW TO DOCUMENT IT

Quote the specific policy sentence that satisfies each of the four required elements, with the section number. Where an element is missing, say so explicitly rather than describing the policy as weak. Record acknowledgement coverage as a percentage with the population and the date pulled. For the staff sample, record the number asked, the functions represented, and the number who could locate the policy.

EXECUTIVE SUMMARY TREATMENT

Only escalate this when the failure is substantive rather than technical. Suggested language: the organization's security policy does not commit to meeting its own legal and contractual security obligations, which weakens the enforceability of every standard beneath it. If the failure is communication rather than content, say instead that a majority of sampled staff could not locate the policy that governs their handling of company information.

5.3 Organizational roles, responsibilities and authorities

WHAT THE CONTROL ASKS FOR

Top management must assign and communicate the responsibilities and authorities for security-relevant roles. Two responsibilities are named specifically: making sure the ISMS conforms to the standard, and reporting on ISMS performance to top management. Authority matters as much as responsibility. Assigning someone a duty without the power to carry it out does not satisfy this clause.

WHY IT EXISTS

Unassigned responsibility is the most common root cause in incident post-mortems. When nobody owns access reviews, they do not happen and no individual is accountable for that. Naming the role, the duty, and the authority converts a diffuse expectation into something a person can be held to and an auditor can test.

HOW TO AUDIT IT

1. Obtain the role and responsibility matrix and confirm it names the two specifically required duties, with an identified holder for each.
2. Test communication by asking role holders to state their own security responsibilities without prompting. Compare their answer to the matrix.
3. Test authority, not just duty. Ask each sampled role holder what they can do if someone refuses a security requirement. If the answer is nothing, the authority was never granted.
4. Look for vacancies and stale assignments. Cross-check the matrix against the current employee directory for departed staff still listed.
5. Check coverage during absence. Confirm named deputies for critical roles and test one by asking who covered during the last extended absence.

EVIDENCE TO COLLECT

- Role and responsibility matrix or RACI, current version
- Job descriptions for key security roles
- Appointment records or delegation letters showing granted authority
- Current employee directory for cross-checking
- Deputy or succession assignments for critical roles
- Interview notes recording what role holders believe they own

HOW TO DOCUMENT IT

Present the comparison between assigned and understood responsibilities as a two-column table by role. Record each authority test question and answer verbatim, since the exact words matter when the finding is disputed. For vacancies, record the role, the date it became vacant, and who has been covering it in the interim, if anyone.

EXECUTIVE SUMMARY TREATMENT

Suggested language: named security responsibilities have been assigned without the corresponding authority to enforce them, so accountability exists on paper while decisions are made elsewhere. If the issue is vacancy, state the number of security responsibilities currently assigned to people who have left the organization, and how long that has been true.

6.1.1 Actions to address risks and opportunities: general

WHAT THE CONTROL ASKS FOR

When planning the ISMS, you must consider the context from 4.1 and the requirements from 4.2, then determine the risks and opportunities that need to be addressed to make sure the system achieves what it is meant to achieve, to prevent or reduce unwanted effects, and to achieve continual improvement. You must plan the actions to address them and how to fold those actions into the system, and how you will evaluate whether they worked.

WHY IT EXISTS

This clause is about risks to the management system itself, which is distinct from information security risks to assets. A key person leaving, a budget cut, or a reorganization can disable the system that manages all your other risks. Organizations frequently skip this entirely because they assume 6.1.2 covers it. It does not.

HOW TO AUDIT IT

1. Confirm that risks to the ISMS itself are recorded somewhere distinct from asset-level security risks. Look for entries about resourcing, competence loss, organizational change, and management attention.
2. Trace the inputs. Verify that specific items from the context analysis (4.1) and the interested party register (4.2) appear as inputs to this determination.
3. Check that opportunities, not only risks, are addressed. Most registers omit opportunities entirely, which is a straightforward nonconformity.
4. For a sample of identified items, confirm a planned action exists, is integrated into an ISMS process rather than sitting in a standalone list, and has a defined method of evaluating effectiveness.
5. Test evaluation. Pick an action completed at least six months ago and ask how the organization concluded it worked.

EVIDENCE TO COLLECT

- Register or section covering ISMS-level risks and opportunities
- Traceability from context and interested party inputs
- Action plans with owners, dates, and integration points
- Effectiveness evaluation records for completed actions
- Planning meeting minutes or workshop outputs

HOW TO DOCUMENT IT

State clearly whether ISMS-level risk is addressed separately from asset-level risk, because this distinction is the whole point of the clause and is the most common misunderstanding. Record the traced inputs by name. For the effectiveness test, document the action, the completion date, the evaluation method, and the conclusion the organization reached.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization assesses risks to its data but not risks to the program that protects that data, leaving predictable disruptions such as key person departure or budget reduction unplanned for. This resonates with executives because it is a continuity argument they already understand from other domains.

6.1.2 Information security risk assessment

WHAT THE CONTROL ASKS FOR

Define and apply a repeatable risk assessment process. It must set criteria for accepting risk and criteria for performing assessments, produce consistent and comparable results when repeated, identify risks to the confidentiality, integrity, and availability of information in scope, identify **risk owners**, analyze the realistic consequences and likelihood of each risk, determine risk levels, and then compare those levels to your criteria and prioritize. A risk owner is the person with the authority and accountability to decide what to do about a specific risk.

WHY IT EXISTS

Everything downstream depends on this. Your controls, your budget, and your Statement of Applicability all derive from the risk assessment. The requirement for repeatable and comparable results exists because risk scoring that varies with the mood of the assessor produces a register that cannot be used to prioritize anything.

HOW TO AUDIT IT

1. Obtain the documented risk assessment methodology and confirm it defines both the acceptance criteria and the criteria for when assessments are performed.
2. Test repeatability directly. Take one risk and independently apply the methodology yourself. If you cannot reach the recorded score using the documented method, the method is not being followed or is not usable.
3. Confirm risk owners are named individuals with real authority, not committees or job families. A risk owned by IT is not owned.
4. Sample risks across the register and check that consequence and likelihood are justified with reasoning, not just asserted as numbers.
5. Test coverage against the asset inventory and the interested party register. Assets or obligations with no associated risk entry indicate incomplete identification.
6. Confirm assessments were actually performed at the frequency the methodology requires.

EVIDENCE TO COLLECT

- Documented risk assessment methodology including acceptance criteria
- Current risk register with owners, analysis, and levels
- Evidence of assessment sessions: dates, participants, scope covered
- Asset inventory for coverage comparison
- Prior register versions to test consistency over time
- Approval records for the risk acceptance criteria

HOW TO DOCUMENT IT

Document your independent re-scoring in full: the risk selected, each methodology input you applied, the score you derived, the score on file, and the variance. This is the highest-value test in the clause and it must be reproducible from your workpaper alone. Record sample size against total population. For coverage gaps, list the specific assets or obligations with no corresponding risk entry.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's risk scores cannot be reproduced by following its own documented method, which means the register does not reliably rank risks and cannot be used to justify where security money is spent. That last clause is the one that gets attention. If the issue is coverage, name the categories of asset that were never assessed.

6.1.3 Information security risk treatment

WHAT THE CONTROL ASKS FOR

Define and apply a process to choose how each risk will be handled, select the controls needed to implement those choices, compare your selected controls against Annex A to confirm nothing necessary was missed, produce a **Statement of Applicability**, formulate a risk treatment plan, and obtain risk owner approval for the plan and for accepting the **residual risk**. The Statement of Applicability, usually shortened to SoA, lists every Annex A control, says whether you apply it, and justifies inclusion or exclusion. Residual risk is what remains after your controls are working as intended.

WHY IT EXISTS

This is the clause that connects risk to action and produces the SoA, which is the document certification bodies examine most closely. The comparison against Annex A exists as a safety net: it forces you to consciously reject each standard control rather than simply forgetting it existed.

HOW TO AUDIT IT

1. Obtain the SoA and confirm it covers all 93 Annex A controls with an applicability decision and a justification for each. Justifications that merely restate the decision, such as not applicable because it does not apply, are not justifications.
2. Test the necessity comparison. Confirm the organization can show it derived controls from risks first and then compared to Annex A, rather than starting from Annex A and reverse-engineering risks to fit.
3. Sample exclusions, particularly in areas like development, physical security, and supplier management, and verify the stated reason against reality.
4. Confirm the risk treatment plan has owners, target dates, and resource commitments, and check overdue items against their original dates.
5. Verify documented risk owner approval of both the plan and the residual risk acceptance. Approval by the security team on behalf of risk owners does not satisfy the clause.

EVIDENCE TO COLLECT

- Statement of Applicability, approved, versioned, covering all Annex A controls
- Risk treatment plan with owners, dates, and status
- Risk owner approval records for the plan and residual risk acceptance
- Mapping from individual risks to selected controls
- Evidence of the Annex A comparison step
- Overdue treatment item aging report

HOW TO DOCUMENT IT

Record SoA completeness as a count: controls listed, controls with a stated justification, and controls where the justification is substantive. Present sampled exclusions in a table showing the control, the stated reason, and your verification result. For the treatment plan, produce an aging analysis of open items showing original due date and days overdue, which is far more useful to management than a status column.

EXECUTIVE SUMMARY TREATMENT

Suggested language: risks the organization formally accepted were never approved by the executives accountable for the affected business areas, meaning risk acceptance decisions were made below the level authorized to make them. Alternatively, if treatment is the issue: a material share of agreed security remediations are past their committed dates, with the oldest outstanding since a named date. Give the count and the oldest date.

6.2 Information security objectives and planning to achieve them

WHAT THE CONTROL ASKS FOR

Set security objectives at relevant functions and levels. Each must be consistent with the policy, measurable where practicable, account for applicable security requirements and risk assessment results, be monitored, be communicated, and be updated as needed. Objectives must be documented. For each one you must also plan what will be done, what resources are required, who is responsible, when it will be complete, and how results will be evaluated.

WHY IT EXISTS

Objectives turn intent into something you can measure and manage. The requirement to plan resources and completion dates exists because objectives without plans are aspirations. The requirement to set them at relevant functions and levels prevents a single corporate objective from standing in for accountability across the whole organization.

HOW TO AUDIT IT

1. Confirm objectives exist below the corporate level. A single set of enterprise objectives with nothing cascaded to functions does not meet the clause.
2. Test measurability. For each sampled objective, ask what number would demonstrate success and where that number comes from. If nobody can answer, it is not measurable.
3. Verify the link to risk assessment results and to security requirements. Objectives disconnected from the risk register suggest the two processes run independently.
4. For each objective, confirm all five planning elements are present: actions, resources, responsibility, deadline, and evaluation method. Missing any one is a nonconformity.
5. Check monitoring in practice. Ask for the most recent measurement of each sampled objective and compare its date to the stated monitoring frequency.
6. Test communication by asking staff in the relevant function whether they know the objective their team is working toward.

EVIDENCE TO COLLECT

- Documented objectives at corporate and functional levels
- Objective plans showing actions, resources, owners, deadlines, and evaluation methods
- Most recent measurement results with dates
- Evidence linking objectives to risk assessment outputs
- Communication records for each level
- Records of objectives being updated and why

HOW TO DOCUMENT IT

Use a single table with one row per objective and one column per required element, marked present or absent. This makes the nonconformity self-evident and is easy for management to act on. Record the last measurement date beside the required frequency to expose monitoring gaps. Where objectives are not measurable, quote the objective wording so the problem is visible.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's security objectives cannot be measured, so there is no basis for stating whether the security program is succeeding or failing. Pair it with one or two quoted objectives to make the point concrete. If measurement exists but is not performed, state how long it has been since the last measurement.

6.3 Planning of changes

WHAT THE CONTROL ASKS FOR

When the organization determines that the ISMS needs to change, those changes must be made in a planned manner. This is a short clause added in the 2022 revision. It applies to changes to the management system itself, such as scope changes, methodology changes, reorganizations of the security function, or shifts in governance structure, rather than to routine technical change management.

WHY IT EXISTS

Management systems degrade fastest during change. A reorganization that dissolves a committee, or a scope expansion made without revisiting the risk assessment, can invalidate large parts of the system silently. Requiring planned change means the effects have to be thought through before the change lands rather than discovered at the next audit.

HOW TO AUDIT IT

1. Identify ISMS changes made since the last audit: scope changes, methodology revisions, structural changes to the security function, tooling replacements, governance changes.
2. For each, ask for the plan produced before the change. Retrospective documentation is a finding.
3. Assess whether the plan considered downstream effects, particularly on the risk assessment, the SoA, competence requirements, and documented information.
4. Check that changes were communicated to affected parties and that dependent documents were updated within a reasonable period.
5. Compare against Clause 8.1, which covers planned changes at the operational level, and confirm the organization understands which clause governs which type of change.

EVIDENCE TO COLLECT

- Change plans for ISMS-level changes, dated before implementation
- Impact assessments covering dependent processes and documents
- Approval records for significant ISMS changes
- Updated downstream documents with revision dates
- Communication records to affected functions

HOW TO DOCUMENT IT

List every ISMS change identified in the period with its date, and for each record whether a plan existed beforehand. The date comparison between the change and the plan is the core evidence. Where downstream documents were not updated, name the document and show the gap in days between the change and the update, or note that no update occurred.

EXECUTIVE SUMMARY TREATMENT

Usually a minor finding, so escalate only if a change caused real degradation. Suggested language: a significant change to the security function was implemented without assessing its effect on existing controls, and as a result named responsibilities went unassigned for a period. Give the duration of the gap.

7.1 Resources

WHAT THE CONTROL ASKS FOR

Determine and provide the resources needed to establish, implement, maintain, and continually improve the ISMS. Resources means people, budget, tooling, time, and access to expertise. The clause is brief but it is the hook on which chronic under-investment findings hang.

WHY IT EXISTS

Almost every other failure in a management system traces back to insufficient resource. A security team of two supporting a thousand employees will produce late access reviews and shallow risk assessments no matter how competent they are. This clause lets the auditor address the cause rather than repeatedly writing up the symptoms.

HOW TO AUDIT IT

1. Establish what the organization determined it needs. Look for a documented resourcing analysis rather than a headcount that evolved by accident.
2. Compare determined need against actual provision across at least two budget cycles, covering headcount, budget, and tooling.
3. Correlate resource shortfalls with other findings. If access reviews are late and the team is at half its assessed need, the two findings should be linked rather than reported separately.
4. Check use of external resource where internal capability is absent, such as penetration testing or specialist legal advice.
5. Ask the ISMS owner what they would do with additional resource and what is currently not being done. Compare their answer to your own findings.

EVIDENCE TO COLLECT

- Resourcing analysis or capacity assessment for the security function
- Budget requests and approvals across two or more cycles
- Current headcount versus approved and versus assessed need
- Contracts for external specialist services
- Backlog or work queue data showing unmet demand
- Turnover data for the security function

HOW TO DOCUMENT IT

Present requested versus approved resource as a table by cycle. Explicitly cross-reference every other finding you believe is caused by the shortfall, by finding number. A resourcing finding supported by four downstream operational findings is far harder to dismiss than one supported by an opinion about adequacy.

EXECUTIVE SUMMARY TREATMENT

This is one of the few findings where the recommendation is a spending decision, so be precise. Suggested language: the security function is operating below the resource level the organization itself assessed as necessary, and this shortfall is the direct cause of a stated number of other findings in this report. List those findings by number. Avoid recommending a specific headcount unless you have a defensible basis for it.

7.2 Competence

WHAT THE CONTROL ASKS FOR

Determine the competence needed by people whose work affects security performance, make sure those people are competent based on education, training, or experience, take action where they are not, and keep documented evidence of competence. Competence means the demonstrated ability to do the specific job, which is not the same as having attended a course.

WHY IT EXISTS

Security work is technical and the consequences of doing it incorrectly are severe and often invisible. A misconfigured firewall rule looks the same as a correct one to an untrained reviewer. The clause requires the organization to define the ability needed for each role and then verify it, rather than assuming that a job title implies capability.

HOW TO AUDIT IT

1. Obtain the competence requirements by role. If none exist, the clause fails at the first requirement regardless of how much training the organization does.
2. Sample individuals in security-relevant roles and compare their documented education, training, and experience against the defined requirement for their role.
3. Test that competence is verified rather than assumed. Course attendance records prove attendance. Look for assessments, certifications, supervised practice sign-offs, or documented experience evaluation.
4. Check the action taken where gaps were identified, and verify the gap was subsequently closed.
5. Include contractors and third parties performing security-relevant work. They are frequently omitted and the clause does not exempt them.
6. Confirm competence records are retained as documented information and are current.

EVIDENCE TO COLLECT

- Competence requirements defined per security-relevant role
- Individual competence records: qualifications, certifications, training completions, experience assessments
- Assessment results or supervised sign-off records
- Gap remediation plans and evidence of closure
- Contractor and third-party competence evidence
- Training plan and completion data

HOW TO DOCUMENT IT

Build a sample table with one row per person, columns for role, required competence, evidence held, and conclusion. Record the sample size against the population and how you selected it. Where you concluded competence was assumed rather than verified, state exactly what evidence was offered and why it does not demonstrate ability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has not defined what capability is required for roles that make security decisions, and cannot demonstrate that the people in those roles have it. Where the gap is concentrated, name the function. If contractors are the gap, state that externally sourced staff perform security-relevant work without any competence verification, and give the number of people involved.

7.3 Awareness

WHAT THE CONTROL ASKS FOR

People doing work under the organization's control must be aware of the security policy, of how they contribute to the effectiveness of the ISMS including the benefits of improved performance, and of what happens if they do not conform to requirements. Note the population: everyone under the organization's control, which includes contractors and temporary staff, not only employees.

WHY IT EXISTS

Most incidents involve a person doing something ordinary. Awareness is the control that addresses the majority of the actual attack surface. The specific requirement to communicate the consequences of nonconformity exists because a program that never mentions consequences produces compliance that evaporates under deadline pressure.

HOW TO AUDIT IT

1. Confirm awareness content covers all three required elements. Many programs cover phishing and passwords thoroughly while never mentioning the policy or the consequences of noncompliance.
2. Verify the population includes contractors, temporary staff, and third parties working under organizational control. Compare completion records to a full population list, not just the employee roster.
3. Test effect rather than delivery. Ask sampled staff to describe their own security responsibilities and what would happen if they ignored them. Completion percentages measure attendance, not awareness.
4. Check timing for new starters. Confirm awareness is delivered before or shortly after access is granted, and measure the actual gap for a sample of recent joiners.
5. Review refresh frequency and evidence that content is updated to reflect current threats and lessons from actual incidents.

EVIDENCE TO COLLECT

- Awareness programme content covering the three required elements
- Completion records mapped to a complete population list including contractors
- New starter onboarding records with access grant dates and awareness completion dates
- Refresher schedule and content revision history
- Phishing simulation or knowledge assessment results, if used
- Evidence of content updates driven by incidents

HOW TO DOCUMENT IT

Record the population reconciliation explicitly: total workforce including contractors, number with completion records, and the difference. This reconciliation is the most common source of findings in this clause. For new starters, present a small table of joiner date, access grant date, and awareness completion date, with the gap in days.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of people with access to company systems have no record of security awareness training, and the majority of them are contractors excluded from the tracking process. Give the number and the percentage of the total population. If the issue is content, state that staff are not told what happens if they bypass security requirements, which weakens every policy the organization has.

7.4 Communication

WHAT THE CONTROL ASKS FOR

Determine the internal and external communications relevant to the ISMS, including what will be communicated, when, to whom, and how. This is a planning requirement. The organization must decide its communication approach deliberately rather than communicating ad hoc.

WHY IT EXISTS

Security information that does not reach the right people at the right time has no effect. This clause matters most during incidents, when unplanned communication produces delay, contradiction, and regulatory breach. Deciding in advance who is told what, and by whom, is the difference between a managed incident and a chaotic one.

HOW TO AUDIT IT

1. Obtain the communication plan and confirm it addresses all four required elements: what, when, with whom, and how.
2. Check that external communication is covered, including regulators, customers, and law enforcement, not only internal channels.
3. Test against a real event. Take a recent incident or significant security change and compare the actual communication to the plan.
4. Verify that regulatory notification timelines are reflected. Where breach notification deadlines apply, confirm the plan accounts for them.
5. Confirm named roles rather than named individuals where possible, and check that the named roles are currently filled.

EVIDENCE TO COLLECT

- Communication plan or matrix covering internal and external audiences
- Incident communication procedures with timelines
- Records of actual communications during a recent event
- Regulatory notification requirements and how they map to the plan
- Contact lists with a recent verification date
- Escalation paths and their current role holders

HOW TO DOCUMENT IT

Present the plan-versus-actual comparison for the tested event as a timeline: what the plan required, what actually happened, and the variance in time. Note the last verification date on contact lists, since stale contact details are a common and consequential gap that is easy to evidence.

EXECUTIVE SUMMARY TREATMENT

Escalate mainly where regulatory notification is at stake. Suggested language: the organization has no planned communication path for notifying regulators within the deadlines that apply to it, creating exposure to penalties independent of the underlying incident. That framing separates the process failure from the incident itself, which executives find useful.

7.5.1 Documented information: general

WHAT THE CONTROL ASKS FOR

The ISMS must include the documented information the standard requires plus whatever the organization determines is necessary for the system to be effective. **Documented information** is the standard's term covering both documents, which say what should happen, and records, which show what did happen. The extent varies legitimately with organization size, complexity, and competence of staff.

WHY IT EXISTS

The standard deliberately avoids prescribing a document set, because a fixed list would be wrong for most organizations. What it requires is that the organization decide what it needs and can justify that decision. This prevents both under-documentation, where nothing can be evidenced, and over-documentation, where a large library exists that nobody follows.

HOW TO AUDIT IT

1. Build a checklist of every explicitly required documented information item in the standard and verify each exists. This is mechanical but it is where straightforward nonconformities are found.
2. Ask how the organization decided what additional documentation is necessary, and whether that determination is itself recorded.
3. Test sufficiency in the other direction: find a process performed consistently by one person with no documentation, and assess the continuity risk if that person leaves.
4. Check that documents match practice. Where they differ, determine which one is wrong; a procedure nobody follows is a finding whether or not the practice is sound.
5. Confirm required retention periods are defined and being observed.

EVIDENCE TO COLLECT

- Master document register or index of the ISMS documentation set
- The specific documented information items the standard requires
- Rationale for additional documentation determined necessary
- Retention schedule
- Sample of records demonstrating processes were performed

HOW TO DOCUMENT IT

Include your required-items checklist in full, with the location of each item or a note that it is absent. This checklist is reusable across engagements and makes completeness self-evident. Where documents and practice diverge, record both the documented step and the observed step side by side.

EXECUTIVE SUMMARY TREATMENT

Only escalate when the missing documentation creates operational risk rather than a technical gap. Suggested language: critical security processes exist only in the knowledge of individual staff, so the organization would lose the ability to perform them if those individuals left. Name the processes and the number of people who can currently perform each.

7.5.2 Creating and updating documented information

WHAT THE CONTROL ASKS FOR

When creating or updating documented information, ensure appropriate identification and description such as title, date, author, and reference number; appropriate format and media; and appropriate review and approval for suitability and adequacy. In short: documents must be identifiable, usable, and approved by someone qualified to approve them.

WHY IT EXISTS

Unidentifiable documents cannot be relied on. If a procedure has no version, no date, and no approver, nobody can tell whether the copy in front of them is current or who stands behind it. During an incident, staff following a superseded procedure will do the wrong thing confidently.

HOW TO AUDIT IT

1. Sample documents across the ISMS and check each for title, unique identifier, version, date, author, and approver.
2. Verify the approver had the authority to approve that document. Self-approval by the author is a common finding.
3. Check format suitability for actual use. A procedure needed during an outage that exists only on the system affected by the outage is not appropriately formatted.
4. Compare the copy in the official repository to copies in circulation, such as team wikis or shared drives, and look for divergent versions.
5. Confirm review covered suitability and adequacy rather than being a rubber stamp, by asking the approver what they changed or questioned.

EVIDENCE TO COLLECT

- Sampled documents with visible metadata
- Approval records showing approver identity and date
- Delegation of authority defining who may approve what
- Copies of the same document found in secondary locations
- Offline or out-of-band availability arrangements for incident-critical procedures

HOW TO DOCUMENT IT

Use a sample table with one row per document and one column per required attribute. Record where you found divergent copies, including the location and the version difference, since this is the finding most likely to be disputed. Note the specific documents that are incident-critical and unavailable during an outage.

EXECUTIVE SUMMARY TREATMENT

Rarely escalated alone. Where it matters: incident response procedures are stored only on systems that would be unavailable during the incidents they cover, so staff would have no access to them when needed. That framing is concrete enough to drive action.

7.5.3 Control of documented information

WHAT THE CONTROL ASKS FOR

Documented information must be available and suitable for use where and when it is needed, and adequately protected from loss of confidentiality, improper use, or loss of integrity. The organization must address distribution, access, retrieval, use, storage, preservation, version control, retention, and disposition. Documents of external origin that the organization needs must also be identified and controlled.

WHY IT EXISTS

The ISMS documentation set is itself an information asset, and often a sensitive one. Network diagrams, risk registers, and incident procedures are exactly what an attacker wants. This clause requires the organization to apply its own principles to its own governance material, which is frequently overlooked.

HOW TO AUDIT IT

1. Test access controls on the documentation repository. Confirm restriction is by need, and check whether sensitive items such as the risk register and network diagrams are more tightly controlled than general policies.
2. Test retrieval under pressure. Ask a staff member to locate a specific current procedure and time it. Slow or failed retrieval is a real operational finding.
3. Verify version control prevents superseded documents from circulating, and check whether obsolete versions are marked as such or removed.
4. Confirm retention and disposition are applied, including secure destruction where required.
5. Check control of external documents such as standards, regulatory guidance, and supplier procedures, confirming the versions relied on are current.
6. Confirm backup and recovery cover the documentation repository itself.

EVIDENCE TO COLLECT

- Access control lists for the documentation repository
- Version control configuration and history for sampled documents
- Retention schedule and evidence of disposal actions
- Register of external documents with version and currency check dates
- Backup records covering the repository
- Retrieval test results

HOW TO DOCUMENT IT

Record the access review as a comparison between who has access and who needs it, with the excess count. Document the retrieval test with the exact request, the person asked, and the elapsed time. For external documents, list each one with the version held and the current published version, since organizations frequently operate against superseded standards without realizing it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's own security documentation, including network diagrams and risk registers, is accessible to a far wider group than needs it, concentrating a significant amount of attack-useful information in a poorly protected location. Give the access count versus the justified count.

8.1 Operational planning and control

WHAT THE CONTROL ASKS FOR

Plan, implement, and control the processes needed to meet security requirements and to carry out the actions determined in Clause 6. Keep documented information sufficient to have confidence the processes were carried out as planned. Control planned changes and review the consequences of unintended changes, taking action to mitigate adverse effects. Also ensure that externally provided processes relevant to the ISMS are controlled.

WHY IT EXISTS

This is where planning becomes operation. The specific requirement to review unintended changes matters: emergency fixes, shadow IT, and configuration drift all produce changes nobody planned, and they routinely undo controls silently. The clause also closes the outsourcing gap, since delegating a process does not delegate the obligation.

HOW TO AUDIT IT

1. Confirm operational processes exist for the security activities the organization committed to, and that they are performed at the stated frequency.
2. Test that records provide confidence processes ran as planned. A process performed with no record is unverifiable regardless of whether it happened.
3. Sample unplanned or emergency changes and confirm each was reviewed afterward for security consequences. This is the most commonly missed element.
4. Examine externally provided processes. For each outsourced security-relevant activity, verify a defined control mechanism such as contractual requirements, reporting, or audit rights, and evidence it is exercised.
5. Look for configuration drift by comparing a documented standard build or configuration baseline against a sample of live systems.

EVIDENCE TO COLLECT

- Operational procedures for security processes with stated frequencies
- Records demonstrating execution: completed checklists, tickets, logs, sign-offs
- Emergency change records and post-implementation security reviews
- Contracts and service descriptions for outsourced security processes
- Reports received from providers and evidence they were reviewed
- Configuration baselines and comparison results against live systems

HOW TO DOCUMENT IT

For each sampled process, record the required frequency, the dates it was actually performed in the period, and any gaps. Present emergency change testing as a table of change reference, date, and whether a security review followed. For outsourced processes, name the provider, the process, the control mechanism, and the date the mechanism was last exercised.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security-relevant processes have been outsourced without any mechanism to verify the provider performs them, so the organization is relying on assurance it has never tested. Name the providers and processes. For change control, state that emergency changes bypass security review entirely and give the volume of such changes in the period, which is usually larger than management expects.

8.2 Performing information security risk assessment

WHAT THE CONTROL ASKS FOR

Actually perform risk assessments at planned intervals and whenever significant changes are proposed or occur. Retain documented information about the results. Clause 6.1.2 requires you to define the process; this clause requires you to run it, on schedule and on trigger.

WHY IT EXISTS

A well-designed risk assessment methodology that is executed once and then left alone is worth very little. Risk changes as the business changes. The trigger-based requirement exists because scheduled assessments always lag reality, and the changes most likely to introduce risk are exactly the ones that will not wait for the annual cycle.

HOW TO AUDIT IT

1. Compare the required assessment frequency to the dates assessments were actually performed. Late is a finding, and repeated lateness is a systemic one.
2. Identify significant changes in the period independently, using change records, project lists, and press releases, then check whether each triggered an assessment.
3. Confirm the trigger for change-based assessment is defined. If nobody has defined what counts as significant, the trigger cannot be applied consistently.
4. Verify results are retained as documented information with enough detail to reconstruct the conclusion, not just a final score.
5. Compare successive assessments for genuine reassessment rather than a copied register with a new date.

EVIDENCE TO COLLECT

- Risk assessment schedule and records of actual performance with dates
- Definition of what constitutes a significant change
- Independent list of significant changes in the period
- Change-triggered assessment records
- Successive versions of the risk register for comparison
- Participant lists and session records

HOW TO DOCUMENT IT

Present a two-column list of significant changes you identified and whether an assessment followed each. Identifying changes independently rather than accepting the organization's list is what gives this test its value, so record your sources. For the copy-forward test, note specific entries that are identical across versions and how much time elapsed between them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: major business changes, including a named acquisition or system migration, were implemented without any assessment of the security risks they introduced. Naming the specific change makes this land. If the issue is copy-forward, state that the risk register has not materially changed in a stated number of years despite substantial change in the business.

8.3 Performing information security risk treatment

WHAT THE CONTROL ASKS FOR

Implement the risk treatment plan and retain documented information about the results. The plan agreed under 6.1.3 has to be carried out, and there must be records showing it was.

WHY IT EXISTS

The gap between agreed remediation and completed remediation is where most residual risk actually lives. Organizations are generally good at deciding what to do and much weaker at finishing. Requiring retained results makes completion evidenced rather than asserted.

HOW TO AUDIT IT

1. Take the risk treatment plan and test completion status for a sample, verifying each claimed completion against independent evidence rather than the status field.
2. Age the open items against their original committed dates, not against revised dates, and note how many times each date has been moved.
3. For completed items, confirm the treatment actually reduced the risk as intended, and check whether the risk register was updated to reflect the new residual level.
4. Identify items closed without completion, such as those closed by risk acceptance after the fact, and confirm the acceptance was approved by the risk owner.
5. Check whether resource constraints are causing systematic non-completion, and link to Clause 7.1 if so.

EVIDENCE TO COLLECT

- Risk treatment plan with original and current target dates
- Independent completion evidence for sampled items, such as configuration exports, tickets, or screenshots
- Updated risk register showing revised residual risk after treatment
- Records of date revisions with justification
- Late-stage risk acceptance approvals

HOW TO DOCUMENT IT

Produce an aging table showing item, original due date, current due date, number of revisions, and days overdue against the original. The revision count column is the one that reveals systemic slippage. For each sampled completion, name the independent evidence you inspected and state whether it supported the claimed status.

EXECUTIVE SUMMARY TREATMENT

Strong candidate for the executive summary because it is quantitative and unambiguous. Suggested language: a stated number of agreed security remediations are past their original committed dates, with the oldest outstanding for a stated period, meaning risks the organization decided to fix remain live. Include the aging table if space allows.

9.1 Monitoring, measurement, analysis and evaluation

WHAT THE CONTROL ASKS FOR

Determine what needs monitoring and measuring, the methods to use, when to perform it, and who performs it, plus when results are analyzed and evaluated and by whom. The methods must produce valid results, meaning comparable and reproducible. Retain documented information as evidence, and evaluate both security performance and ISMS effectiveness.

WHY IT EXISTS

Without measurement, an organization cannot distinguish a program that is working from one that is merely busy. The validity requirement is the point of difficulty: many security metrics measure activity rather than effect, such as counting alerts handled without knowing how many were missed.

HOW TO AUDIT IT

1. Obtain the measurement plan and confirm it specifies what, how, when, and by whom, for both performance and effectiveness.
2. Assess validity. For each sampled metric, ask whether repeating the measurement would produce the same result and whether it measures the outcome or only the activity.
3. Distinguish performance measurement from effectiveness evaluation. Many organizations do the first and none of the second. Effectiveness asks whether the control is achieving its purpose.
4. Verify measurement actually occurs at the stated frequency by comparing planned dates to result dates.
5. Confirm results are analyzed and evaluated by a named party, and check that the analysis reached a conclusion rather than simply presenting numbers.
6. Trace a measurement result to a decision. Metrics that never change anything indicate the evaluation step is not functioning.

EVIDENCE TO COLLECT

- Measurement plan naming metrics, methods, frequencies, and responsible parties
- Measurement results across multiple periods
- Analysis and evaluation records with conclusions
- Evidence of decisions driven by measurement results
- Definition and calculation method for each metric
- Source data allowing recalculation

HOW TO DOCUMENT IT

For each sampled metric, record the stated definition, the calculation you were able to reproduce, and whether your figure matched. Independently recalculating one or two metrics is the highest value test here. Record explicitly whether effectiveness evaluation exists separately from performance measurement, since this distinction drives the clause.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization measures security activity but not security outcomes, so it cannot tell whether its controls are working, only that they are running. Give an example, such as reporting the number of vulnerabilities scanned without reporting how long known critical vulnerabilities remain unremediated. Concrete contrasts like this communicate faster than a description of the gap.

9.2 Internal audit

WHAT THE CONTROL ASKS FOR

Conduct internal audits at planned intervals to determine whether the ISMS conforms both to the organization's own requirements and to the standard, and whether it is effectively implemented and maintained. Plan, establish, implement, and maintain an audit programme covering frequency, methods, responsibilities, planning requirements, and reporting. Consider the importance of the processes and prior results. Define criteria and scope for each audit, select auditors who ensure objectivity and impartiality, report results to relevant management, and retain documented information.

WHY IT EXISTS

Internal audit is the organization's own detection capability for management system failure. Certification audits are brief and sample lightly; internal audit is what is supposed to find problems between them. The impartiality requirement exists because auditors reviewing their own work do not report their own mistakes.

HOW TO AUDIT IT

1. Obtain the audit programme and confirm it covers the entire ISMS over a defined cycle, including Annex A controls and all management system clauses. Programmes that repeatedly audit the same easy areas are a finding.
2. Verify the programme is risk-based, considering process importance and prior results, rather than a fixed rotation.
3. Test auditor independence for each audit performed. Confirm no auditor audited their own work or reported to the manager of the area audited.
4. Assess auditor competence, linking to Clause 7.2. Internal audit performed by untrained staff produces findings that miss the substance.
5. Compare planned audits to completed audits and examine any that were deferred or cancelled.
6. Review a sample of internal audit reports for depth. Reports with no findings across a whole ISMS usually indicate shallow work rather than an excellent system.
7. Confirm results were reported to relevant management, not just filed.

EVIDENCE TO COLLECT

- Internal audit programme covering the full cycle
- Risk-based rationale for the programme
- Individual audit plans with criteria and scope
- Auditor independence declarations and reporting lines
- Auditor competence records
- Completed audit reports with findings
- Evidence reports were delivered to management, with dates

HOW TO DOCUMENT IT

Produce a coverage map showing every ISMS clause and Annex A theme against the date it was last internally audited. Gaps are immediately visible and hard to argue with. Record independence testing per audit, naming the auditor's role and the audited area's reporting line. Record the finding count per audit, since an unusually low count is itself worth reporting.

EXECUTIVE SUMMARY TREATMENT

Suggested language: internal audits are performed by staff reviewing their own areas of responsibility, so the organization has no independent assurance that its security controls work. Where coverage is the issue, state

the proportion of the system that has not been internally audited within the defined cycle, and name the most significant uncovered area.

9.3 Management review

WHAT THE CONTROL ASKS FOR

Top management must review the ISMS at planned intervals to confirm it remains suitable, adequate, and effective. The review must consider a defined list of inputs including the status of prior actions, changes in relevant internal and external issues, changes in interested party needs, feedback on security performance covering nonconformities, monitoring results, audit results and objective achievement, feedback from interested parties, risk assessment results and treatment plan status, and opportunities for continual improvement. Outputs must include decisions on improvement and any need to change the ISMS. Results must be retained.

WHY IT EXISTS

This is the governance loop that closes the system. It is where evidence from every other process is supposed to reach the people with authority to act. When management review is treated as a status update, the system loses its only mechanism for redirecting itself.

HOW TO AUDIT IT

1. Confirm reviews occurred at the planned frequency, comparing planned dates to actual dates.
2. Check attendance. Top management must attend. A review conducted by the security team and later circulated to management does not satisfy the clause.
3. Verify every required input was presented. Work through the list item by item against the pack and the minutes. Missing inputs are straightforward nonconformities and are common.
4. Test the outputs. Look for decisions with owners and dates, not observations. Minutes that record discussion without decision fail the output requirement.
5. Trace prior actions forward. Confirm actions from the previous review were followed up in the current one, with status.
6. Assess whether the review reached a conclusion on suitability, adequacy, and effectiveness. These three words should appear as an explicit judgment.

EVIDENCE TO COLLECT

- Management review schedule and actual meeting dates
- Attendance records identifying roles
- Review packs or input documents
- Minutes recording discussion, decisions, owners, and dates
- Action tracker showing prior actions and their closure
- Explicit statement of conclusions on suitability, adequacy, and effectiveness

HOW TO DOCUMENT IT

Use a checklist table listing every required input against present or absent, with the page reference in the review pack where present. This is the single most efficient test in the clause. Record outputs separately, distinguishing decisions from observations. For prior action follow-through, show the action, its original date, and its status at the following review.

EXECUTIVE SUMMARY TREATMENT

Suggested language: management reviews of the security program do not consider the results of internal audits or the status of outstanding risks, so leadership is approving a system it has not been shown the problems with. Name the specific missing inputs. If actions are the issue, state how many decisions from prior reviews remain open and for how long.

10.1 Continual improvement

WHAT THE CONTROL ASKS FOR

Continually improve the suitability, adequacy, and effectiveness of the ISMS. The clause is one sentence and has no prescribed method. It is tested by looking for evidence that the system is deliberately getting better over time, driven by the outputs of measurement, audit, review, and incidents.

WHY IT EXISTS

Threats change, the business changes, and a static system falls behind without anyone deciding to let it. Continual improvement is the requirement that makes stagnation a nonconformity. It also distinguishes a live management system from a certification maintained by annual repair work.

HOW TO AUDIT IT

1. Ask for a list of improvements made in the period and the trigger for each. Improvements with no traceable trigger are usually projects relabelled as improvements.
2. Confirm improvement is driven by the system's own outputs: measurement results, audit findings, management review decisions, incidents, and risk changes.
3. Distinguish improvement from correction. Fixing a broken control is corrective action under 10.2. Improvement raises capability beyond the prior baseline.
4. Assess whether improvements were evaluated for effect. An improvement nobody measured is an assumption.
5. Look at trend data across multiple periods. Flat or worsening trends alongside claimed improvement warrant challenge.

EVIDENCE TO COLLECT

- Improvement register or log with triggers and outcomes
- Evidence linking improvements to audit findings, measurement results, or review decisions
- Before and after measurement for sampled improvements
- Multi-period trend data for key metrics
- Management review outputs directing improvement

HOW TO DOCUMENT IT

Record improvements in a table of improvement, trigger, date, and measured effect. The trigger column is what separates genuine continual improvement from ordinary project work. Where effect was not measured, say so directly rather than describing the improvement as unverified.

EXECUTIVE SUMMARY TREATMENT

Rarely a standalone executive item, but useful as a summary theme. Suggested language: the security program has not measurably improved over the review period, and the changes described as improvements were not evaluated for effect. Support with the trend data, which is more persuasive than the absence of a register.

10.2 Nonconformity and corrective action

WHAT THE CONTROL ASKS FOR

When a **nonconformity** occurs, react to it and take action to control and correct it, and deal with the consequences. Then evaluate whether action is needed to eliminate the cause so it does not recur, by reviewing the nonconformity, determining its causes, and checking whether similar ones exist or could occur. Implement any action needed, review its effectiveness, and change the ISMS if necessary. Retain documented information on the nature of the nonconformity, the actions taken, and the results. A nonconformity is any failure to meet a requirement, whether from the standard, your own policy, or a legal or contractual obligation.

WHY IT EXISTS

The distinction between correction and corrective action is the entire point. Correction fixes the instance; corrective action fixes the cause. Organizations that only correct will keep seeing the same failure, which is why auditors look at recurrence patterns before they look at closure rates.

HOW TO AUDIT IT

1. Confirm nonconformities from all sources are captured in one process: internal audit, external audit, incidents, monitoring, and self-identification. Self-identified nonconformities being absent is a signal that the process is externally driven only.
2. For a sample, verify both correction and cause analysis were performed, and that the recorded cause is an actual cause rather than a restatement of the symptom. Human error is a symptom, not a cause.
3. Check the similar-occurrence review. Confirm the organization asked where else the same weakness exists, and record what it found.
4. Verify effectiveness review after closure, performed far enough after implementation to be meaningful.
5. Analyze recurrence across periods. Repeating nonconformities indicate cause analysis is not working, regardless of individual closure records.
6. Confirm retained records cover nature, actions, and results for each nonconformity.

EVIDENCE TO COLLECT

- Nonconformity and corrective action register covering all sources
- Root cause analysis records for sampled items
- Similar-occurrence review results
- Effectiveness review records with dates after implementation
- Multi-period data showing recurrence
- Closure approvals and supporting evidence

HOW TO DOCUMENT IT

For each sampled item, record the stated cause and your assessment of whether it is a cause or a symptom, with reasoning. This is the judgment that carries the clause. Present recurrence analysis as a count of nonconformities by type across periods. Record the interval between implementation and effectiveness review, since reviews performed the same day are not meaningful.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the same control failures recur across audit cycles because the organization fixes individual instances without addressing why they happen, so remediation effort is being spent repeatedly on the same problems. That framing turns a process finding into a cost argument, which tends to get resourced. Give the count of repeat findings and the number of cycles they have persisted across.

Annex A.5: Organizational Controls

Thirty-seven controls, the largest of the four themes and the one that carries the governance weight of Annex A. These are the controls that establish who decides what, how the organization relates to its suppliers and regulators, how information is classified and shared, and how incidents are handled. Very few of them are technical. Most fail for the same reason: someone was supposed to do something on a schedule and nobody checked whether they did.

A word on numbering. The 2022 revision reorganized Annex A from fourteen domains into four themes, and merged, split, or dropped a number of the older controls. If you are working from a 2013-era control set, the mapping is not one to one and you should not assume your old evidence still lands in the right place.

The controls in this theme are also where a Statement of Applicability is most often wrong. Exclusions here are usually justified on the basis that the organization is small or does not do a particular activity, and both justifications deserve testing.

Quick reference: A.5 Organizational

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **CYB** or **AI** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.5.1	Policies for information security	Overarching information security policy, approved and dated
A.5.2	Information security roles and responsibilities	Security roles and responsibilities matrix or RACI
A.5.3	Segregation of duties	Documented conflicting duty matrix
A.5.4	Management responsibilities	Management job descriptions and performance objectives containing security duties
A.5.5	Contact with authorities	Authority contact register with jurisdictions, roles, contact routes, and last verification date
A.5.6	Contact with special interest groups	List of group memberships, subscriptions, and sharing arrangements
A.5.7 CYB	Threat intelligence	List of intelligence sources with types and coverage
A.5.8	Information security in project management	Project management methodology showing security gates
A.5.9	Inventory of information and other associated assets	Asset inventory with classification, owner, and location
A.5.10 CYB/AI	Acceptable use of information and other associated assets	Acceptable use policy or rules, current version
A.5.11	Return of assets	Offboarding procedure including asset return

Ref	Title	Primary evidence
A.5.12	Classification of information	Classification scheme with level definitions and criteria
A.5.13	Labelling of information	Labelling procedures per media type
A.5.14 CVB	Information transfer	Transfer rules and procedures per channel
A.5.15 CVB	Access control	Access control policy stating the granting basis
A.5.16 CVB	Identity management	Identity inventory or directory export
A.5.17 CVB	Authentication information	Credential issuance and reset procedures with verification steps
A.5.18 CVB	Access rights	Access request and approval records for sampled grants
A.5.19 CVB	Information security in supplier relationships	Supplier register with risk tier, owner, and assessment status
A.5.20 CVB	Addressing information security within supplier agreements	Executed supplier agreements for sampled suppliers
A.5.21 CVB	Managing information security in the ICT supply chain	Technology supply chain mapping or dependency register
A.5.22 CVB	Monitoring, review and change management of supplier services	Supplier monitoring plan with frequency by risk tier
A.5.23 CVB/AI	Information security for use of cloud services	Inventory of cloud services with owner, data held, and criticality
A.5.24 CVB	Information security incident management planning and preparation	Incident response plan with roles, authorities, and escalation paths
A.5.25 CVB	Assessment and decision on information security events	Event classification criteria and severity definitions
A.5.26 CVB	Response to information security incidents	Incident records for sampled incidents with full timeline
A.5.27 CVB	Learning from information security incidents	Post-incident review reports with cause analysis
A.5.28 CVB	Collection of evidence	Evidence handling and chain of custody procedures
A.5.29 CVB	Information security during disruption	Business continuity and disaster recovery plans with security provisions
A.5.30 CVB	ICT readiness for business continuity	Documented recovery objectives per service with business sign-off
A.5.31	Legal, statutory, regulatory and contractual requirements	Legal and regulatory obligations register with owner and approach per entry
A.5.32	Intellectual property rights	Software asset management records reconciling installations to entitlements
A.5.33	Protection of records	Retention schedule with periods and legal basis
A.5.34 AI	Privacy and protection of personally identifiable information	Record of processing activities
A.5.35	Independent review of information security	Independent review reports with scope, method, and findings
A.5.36	Compliance with policies, rules and standards for information security	Compliance checking programme with scope and frequency
A.5.37	Documented operating procedures	Inventory of operational procedures against critical systems

A.5.1 Policies for information security

WHAT THE CONTROL ASKS FOR

Have a security policy and supporting topic-specific policies. Get them approved by management, publish them, tell the people they apply to, make those people acknowledge them, and review them on a schedule and after significant change. Topic-specific policies are the narrower documents beneath the main policy, covering areas like access control, acceptable use, or cryptography.

WHY IT EXISTS

Policy is the authority behind every security requirement you will ever enforce. Without it, a security instruction is one team's preference and staff can decline it without consequence. The review requirement exists because policies age badly; a policy written before the organization moved to cloud infrastructure will contain requirements nobody can meet, which teaches staff that policies can be ignored.

HOW TO AUDIT IT

1. Obtain the policy set and confirm both the overarching policy and the topic-specific policies exist. Check for coverage gaps against the areas the organization actually operates in.
2. Verify approval by an authority with the standing to approve, with a date and an identifiable approver.
3. Test communication and acknowledgement. Pull acknowledgement statistics against the full population including contractors, and compute the coverage percentage yourself rather than accepting a reported figure.
4. Check the review cycle. Confirm a defined frequency, then compare the last review date to it. Also confirm reviews were triggered by significant changes such as a major system migration.
5. Test whether policies match practice. Pick two specific requirements and verify them operationally. A policy requiring quarterly access reviews in an organization that performs them annually is a finding against this control, not just against access control.
6. Check readability and reachability. Ask two staff to find the policy that governs a task they perform.

EVIDENCE TO COLLECT

- Overarching information security policy, approved and dated
- Full set of topic-specific policies with owners and versions
- Approval records identifying approver and date
- Acknowledgement records reconciled to a complete population list
- Review log with scheduled and actual review dates
- Change records showing policy review triggered by significant change
- Policy repository access and search evidence

HOW TO DOCUMENT IT

List every policy with version, approval date, last review date, and next due date in a single table; overdue rows are then self-evident. Record acknowledgement coverage as a fraction with the population source and date pulled. For the practice test, record the policy clause quoted and the operational reality observed, side by side.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's security policies require practices it does not perform, which undermines the credibility of every other requirement staff are asked to follow. Name one or two specific mismatches. Where coverage is the issue: a stated percentage of the workforce has never acknowledged the policies governing their access to company information.

A.5.2 Information security roles and responsibilities

WHAT THE CONTROL ASKS FOR

Define and allocate security roles and responsibilities according to the organization's needs. This is the operational counterpart to Clause 5.3. Where Clause 5.3 addresses the management system roles, this control addresses security responsibilities across the whole organization, including asset owners, risk owners, system administrators, and ordinary users.

WHY IT EXISTS

Security work that belongs to everyone belongs to nobody. When responsibilities are undefined, the tasks that get done are the ones somebody personally cares about, and the rest quietly lapse. Defined allocation also makes handover survivable, which matters more than most organizations realize until someone resigns.

HOW TO AUDIT IT

1. Obtain the responsibility allocation and confirm it covers the operational security duties, not only the governance ones.
2. Sample duties that commonly go unassigned: log review, certificate renewal, firewall rule review, third-party access recertification, backup restoration testing.
3. For each sampled duty, identify the named owner and verify with that person that they know they own it.
4. Check that allocation is current against the employee directory, looking for departed or transferred staff.
5. Confirm responsibilities are reflected where they have force, such as job descriptions or objectives, rather than only in a matrix nobody reads.
6. Test one duty for actual performance. An assigned but unperformed duty is a different finding from an unassigned one, and both are worth reporting.

EVIDENCE TO COLLECT

- Security roles and responsibilities matrix or RACI
- Job descriptions containing security duties
- Current employee directory for reconciliation
- Performance records for sampled duties, such as completed log reviews
- Handover documentation for recent role changes
- Deputy assignments for critical duties

HOW TO DOCUMENT IT

Record the sampled duties in a table showing duty, documented owner, owner confirmed yes or no, and evidence of recent performance. This three-way test distinguishes paper allocation from working allocation and is the core of the control. Note every duty you could not find an owner for, since those are usually the ones already failing.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security duties including a named example are not assigned to anyone, and consequently have not been performed for a stated period. Naming the specific unperformed duty and its duration is far more effective than describing the allocation process as immature.

A.5.3 Segregation of duties

WHAT THE CONTROL ASKS FOR

Separate conflicting duties and areas of responsibility so that no single person can carry out a sensitive process end to end without oversight. Where separation is impractical, put compensating measures in place, such as monitoring, logging, or after-the-fact review by an independent party.

WHY IT EXISTS

Concentrated authority is the enabling condition for both fraud and undetected error. A person who can create a supplier, approve it, and pay it can steal without collusion. In IT the equivalent is a person who can write code, approve it, and deploy it to production. Separation makes wrongdoing require cooperation, which raises its cost and its detectability.

HOW TO AUDIT IT

1. Identify the conflicting duty pairs relevant to the organization. Typical pairs include develop and deploy, request access and approve access, administer a system and review its logs, and create a payment and release it.
2. For each pair, test technically rather than by policy. Pull the actual permission assignments and look for individuals holding both sides.
3. Pay particular attention to privileged and emergency accounts, which frequently defeat segregation by design.
4. Where separation is not achieved, verify the compensating measure exists, is documented, and is operating. A stated compensating control nobody performs is worse than an acknowledged gap.
5. Test the compensating review for independence. Review of an administrator's actions by that administrator's own account is not a compensating measure.
6. Check small teams honestly. In a team of three, full separation may be impossible; the finding is then about the adequacy of compensating measures, not the absence of separation.

EVIDENCE TO COLLECT

- Documented conflicting duty matrix
- Permission or role assignment exports from key systems
- Privileged account inventory with assigned holders
- Compensating control descriptions and evidence of operation, such as completed review records
- Change deployment records showing author and approver identities
- Emergency access procedures and usage logs

HOW TO DOCUMENT IT

Present the technical test as a table of conflicting pair, individuals holding both sides, and the compensating measure with its last performance date. Extracting permissions yourself rather than accepting a report is what gives this test weight, so record the extraction method and date. Where the team is genuinely too small, say so and shift the finding to compensating adequacy.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of individuals can complete sensitive processes end to end without any independent check, including the ability to move code into production without review. Give the count and name the most consequential combination. Executives grasp this control quickly because it maps to financial controls they already accept.

A.5.4 Management responsibilities

WHAT THE CONTROL ASKS FOR

Management at all levels must require their people to apply security in line with the organization's policies, procedures, and topic-specific policies. This is about line managers, not just top management. It puts the obligation to enforce security on the person who supervises the work.

WHY IT EXISTS

Security teams cannot supervise everyone. Compliance happens or fails at the point where a manager either does or does not insist on it. When line managers treat security as an obstacle to delivery, staff follow their manager, not the policy. This control makes managerial reinforcement an explicit expectation rather than a hope.

HOW TO AUDIT IT

1. Confirm managerial security responsibilities are defined somewhere with force, such as management job descriptions or performance objectives.
2. Interview line managers outside the security function. Ask what they are expected to do about security in their team and what they actually do.
3. Look for evidence of managers enforcing rather than merely permitting: approvals refused, exceptions challenged, training completion chased.
4. Examine exception requests. Managers routinely approving exceptions for their own teams without security involvement indicates the responsibility is not understood as an enforcement duty.
5. Check whether security is part of manager onboarding and whether new managers receive any instruction on their security duties.
6. Correlate with awareness completion rates by department. Departments with persistently low completion usually point to a manager who does not enforce.

EVIDENCE TO COLLECT

- Management job descriptions and performance objectives containing security duties
- Manager onboarding materials
- Exception request records with approver identity
- Awareness and training completion rates broken down by department or manager
- Records of managerial enforcement actions
- Interview notes from line managers

HOW TO DOCUMENT IT

Present completion rates by department alongside the responsible manager, which turns a diffuse cultural observation into a specific and actionable one. Record manager interview answers close to verbatim; the gap between what managers say they are expected to do and what is written down is usually the substance of the finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security requirements are not reinforced by line management, so compliance varies substantially between departments with no accountability for the difference. Support it with the departmental completion table. Avoid framing this as a culture problem; frame it as an unassigned managerial duty, which is fixable.

A.5.5 Contact with authorities

WHAT THE CONTROL ASKS FOR

Establish and maintain contact with relevant authorities. Authorities means regulators, data protection supervisory bodies, law enforcement, national cyber security centres, and sector regulators. The point is to have working relationships and known contact routes before you need them, plus a defined process for when and how to make contact.

WHY IT EXISTS

During a serious incident you may have a legal duty to notify a regulator within a short window, sometimes 72 hours or less. An organization discovering during an incident that it does not know which regulator to call, or which portal to use, will miss deadlines. Pre-existing contact also means law enforcement engagement is faster when it matters.

HOW TO AUDIT IT

1. Obtain the list of relevant authorities and confirm it is complete for the organization's jurisdictions, sectors, and data types.
2. Verify contact details are current and were checked within a defined period. Ask when they were last verified and how.
3. Confirm a defined process for when to contact each authority, including who decides and who is authorized to make contact.
4. Check notification deadlines are recorded against each authority, since these vary and being wrong about them is costly.
5. Test with a real example if one exists. If an incident occurred, compare actual notification timing against the requirement.
6. For organizations operating in multiple countries, confirm each jurisdiction is covered rather than only the headquarters country.

EVIDENCE TO COLLECT

- Authority contact register with jurisdictions, roles, contact routes, and last verification date
- Notification decision procedure with named decision authority
- Recorded notification deadlines per authority and per obligation type
- Evidence of any actual contact, including registrations with national cyber bodies
- Incident records showing notification decisions and timing
- Legal or external counsel arrangements for notification support

HOW TO DOCUMENT IT

Record the register contents with the last verification date for each entry, and flag any entry unverified within the last twelve months. Where a jurisdiction is missing, name it and state the obligation that applies there. If an actual notification occurred, document the timeline in hours against the deadline.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not maintain current notification routes for the regulators it is legally obliged to inform after a breach, creating penalty exposure that is independent of the incident itself. Name the jurisdictions affected and the applicable deadline. This lands well because the exposure is regulatory and quantifiable.

A.5.6 Contact with special interest groups

WHAT THE CONTROL ASKS FOR

Maintain contact with special interest groups, specialist security forums, and professional associations. This is about staying connected to the wider security community so that emerging threats, vulnerabilities, and practices reach you through channels other than public news.

WHY IT EXISTS

Threat information is time sensitive and the useful version usually circulates in trusted communities before it becomes general knowledge. An organization with no such connections learns about relevant threats late. It is a low-cost control with an outsized effect on how early you can react.

HOW TO AUDIT IT

1. Identify which groups, forums, sector sharing bodies, and vendor advisory channels the organization participates in.
2. Confirm participation is active rather than nominal. Membership with no attendance and no consumed feeds is not participation.
3. Check that information received is routed somewhere useful. Ask how an advisory received through these channels reaches the people who would act on it.
4. Test with an example. Pick a significant vulnerability disclosed in the period and ask how the organization first learned of it and when.
5. Confirm participation does not depend on a single individual, since these relationships often leave with the person who held them.
6. Verify that information sharing outward respects confidentiality obligations.

EVIDENCE TO COLLECT

- List of group memberships, subscriptions, and sharing arrangements
- Attendance or participation records
- Examples of advisories received and the resulting internal action
- Routing procedure showing how external intelligence reaches decision makers
- Timeline evidence for a sampled vulnerability
- Named participants and their deputies

HOW TO DOCUMENT IT

The valuable evidence here is the timeline test, so document it precisely: vulnerability, public disclosure date, date the organization became aware, source of awareness, and date of first action. Record memberships in a simple list with an activity indicator rather than assessing them qualitatively.

EXECUTIVE SUMMARY TREATMENT

Rarely an executive item alone. Where it matters: the organization learns about threats relevant to its technology stack only after they are widely publicized, giving it a stated number of days less warning than peers. Use the timeline as support.

A.5.7 Threat intelligence

WHAT THE CONTROL ASKS FOR

Collect and analyze information about threats, and use the result to inform action. This control was new in the 2022 revision. It covers strategic intelligence about who might target you and why, tactical intelligence about how they operate, and operational intelligence about specific active campaigns. The requirement is not just to collect but to analyze and act.

WHY IT EXISTS

Generic security spending defends against generic threats. Knowing that your sector is being targeted by a specific technique lets you prioritize the defenses that matter for your actual risk. The analysis requirement exists because raw feeds are noise; unanalyzed intelligence produces alert fatigue rather than better defense.

HOW TO AUDIT IT

1. Identify the intelligence sources in use and whether they cover the strategic, tactical, and operational levels or only one.
2. Confirm relevance filtering. Intelligence must be assessed for applicability to this organization's technology, sector, and geography.
3. Verify analysis actually occurs and is documented. Look for someone reaching conclusions, not just forwarding feeds.
4. Trace intelligence to action. Pick two intelligence items and follow them to a change: a detection rule, a patch priority, a risk register update, or an accepted decision not to act.
5. Check integration with the risk assessment. Threat intelligence that never updates the risk register is not informing risk decisions.
6. Confirm the process runs on a defined cadence with a named owner.

EVIDENCE TO COLLECT

- List of intelligence sources with types and coverage
- Analysis products such as briefings, assessments, or summaries with dates and authors
- Records showing intelligence-driven changes to detection, patching, or configuration
- Risk register entries updated as a result of intelligence
- Process document with owner and cadence
- Distribution records showing who receives intelligence output

HOW TO DOCUMENT IT

Document the two traced items end to end: source, date received, analysis performed, decision reached, action taken, and date. Two complete traces demonstrate the control works better than any description of the process. Where intelligence is collected but not analyzed, state the volume received and the number of analysis products produced, which usually makes the gap obvious.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization subscribes to threat intelligence but does not analyze it, so it is paying for information that does not change any security decision. That framing as wasted spend rather than as a missing capability tends to get faster attention. If the gap is complete absence, state that security investment is not informed by any assessment of who is likely to attack the organization or how.

A.5.8 Information security in project management

WHAT THE CONTROL ASKS FOR

Integrate security into project management, for all projects, not only IT projects. Security requirements must be identified and addressed early and throughout the project lifecycle, and security risks must be assessed as part of project risk management.

WHY IT EXISTS

Security added at the end of a project is expensive, incomplete, or skipped because the deadline has arrived. Building it into the project process means requirements are known while design decisions are still open. The extension to non-IT projects matters because office moves, outsourcing arrangements, and business restructures all create security consequences.

HOW TO AUDIT IT

1. Obtain the project management methodology and confirm security appears as a defined activity with a gate, not as optional guidance.
2. Sample recent projects across types, including at least one non-IT project, and verify security involvement actually occurred.
3. Check timing. Determine at which stage security was engaged. Engagement at user acceptance testing is too late and is a common pattern.
4. Verify security risks were assessed within project risk management and, where material, escalated to the organizational risk register.
5. Look for projects that bypassed the process entirely, using finance records or vendor onboarding records rather than the project register, since unregistered projects will not appear on the register.
6. Confirm security sign-off before go-live, and check whether any project went live with unresolved security items and how that was authorized.

EVIDENCE TO COLLECT

- Project management methodology showing security gates
- Project documentation for sampled projects, including risk logs and security requirements
- Evidence of security engagement with dates relative to project stages
- Go-live approvals including security sign-off
- Records of accepted security items at go-live and who authorized them
- Finance or procurement records used to identify unregistered projects

HOW TO DOCUMENT IT

For each sampled project, record project name, start date, date security was first engaged, and the project stage at that point. The stage-of-engagement column is what turns a subjective concern into evidence. Record any projects identified through finance records that were absent from the project register, since that is a distinct and often significant finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security is engaged after design decisions are final on most projects, so security requirements are either retrofitted at extra cost or waived to meet delivery dates. Give the number of projects that went live with unresolved security items in the period and who authorized the waivers. If shadow projects exist, state how many were identified that never entered the project process at all.

A.5.9 Inventory of information and other associated assets

WHAT THE CONTROL ASKS FOR

Develop and maintain an inventory of information and the assets associated with it, including owners. Assets here means more than hardware: it covers information itself, software, services, facilities, and the people whose knowledge matters. Each asset needs an identified owner who is accountable for it through its lifecycle.

WHY IT EXISTS

You cannot protect what you do not know you have. Unknown assets receive no patching, no monitoring, and no backup, and they are disproportionately represented in breach reports. Ownership matters as much as the list, because an asset with no owner has nobody to make decisions about it.

HOW TO AUDIT IT

1. Obtain the inventory and assess completeness against independent sources: network discovery output, cloud provider console listings, software licence records, and expense claims for unmanaged subscriptions.
2. Test in both directions. Confirm inventory entries exist in reality, and confirm discovered assets exist in the inventory. The second direction finds far more.
3. Verify each sampled asset has a named individual owner, not a team or a department.
4. Confirm the inventory covers information assets and services, not just devices. Most inventories are hardware lists in disguise.
5. Check currency. Compare recently acquired and recently disposed assets against the inventory and measure the lag in days.
6. Confirm cloud and software-as-a-service assets are included, since these are the most commonly omitted category.

EVIDENCE TO COLLECT

- Asset inventory with classification, owner, and location
- Independent discovery output from network scanning or endpoint management
- Cloud provider resource listings
- Software licence and subscription records including corporate card spend
- Procurement and disposal records for the period
- Owner confirmation for a sample of assets

HOW TO DOCUMENT IT

Present the reconciliation as counts: assets in the inventory, assets found by discovery, assets in both, and assets found only by discovery. The final number is your finding, and expressing it as a percentage of the total makes it immediately meaningful. List the unmanaged cloud subscriptions found through expense records separately, since these usually surprise management.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of systems holding company information are not on any inventory, meaning they are not patched, monitored, or backed up, and nobody is accountable for them. Give the count and the percentage. If cloud services are the gap, state the number of unmanaged subscriptions found and the annual spend they represent.

A.5.10 Acceptable use of information and other associated assets

WHAT THE CONTROL ASKS FOR

Identify, document, and implement rules for acceptable use of information and assets, and procedures for handling them. People who use or handle organizational assets must be made aware of the requirements. This covers what staff may and may not do with company information, devices, networks, and accounts.

WHY IT EXISTS

Most staff want to do the right thing but cannot infer it. Without stated rules, reasonable people will forward work documents to personal email to work at home, or paste sensitive text into an external tool to summarize it. This control also provides the basis on which misuse can be addressed, since you cannot fairly discipline someone for breaking a rule that was never stated.

HOW TO AUDIT IT

1. Obtain the acceptable use rules and check coverage of the situations that actually arise: personal devices, removable media, personal cloud storage, external AI and productivity tools, personal email, and social media.
2. Confirm the rules are current. Rules that predate the organization's adoption of a major tool category will not address it.
3. Test awareness by asking staff specific scenario questions rather than whether they have read the policy.
4. Verify acknowledgement coverage across the full population including contractors.
5. Check whether handling procedures exist for each classification level, since acceptable use rules that do not vary by sensitivity are usually too coarse to be useful.
6. Look for enforcement evidence. Rules that have never been enforced despite known breaches are not implemented.

EVIDENCE TO COLLECT

- Acceptable use policy or rules, current version
- Handling procedures per classification level
- Acknowledgement records reconciled to full population
- Awareness content covering acceptable use scenarios
- Records of identified misuse and the response taken
- Technical enforcement configuration where applicable, such as data loss prevention rules

HOW TO DOCUMENT IT

Record the scenario questions asked and the answers given, since this is a much better measure of implementation than acknowledgement statistics. Note explicitly whether current-generation tool categories are addressed, naming them, because this is where most acceptable use policies are now out of date. Document any known misuse and what happened.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no stated rules on staff use of external AI and productivity tools, and staff are consequently pasting company information into services with no contractual protection. This is currently the most commonly encountered version of this finding and it gets immediate executive attention. Give any evidence of scale you have.

A.5.11 Return of assets

WHAT THE CONTROL ASKS FOR

Personnel and other interested parties must return all organizational assets in their possession when their employment, contract, or agreement ends or changes. Assets include devices, credentials, tokens, documents, keys, and information held in any form, including on personally owned equipment.

WHY IT EXISTS

Departing staff are a well-documented source of data loss, sometimes deliberate and often incidental. Unreturned devices retain data and unreturned credentials retain access. Role changes matter as much as departures, because assets accumulate across a career and are almost never surrendered when someone moves internally.

HOW TO AUDIT IT

1. Obtain the leaver process and confirm it includes a defined asset return step tied to the asset inventory rather than a generic checklist.
2. Sample recent leavers and verify all assets recorded against them were returned, with dates.
3. Measure the gap between last working day and return date. Long gaps indicate the process runs on goodwill.
4. Include internal movers, not only leavers. This is nearly always the weaker case.
5. Cover contractors and third parties, whose offboarding usually sits outside the human resources process entirely.
6. Check treatment of information on personally owned devices, and confirm there is a defined and legally reviewed method for removing it.
7. Reconcile unreturned assets to a write-off or exception record. Assets simply disappearing from the inventory is a finding in itself.

EVIDENCE TO COLLECT

- Offboarding procedure including asset return
- Leaver list for the period from human resources
- Contractor and third-party termination records
- Asset return records with dates and receiving party
- Internal transfer records
- Exception or write-off records for unreturned assets
- Personal device data removal records

HOW TO DOCUMENT IT

Present sampled leavers in a table showing name or reference, last working day, assets assigned, assets returned, and days elapsed. Report contractors and internal movers separately from employee leavers, because the pass rates usually differ sharply and reporting a blended figure hides the real problem. List every unreconciled asset individually.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices and access credentials remain in the hands of people who no longer work for the organization, the oldest for a stated period. Concrete counts and durations are what drive action here. If internal movers are the gap, state that staff accumulate access and equipment across role changes with no point at which it is surrendered.

A.5.12 Classification of information

WHAT THE CONTROL ASKS FOR

Classify information according to the organization's security needs, based on confidentiality, integrity, and availability requirements and on the expectations of interested parties. The classification scheme has to be defined, applied consistently, and reviewed as information changes in value over time.

WHY IT EXISTS

Protecting everything to the same standard is either unaffordable or inadequate, and usually both at once. Classification is how you direct protection where it is needed. It also gives staff a basis for decisions about sharing, since a person who knows a document is restricted can act on that without asking.

HOW TO AUDIT IT

1. Obtain the classification scheme and assess whether the number of levels is workable. Schemes with six or more levels are generally not applied consistently in practice.
2. Confirm the scheme addresses integrity and availability, not only confidentiality. Most schemes only address confidentiality, which is a partial implementation of this control.
3. Confirm each level has defined criteria that a non-specialist could apply, and defined handling requirements attached.
4. Test application by sampling actual information assets and independently classifying them yourself, then comparing to the recorded classification.
5. Check consistency across similar assets. The same data classified differently in two systems indicates the criteria are not usable.
6. Verify reclassification occurs, particularly declassification of information whose sensitivity has expired.

EVIDENCE TO COLLECT

- Classification scheme with level definitions and criteria
- Handling requirements per level
- Asset inventory showing assigned classifications
- Sample of actual information assets for independent classification
- Reclassification records
- Guidance or training material on applying the scheme

HOW TO DOCUMENT IT

Record your independent classification against the recorded classification in a table, with your reasoning for each disagreement. The disagreement rate is the headline measure of whether the scheme works. State explicitly whether integrity and availability are addressed, since this is a defined requirement of the control and is commonly missed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: information is classified inconsistently, so protection does not track sensitivity and the organization's most valuable information is not reliably its best protected. Support with the disagreement rate from your independent test. Where confidentiality is the only dimension addressed, note that availability and integrity requirements are undefined, which means recovery priorities have never been set.

A.5.13 Labelling of information

WHAT THE CONTROL ASKS FOR

Develop and implement procedures for labelling information in line with the classification scheme. Labels must cover information in all its forms: electronic documents, emails, physical printouts, storage media, and screens. The label is what makes the classification visible at the point of use.

WHY IT EXISTS

A classification nobody can see does not change behavior. Labels let people make correct handling decisions in the moment, and they let technical controls such as data loss prevention act on sensitivity. They also support later investigation, since a leaked document with a visible label makes the breach unambiguous.

HOW TO AUDIT IT

1. Obtain labelling procedures and confirm they cover all media types the organization actually uses.
2. Sample documents, emails, and files and check for correct and present labels. Sample from real working locations rather than from a curated set.
3. Check physical media and printouts, including anything on desks, printers, and in disposal bins during a walkthrough.
4. Verify labels survive common transformations: forwarding an email, converting a document to PDF, exporting from a system.
5. Test whether labelling is enforced or voluntary. Voluntary labelling produces low and inconsistent coverage almost without exception.
6. Confirm external parties can interpret the labels, or that labels intended for external circulation are self-explanatory.

EVIDENCE TO COLLECT

- Labelling procedures per media type
- Sample of labelled and unlabelled documents from live locations
- Email labelling configuration and coverage statistics
- Physical walkthrough observations with dates and locations
- Labelling tool configuration where automated
- Evidence of label persistence through format conversion

HOW TO DOCUMENT IT

Record labelling coverage as a percentage from your own sample, stating the sample size and where you drew it from. Document the walkthrough with location, date, time, and specific observations, since physical evidence is persuasive and easily disputed if vaguely recorded. Note any transformation that strips labels, naming the specific operation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: sensitive information carries no visible marking, so staff handling it have no way to know it requires protection and technical controls cannot act on it. Give your measured coverage percentage. Physical observations from a walkthrough are particularly effective here if you have them.

A.5.14 Information transfer

WHAT THE CONTROL ASKS FOR

Put in place rules, procedures, and agreements covering the transfer of information within the organization and to external parties, for all transfer types: electronic, physical media, and verbal. Verbal transfer is explicitly included and almost always overlooked.

WHY IT EXISTS

Information is most exposed while moving. Transfer is also the point at which control passes to someone else, which is why agreements matter as much as encryption. Including verbal transfer addresses a real exposure: conversations in public places, on calls, and with people whose identity was never verified.

HOW TO AUDIT IT

1. Identify the transfer channels actually in use, including the unsanctioned ones. Ask staff how they send large files, which frequently reveals tools nobody approved.
2. Confirm rules exist per channel with protection requirements appropriate to classification.
3. Verify transfer agreements exist with external parties who regularly receive information, and confirm they include security and return or destruction terms.
4. Test technical protection. Confirm encryption in transit is actually enforced rather than merely available, by checking configuration rather than policy.
5. Check physical media transfer: courier arrangements, tracking, and encryption of media in transit.
6. Address verbal transfer. Look for guidance on discussing sensitive matters in public spaces and on verifying caller identity before disclosing information.
7. Test identity verification on a support channel if one exists, since social engineering succeeds here most often.

EVIDENCE TO COLLECT

- Transfer rules and procedures per channel
- Transfer agreements with external recipients
- Encryption configuration evidence for email and file transfer
- Courier and physical media handling records
- Guidance covering verbal disclosure and caller verification
- List of file transfer tools in use, including unsanctioned ones
- Support channel identity verification procedure and test result

HOW TO DOCUMENT IT

List every transfer channel found, marking each sanctioned or unsanctioned, with the protection applied. The unsanctioned column usually carries the finding. Where you tested caller verification, record exactly what you asked and what was disclosed, since this evidence is compelling and is occasionally disputed. Note verbal transfer explicitly even if only to record that it is unaddressed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff routinely send company information through file transfer services the organization has no agreement with and no visibility of, because sanctioned channels cannot handle the file sizes they work with. Naming the business cause alongside the finding makes the recommendation obvious and prevents the response from being a prohibition that will be ignored.

A.5.15 Access control

WHAT THE CONTROL ASKS FOR

Establish and implement rules controlling physical and logical access to information and assets, based on business and security requirements. This is the umbrella control for access. It requires a defined access control policy that states the basis for granting access, typically need to know and least privilege, and its consistent application.

WHY IT EXISTS

Access is the mechanism through which almost every breach is ultimately realized. Whether the attacker is external or internal, the damage they cause is bounded by what the compromised identity could reach. Least privilege is the single most effective limit on breach impact, and it is the one most often eroded over time.

HOW TO AUDIT IT

1. Obtain the access control policy and confirm it states the granting basis and covers both physical and logical access.
2. Confirm the policy addresses the full lifecycle: request, approval, provisioning, modification, review, and revocation.
3. Test least privilege in practice by sampling users and comparing actual permissions to job requirements. Sample across roles including long-tenured staff, who typically accumulate the most.
4. Examine privileged access separately: how many accounts hold administrative rights, who holds them, and whether they are used for daily work.
5. Check for standing access that should be temporary, such as break-glass accounts left permanently enabled.
6. Test that access rules are enforced technically rather than by convention.
7. Look at shared and service accounts, confirming ownership and accountability for each.

EVIDENCE TO COLLECT

- Access control policy stating the granting basis
- Permission exports from key systems
- Privileged account inventory with justification per holder
- Job descriptions for sampled users
- Shared and service account register with named owners
- Break-glass account configuration and usage logs
- Access request and approval records

HOW TO DOCUMENT IT

Present the least privilege test as a table of user, role, permissions held, permissions justified, and excess. Correlating excess against tenure is a useful additional column, because it demonstrates accumulation rather than a one-off error and points at the review process as the cause. Report privileged account counts as a ratio to total users, which gives an immediately interpretable figure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of staff hold access well beyond what their role requires, concentrated among long-serving employees whose access has accumulated across role changes. This means the compromise of any one of those accounts would expose substantially more than it should. Give the privileged account count and ratio, which executives find easy to judge.

A.5.16 Identity management

WHAT THE CONTROL ASKS FOR

Manage the full lifecycle of identities. Every identity must be traceable to a person or a defined entity, identities must be created and removed in a controlled way, and duplicate or orphaned identities must be prevented and detected. This covers human users, service accounts, and machine identities.

WHY IT EXISTS

Every access decision depends on identity being reliable. If an identity cannot be traced to an accountable party, no log entry it generates can support an investigation and no permission granted to it can be justified. Orphaned identities are among the most reliably exploited weaknesses because nobody notices activity on an account nobody owns.

HOW TO AUDIT IT

1. Obtain the identity inventory and reconcile it against the human resources record for employees and the contract register for non-employees.
2. Identify orphaned identities: accounts with no matching active person or contract. Report the count and the age of the oldest.
3. Check for duplicate identities held by the same person across systems and whether they are linked and jointly managed.
4. Verify every non-human identity has a named human owner and a documented purpose.
5. Confirm identity creation requires approval and that the approval trail exists for a sample.
6. Test removal timeliness by measuring the gap between termination date and identity disablement for recent leavers.
7. Check for dormant accounts and confirm a process exists to identify and act on them.

EVIDENCE TO COLLECT

- Identity inventory or directory export
- Human resources active employee list and contractor register
- Service and machine account register with owners and purposes
- Identity creation approval records
- Leaver list with termination and disablement dates
- Dormancy report showing last logon dates

HOW TO DOCUMENT IT

The reconciliation is the core workpaper. Present it as counts: identities in the directory, matched to active people, unmatched, and unmatched by age band. Age banding is what turns this from a housekeeping observation into a risk finding. For leaver timeliness, give the mean and the maximum gap in days, not just the mean.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of active accounts belong to nobody, including a number that have been active since a named year, giving attackers credentials that no one would notice being used. Give counts and the oldest date. This is one of the most reliably alarming findings available because the risk is immediate and the fix is cheap.

A.5.17 Authentication information

WHAT THE CONTROL ASKS FOR

Control the allocation and management of authentication information through a management process, including advising personnel on appropriate handling. Authentication information means passwords, keys, tokens, biometric data, and anything else used to prove identity. This covers how it is issued, stored, transmitted, changed, and recovered.

WHY IT EXISTS

Authentication information is the key to every other control. Compromised credentials remain the leading initial access vector in breach reporting. How credentials are issued and recovered matters as much as how strong they are, since attackers target the reset process precisely because it is usually weaker than the login itself.

HOW TO AUDIT IT

1. Review the credential issuance process, including how initial credentials reach the user and whether the delivery channel is separate from the identity being established.
2. Examine the reset and recovery process closely, including how the requester is verified. Attempt or observe a reset if permitted.
3. Verify storage protection. Confirm credentials are hashed with a current algorithm and are never stored or logged in recoverable form.
4. Check for credentials embedded in code, configuration files, scripts, and automation. Ask for the results of any secret scanning, and confirm scanning covers historical commits rather than only current files.
5. Confirm multi-factor authentication coverage, identifying explicitly which accounts are exempt and why. Exemptions are usually held by the most privileged users.
6. Review guidance given to staff on handling credentials, including on sharing and on reuse across services.
7. Check management of non-human authentication material such as API keys and certificates, including rotation.

EVIDENCE TO COLLECT

- Credential issuance and reset procedures with verification steps
- Password storage configuration and hashing algorithm evidence
- Secret scanning results including historical repository coverage
- Multi-factor authentication coverage report with exemption list and justifications
- API key and certificate inventory with issue and expiry dates
- Rotation records for keys and service credentials
- Staff guidance on credential handling

HOW TO DOCUMENT IT

Record the multi-factor exemption list in full with the privilege level of each exempt account, because the pattern of exemptions is usually the finding. Document the reset process test step by step, including what identity proof was requested. For embedded secrets, give the count found, the systems affected, and whether the credentials are still valid, since a found-but-rotated secret is a different risk from a found-and-live one.

EXECUTIVE SUMMARY TREATMENT

Suggested language: multi-factor authentication is not enforced on a stated number of administrative accounts, meaning the organization's most powerful access is protected by a password alone. If secrets in code are the issue: valid credentials for production systems are stored in source code repositories accessible to a stated number of people. Both of these are immediately actionable and executives respond to them.

A.5.18 Access rights

WHAT THE CONTROL ASKS FOR

Provision, review, modify, and remove access rights in line with the access control policy. This is the operational execution of A.5.15. It covers the request and approval workflow, periodic review of what people hold, prompt adjustment when roles change, and removal when access is no longer needed.

WHY IT EXISTS

Access granted correctly still becomes wrong over time as people change roles and projects end. Periodic review is the only mechanism that catches this accumulation. Removal timeliness matters most at termination, where the window between departure and revocation is a window of unmonitored access held by someone with a possible grievance.

HOW TO AUDIT IT

1. Sample access grants and verify each had a documented request and an approval by someone with authority. Approval by the requester or by the security team on the business's behalf is a finding.
2. Examine the access review process: frequency, scope, who performs it, and what evidence it produces.
3. Test review quality rather than occurrence. Compare a completed review to the underlying permissions and check whether anything was actually revoked. Reviews that approve everything are rubber stamps.
4. Measure removal timeliness for leavers, from termination date to revocation across all systems, not just the primary directory.
5. Test role change handling specifically. Verify that old access was removed, not merely that new access was added.
6. Check systems outside the central identity platform, which are frequently missed in both review and revocation.
7. Confirm emergency and temporary access is time-bound and actually expires.

EVIDENCE TO COLLECT

- Access request and approval records for sampled grants
- Access review records with reviewer, date, scope, and outcomes
- Revocation counts arising from reviews
- Leaver list with revocation timestamps per system
- Role change records with before and after permission states
- List of systems in and out of scope of the central review process
- Temporary access grants with expiry configuration

HOW TO DOCUMENT IT

Report review quality using the revocation rate: permissions reviewed versus permissions revoked. A rate at or near zero across a large population is strong evidence of a rubber stamp and is much harder to argue with than a qualitative assessment. For leavers, present per-system revocation times, since the aggregate figure hides the outlying system that stays open for weeks.

EXECUTIVE SUMMARY TREATMENT

Suggested language: access reviews are completed on schedule but result in almost no changes, so they provide the appearance of oversight without the substance. Give the revocation rate. For termination: access for departing staff remains active for a stated average and up to a stated maximum number of days, and this includes systems holding a named category of sensitive data.

A.5.19 Information security in supplier relationships

WHAT THE CONTROL ASKS FOR

Define and implement processes and procedures to manage the security risks associated with using suppliers' products and services. This is the governing control for third-party security. It requires you to understand which suppliers can affect your security, assess the risk each presents, and manage it deliberately.

WHY IT EXISTS

Suppliers extend your attack surface into organizations you do not control. A significant and growing share of breaches originate with a third party. The reason this needs a defined process rather than case-by-case judgment is that supplier relationships are created by many different people across the business, most of whom are not thinking about security when they sign.

HOW TO AUDIT IT

1. Obtain the supplier register and test completeness against accounts payable records. Procurement-based registers routinely miss suppliers engaged on corporate cards or through business units directly.
2. Confirm suppliers are assessed for security risk before engagement, and check whether the assessment depth scales with the risk they present.
3. Sample suppliers across risk tiers and verify assessments were performed, are current, and reached a documented conclusion.
4. Check that the process covers the whole relationship lifecycle, including termination and data return or destruction.
5. Identify suppliers with access to sensitive data or to your systems and confirm these were assessed most rigorously.
6. Verify a named owner exists for each significant supplier relationship.
7. Check for suppliers engaged without any assessment and determine how they bypassed the process.

EVIDENCE TO COLLECT

- Supplier register with risk tier, owner, and assessment status
- Accounts payable listing for the period for reconciliation
- Supplier risk assessment methodology and completed assessments
- Evidence of pre-engagement assessment with dates relative to contract signature
- Records of suppliers with system or data access
- Termination and data return records for ended relationships

HOW TO DOCUMENT IT

The accounts payable reconciliation is the most valuable test in this control, so document it fully: total suppliers paid in the period, suppliers on the register, and the difference, with a description of what the unregistered ones do. For sampled assessments, record the assessment date against the contract signature date to expose assessments performed after the fact.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of suppliers with access to company data were engaged without any security assessment, identified by comparing the supplier register to actual payments. Name the most significant one. The reconciliation method is worth mentioning in the summary because it demonstrates the finding is complete rather than anecdotal.

A.5.20 Addressing information security within supplier agreements

WHAT THE CONTROL ASKS FOR

Establish and agree the relevant security requirements with each supplier, based on the type of relationship. The requirements must be in the agreement itself, not in an email or a verbal understanding, and they must be specific enough to be enforceable.

WHY IT EXISTS

Contract terms are the only mechanism you have to compel a supplier to do anything. Once an incident occurs, your rights are exactly what the contract says and nothing more. Generic clauses requiring the supplier to maintain appropriate security are unenforceable because nobody can say what they were breached against.

HOW TO AUDIT IT

1. Sample supplier agreements across risk tiers and check for specific security requirements rather than general assurances.
2. Look for the terms that matter after something goes wrong: incident notification with a defined timeframe, audit or assessment rights, subcontractor restrictions, data location constraints, and return or destruction on termination.
3. Check liability and indemnity positions for security failures, and whether they are proportionate to the data at risk.
4. Verify requirements match the supplier's actual risk. A supplier holding customer data should carry substantially more obligation than one supplying stationery.
5. Confirm agreements are current, since suppliers often continue on expired contracts or on terms predating a significant change in the service.
6. Check that flow-down obligations exist where the supplier uses its own subcontractors.

EVIDENCE TO COLLECT

- Executed supplier agreements for sampled suppliers
- Standard security schedule or terms template
- Data processing agreements where personal data is involved
- Contract expiry and renewal register
- Records of negotiated deviations from standard terms and who approved them
- Subcontractor disclosure and approval records

HOW TO DOCUMENT IT

Use a table with one row per supplier and one column per required term, marked present, absent, or weakened. The pattern across the table shows whether the gap is a template problem or a negotiation problem, and those have different fixes. Record the clause reference where terms are present so the workpaper can be verified without re-reading the contracts.

EXECUTIVE SUMMARY TREATMENT

Suggested language: agreements with suppliers holding company data do not require them to notify the organization of a breach, so the organization could remain unaware of a compromise of its own information indefinitely. Give the number of affected suppliers and the data they hold. Missing notification clauses are the most consequential and most common version of this finding.

A.5.21 Managing information security in the ICT supply chain

WHAT THE CONTROL ASKS FOR

Define and implement processes to manage security risks associated with the supply chain for information and communications technology products and services. This looks past your direct supplier to the components, code, and services that supplier depends on.

WHY IT EXISTS

Attacks that compromise a widely used component reach everyone downstream at once. Your direct supplier may be secure while the library it embeds is not. This control exists because the software you run is assembled from parts you did not choose and often cannot see.

HOW TO AUDIT IT

1. Confirm the organization understands its technology supply chain: which products contain which components, and which suppliers depend on which subcontractors.
2. Check whether software composition is known. Ask whether a software bill of materials is obtained for significant products or produced for software the organization builds.
3. Verify a process exists for responding when a component vulnerability is disclosed, and test it against a real recent example.
4. Examine controls over software acquisition: whether sources are verified, integrity is checked, and updates are validated before deployment.
5. Check open source component management, including how new dependencies are approved and how known-vulnerable versions are detected.
6. Confirm supplier security requirements flow down to subcontractors where relevant.
7. Assess hardware supply chain controls where relevant to the organization's risk.

EVIDENCE TO COLLECT

- Technology supply chain mapping or dependency register
- Software bill of materials for significant products, where obtained
- Dependency scanning results and remediation records
- Software acquisition and integrity verification procedures
- Open source approval process and records
- Timeline evidence for a recent component vulnerability response
- Subcontractor flow-down clauses

HOW TO DOCUMENT IT

Document the component vulnerability response test as a timeline: disclosure date, detection date, assessment date, and remediation date. This single trace tells you more about the control than any policy review. Record whether dependency scanning covers all repositories or only some, naming those excluded.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization cannot determine which of its systems contain a vulnerable component when one is disclosed, so it responds to supply chain vulnerabilities by manual search rather than by lookup. State the elapsed time from the recent example. That number makes the capability gap concrete.

A.5.22 Monitoring, review and change management of supplier services

WHAT THE CONTROL ASKS FOR

Regularly monitor, review, evaluate, and manage changes to supplier security practices and service delivery. Assessment at onboarding is not enough; the relationship has to be managed while it runs, and changes on the supplier's side have to be assessed.

WHY IT EXISTS

Suppliers change. They get acquired, they move data to new regions, they change subcontractors, and their security posture drifts. An assessment performed at signature describes a supplier that may no longer exist in that form. Ongoing monitoring is what keeps the original risk decision valid.

HOW TO AUDIT IT

1. Confirm a defined monitoring approach exists, proportionate to supplier risk, with defined frequency and method.
2. Check whether assurance reports are obtained for significant suppliers and, critically, whether anyone reads them. Ask what was found in the most recent one.
3. Where assurance reports contain exceptions or carve-outs, verify those were assessed rather than accepted along with the overall opinion.
4. Confirm complementary user entity controls from supplier reports have been identified and implemented, since these are obligations placed on you.
5. Test change management. Identify supplier-side changes in the period and check whether each was assessed.
6. Review performance against agreed security service levels and evidence of action where they were missed.
7. Check that the supplier owner is performing the monitoring, and that they know they are supposed to.

EVIDENCE TO COLLECT

- Supplier monitoring plan with frequency by risk tier
- Assurance reports received, with evidence of review such as annotated copies or review notes
- Analysis of exceptions and carve-outs in those reports
- Complementary user entity control assessments
- Records of supplier-side changes and their assessment
- Security service level reporting and escalations

HOW TO DOCUMENT IT

Record whether each obtained assurance report has documented evidence of review, and separately whether its exceptions were assessed. The gap between reports received and reports reviewed is a common and easily evidenced finding. For complementary user entity controls, list each one and its implementation status, since these are frequently unread entirely.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization collects security assurance reports from its major suppliers but does not review them, and the most recent report for a named supplier contains exceptions that have never been assessed. Naming a real exception makes this immediate. Also note any complementary controls the organization was required to implement and has not.

A.5.23 Information security for use of cloud services

WHAT THE CONTROL ASKS FOR

Establish processes for acquiring, using, managing, and exiting cloud services in line with your security requirements. This control was new in 2022. It covers the whole cloud lifecycle, including the exit, which is the part most organizations never plan.

WHY IT EXISTS

Cloud services are acquired quickly, often by business teams, and they hold significant data with security responsibilities split between provider and customer in ways that are easy to misunderstand. The exit requirement exists because organizations discover on termination that they cannot retrieve their data in a usable form or verify its deletion.

HOW TO AUDIT IT

1. Identify all cloud services in use, using expense records and network telemetry rather than relying on a maintained list. Unsanctioned services are the point of the test.
2. Confirm an acquisition process exists with security involvement, and check whether it is followed or bypassed.
3. Verify the shared responsibility split is documented per service, with the organization's own obligations explicitly identified.
4. Test whether those customer-side obligations are actually met. Misconfigured storage and permissive default settings are the classic failures.
5. Confirm exit plans exist for significant services, covering data extraction format, timescale, and deletion verification.
6. Check data location and sovereignty against any applicable requirements.
7. Review provider security configuration against a recognized benchmark for at least one major platform.

EVIDENCE TO COLLECT

- Inventory of cloud services with owner, data held, and criticality
- Expense and network evidence used to identify unsanctioned services
- Shared responsibility documentation per significant service
- Configuration review results against a benchmark
- Exit plans with extraction and deletion provisions
- Data location attestations
- Acquisition approval records for recent services

HOW TO DOCUMENT IT

List discovered services against the maintained inventory and highlight the difference, recording your discovery method. For the shared responsibility test, record the specific customer-side obligation you tested and the configuration you observed, since a documented split with an unmet obligation is the most common real exposure here. Note the absence of exit plans by naming the services affected and the data they hold.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of cloud services holding company data were adopted without security review, and a named category of data is stored in a service the organization has no contract with. If the gap is exit planning: the organization has no way to retrieve or verify deletion of its data from a named critical service, which makes changing provider effectively impossible.

A.5.24 Information security incident management planning and preparation

WHAT THE CONTROL ASKS FOR

Plan and prepare for incident management by defining processes, roles, and responsibilities in advance. This is the preparation control. It requires the incident process to exist, to be documented, to have named roles, and for the people in those roles to be ready before an incident occurs.

WHY IT EXISTS

Incident response is performed under time pressure by people who are stressed and often partly informed. Decisions made well require preparation, because there is no time to design a process during the event. Organizations without prepared plans consistently take longer to contain incidents and make more damaging mistakes while doing it.

HOW TO AUDIT IT

1. Obtain the incident response plan and confirm it defines roles with named holders and deputies, decision authorities, and escalation paths.
2. Check that the plan covers the decisions that are genuinely hard: when to take systems offline, when to notify customers, when to involve law enforcement, and who can authorize each.
3. Verify the plan is accessible during an incident, including when the primary systems are unavailable.
4. Confirm the plan has been exercised, and review the results of the most recent exercise including what it revealed.
5. Test readiness by asking a named role holder what they would do first. Hesitation or uncertainty is evidence.
6. Check that supporting arrangements are in place in advance: forensic support, legal counsel, communications support, and cyber insurance notification requirements.
7. Confirm the plan is reviewed and updated, particularly after exercises and real incidents.

EVIDENCE TO COLLECT

- Incident response plan with roles, authorities, and escalation paths
- Contact lists with last verification date
- Offline or out-of-band copies of the plan
- Exercise records including scenario, participants, findings, and actions
- Retainer agreements for forensic, legal, and communications support
- Cyber insurance policy notification requirements
- Plan revision history

HOW TO DOCUMENT IT

Record the readiness interview questions and answers, since this evidences preparedness far better than the existence of a document. Note the date of the last exercise and the status of the actions it generated; unclosed exercise findings are a strong indicator that the plan will fail again the same way. Confirm and record how the plan would be accessed during a full outage.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the incident response plan has not been exercised, and the people named in it could not describe their own responsibilities when asked. Alternatively: the plan is stored only on systems that would be unavailable during the incidents it covers. Both are concrete and neither requires the executive to understand any technical detail.

A.5.25 Assessment and decision on information security events

WHAT THE CONTROL ASKS FOR

Assess security events and decide whether each should be classified as a security incident. An event is anything observed that might be security relevant; an incident is an event that has been determined to actually threaten security. The control requires a defined assessment and a recorded decision.

WHY IT EXISTS

The volume of events far exceeds the volume of real incidents, and the triage decision determines whether anything happens. Under-classification means real attacks are dismissed as noise. Over-classification exhausts the response team. A defined and consistent decision process is what makes triage reliable rather than dependent on who is on shift.

HOW TO AUDIT IT

1. Obtain the event classification criteria and confirm they are specific enough to apply consistently.
2. Sample events that were assessed and not escalated, and independently assess a subset yourself. Disagreements are the finding.
3. Confirm decisions are recorded with a rationale and an identifiable decision maker.
4. Check assessment timeliness by measuring the interval between event detection and assessment decision.
5. Verify the assessors are competent and that assessment is available outside business hours if the organization's risk warrants it.
6. Look for events assessed as non-incidents that later proved to be incidents, and check whether that pattern was reviewed.
7. Confirm the criteria are updated based on experience.

EVIDENCE TO COLLECT

- Event classification criteria and severity definitions
- Event log for the period with assessment outcomes and decision makers
- Timestamps for detection and assessment decision
- Escalation records
- Assessor competence records and rota covering out-of-hours
- Examples of reclassified events

HOW TO DOCUMENT IT

Present your independent reassessment as a table of event, organizational decision, your decision, and the basis for disagreement. State the disagreement rate. Record assessment intervals as a distribution rather than an average, since the slow tail matters more than the mean. Note out-of-hours coverage explicitly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security events are dismissed without recorded reasoning, and independent review found a stated number that should have been treated as incidents. Give the sample size and the disagreement count. If timing is the issue, state that events detected outside business hours wait a stated number of hours before anyone assesses them.

A.5.26 Response to information security incidents

WHAT THE CONTROL ASKS FOR

Respond to incidents in accordance with the documented procedures. This is the execution control. It requires that when an incident occurs, the response follows the plan, is coordinated, is recorded, and continues through to resolution.

WHY IT EXISTS

A plan that is not followed provides no protection. Response under pressure tends to improvise, which produces inconsistent containment, lost evidence, and gaps nobody notices until later. Recording the response as it happens is what makes later learning and any legal or regulatory defense possible.

HOW TO AUDIT IT

1. Select recent incidents across severities and reconstruct the response from the records.
2. Compare the actual response to the documented procedure and identify deviations, then determine whether deviations were justified and authorized.
3. Measure the key intervals: detection to response, response to containment, and containment to resolution.
4. Confirm the response was coordinated, with a clear incident lead at each point and no gaps during handover between shifts.
5. Check that records were made during the incident rather than reconstructed afterward, by examining timestamps.
6. Verify communication occurred as planned, internally and externally, including any regulatory notification.
7. Confirm incidents were formally closed with a documented resolution rather than simply going quiet.

EVIDENCE TO COLLECT

- Incident records for sampled incidents with full timeline
- Contemporaneous notes, chat logs, or ticket updates with timestamps
- Containment and remediation evidence
- Communication records including notifications made
- Incident lead assignments and handover records
- Formal closure records with resolution statements

HOW TO DOCUMENT IT

Build a timeline per sampled incident with timestamps at each stage and the elapsed intervals calculated. Note where the timeline had to be reconstructed because contemporaneous records were absent, since that is itself a finding and affects the reliability of everything else you report. Record deviations from procedure alongside whether they were authorized.

EXECUTIVE SUMMARY TREATMENT

Suggested language: incident response is not recorded as it happens, so the organization cannot reconstruct what it did during a named incident or demonstrate to a regulator that it acted appropriately. If timing is the issue, give the interval from detection to containment for the sampled incidents and compare it to the organization's own stated target.

A.5.27 Learning from information security incidents

WHAT THE CONTROL ASKS FOR

Use the knowledge gained from incidents to strengthen and improve controls. This requires analysis after the event, identification of underlying causes, and actions that reduce the chance of recurrence or the impact if it recurs.

WHY IT EXISTS

Incidents are expensive information. An organization that responds well but learns nothing will pay for the same lesson repeatedly. Recurrence is the clearest evidence that this control is not working, and it is also the easiest thing for an auditor to demonstrate.

HOW TO AUDIT IT

1. Confirm post-incident reviews are performed, with defined criteria for which incidents warrant one.
2. Assess review quality. Look for identified underlying causes rather than descriptions of what happened.
3. Verify actions arising have owners and dates, and check completion against those dates.
4. Analyze recurrence across periods. Group incidents by cause and look for repetition, which is the definitive test of this control.
5. Check whether learning crosses boundaries. An issue found in one system should prompt a check of similar systems.
6. Confirm learning reaches the people who need it, including through awareness content and procedure updates.
7. Verify that incident data informs the risk assessment.

EVIDENCE TO COLLECT

- Post-incident review reports with cause analysis
- Action registers arising from reviews with owners, dates, and status
- Multi-period incident data categorized by cause
- Evidence of procedure or control changes made as a result
- Awareness content updated from incident learning
- Risk register entries updated from incident data

HOW TO DOCUMENT IT

Present recurrence analysis as a count of incidents by cause category across at least two periods. Repetition in that table is the single most persuasive evidence available for this control. Record post-incident action completion rates and the age of open actions. Where causes are recorded as human error, note it, since that is a symptom and its presence indicates the analysis stopped early.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of incidents in the period shared the same underlying cause as incidents from the previous period, indicating that response is effective but learning is not. That contrast is useful because it credits the response team while identifying the real gap, which makes the finding easier to accept and act on.

A.5.28 Collection of evidence

WHAT THE CONTROL ASKS FOR

Establish and implement procedures for identifying, collecting, acquiring, and preserving evidence relating to security events. Evidence must be handled so that it remains admissible and reliable if it is later needed for disciplinary action, legal proceedings, insurance claims, or regulatory defense.

WHY IT EXISTS

Evidence is destroyed most often by the people responding to the incident, acting in good faith to restore service. Rebuilding a compromised server removes the evidence of how it was compromised. Once lost, it cannot be recovered, and with it goes the ability to prove what happened to anyone who later asks.

HOW TO AUDIT IT

1. Obtain evidence handling procedures and confirm they cover identification, collection, acquisition, and preservation.
2. Check that chain of custody is defined and that a record format exists.
3. Verify responders know to preserve before remediating, and test this by asking about a real incident.
4. Examine evidence handling in sampled incidents and identify anything lost through remediation.
5. Confirm the organization has access to the necessary capability, whether internal or through a retained forensic provider engaged in advance.
6. Check retention of logs and other potential evidence, and confirm retention periods are long enough given typical detection delays.
7. Verify legal input into the procedures, since admissibility requirements vary by jurisdiction.

EVIDENCE TO COLLECT

- Evidence handling and chain of custody procedures
- Completed chain of custody records from actual incidents
- Forensic provider retainer agreement
- Log retention configuration and actual retention periods
- Incident records showing preservation actions taken
- Legal review of the procedures
- Responder training records covering evidence preservation

HOW TO DOCUMENT IT

State log retention periods per source alongside the organization's own average detection time. Where retention is shorter than typical detection delay, the evidence is gone before the incident is found, and expressing it that way makes the problem self-evident. Record any specific instance where evidence was destroyed during remediation, with the date and the action taken.

EXECUTIVE SUMMARY TREATMENT

Suggested language: system logs are retained for a stated period while the organization's average time to detect an incident is longer than that, meaning evidence of a breach would be deleted before the breach was discovered. This comparison is immediately understood and usually produces a fast decision on retention.

A.5.29 Information security during disruption

WHAT THE CONTROL ASKS FOR

Plan how to maintain information security at an appropriate level during disruption. The point is that security must not be abandoned when things go wrong. Continuity arrangements, failover sites, and workarounds all need to preserve security, not just availability.

WHY IT EXISTS

Disruption is when organizations cut corners. Emergency access is granted broadly, approval steps are skipped, and data is moved to whatever platform works. Attackers know this and some deliberately create or exploit disruption for exactly this reason. The control requires the compromise to be planned rather than improvised.

HOW TO AUDIT IT

1. Review continuity plans and identify where security requirements are addressed during the disrupted state.
2. Examine emergency procedures for security shortcuts, such as broad emergency access grants or suspended change approval, and confirm each is bounded and reviewed afterward.
3. Check that alternate facilities and failover environments carry equivalent security controls to primary environments. Secondary sites are frequently weaker.
4. Verify backup data is protected to the same standard as live data, including encryption and access restriction.
5. Test whether monitoring and logging continue during failover, since detection commonly stops at the moment it is most needed.
6. Review any actual disruption in the period and assess what security degradation occurred and whether it was restored.
7. Confirm exercises include security scenarios rather than only availability scenarios.

EVIDENCE TO COLLECT

- Business continuity and disaster recovery plans with security provisions
- Emergency access procedures with authorization and time limits
- Security control comparison between primary and alternate environments
- Backup encryption and access control configuration
- Monitoring configuration for failover environments
- Records of actual disruptions and security decisions made
- Exercise records including security scenarios

HOW TO DOCUMENT IT

Present a control comparison table between primary and alternate environments; the gaps are then visible without commentary. Record any emergency access granted during real disruptions, including how many accounts, for how long, and whether it was revoked. Note explicitly whether logging continues in the failover state.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the disaster recovery environment does not carry the same security controls as production, so recovering from an outage would place company data in a materially less protected environment. Name the missing controls. If monitoring is the gap, state that the organization would lose its ability to detect attacks precisely while operating in a degraded state.

A.5.30 ICT readiness for business continuity

WHAT THE CONTROL ASKS FOR

Plan, implement, maintain, and test the readiness of information and communications technology to support business continuity objectives. This control was new in 2022. It requires that technology recovery capability is actually aligned with what the business needs and is proven by testing.

WHY IT EXISTS

Recovery objectives set by the business are frequently impossible for the technology as built, and nobody discovers this until a real outage. Testing is what converts an assumed capability into a known one. Untested recovery plans fail at a high rate, and they fail at the worst possible moment.

HOW TO AUDIT IT

1. Obtain the business recovery objectives, expressed as maximum tolerable downtime and maximum tolerable data loss, and confirm they were set by the business rather than by technology.
2. Compare stated objectives against demonstrated technical capability from actual test results, not from design documents.
3. Review test records: what was tested, how, when, whether it succeeded, and what failed.
4. Assess test realism. Testing restoration of a single file does not demonstrate the ability to recover a service.
5. Confirm dependencies were considered. A recovered application with an unrecovered authentication service is not recovered.
6. Check that test failures produced remediation and that remediation was verified in a later test.
7. Verify test frequency against the plan and confirm tests were not repeatedly deferred.

EVIDENCE TO COLLECT

- Documented recovery objectives per service with business sign-off
- Recovery test plans and results with dates and measured recovery times
- Dependency maps for critical services
- Remediation records from failed tests
- Backup success and failure reports for the period
- Actual restoration evidence, not just backup completion evidence

HOW TO DOCUMENT IT

Present a table of critical service, required recovery time, last demonstrated recovery time, and last test date. Blank cells in the demonstrated column are the finding, and they usually outnumber the filled ones. Distinguish clearly between backup completion and restoration testing, because organizations routinely present the first as evidence of the second.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never demonstrated that it can restore a stated number of its critical services within the timeframes the business requires, and for several the recovery capability has never been tested at all. Name the services. The gap between assumed and demonstrated capability is the message.

A.5.31 Legal, statutory, regulatory and contractual requirements

WHAT THE CONTROL ASKS FOR

Identify, document, and keep up to date the legal, statutory, regulatory, and contractual requirements relevant to information security, and the organization's approach to meeting them. This is the compliance obligations register.

WHY IT EXISTS

Security obligations arrive from law, regulation, and contract simultaneously, and they conflict, overlap, and change. Without a maintained register, obligations are discovered when they are breached. The requirement to document the approach to meeting each one is what prevents the register from becoming a list nobody acts on.

HOW TO AUDIT IT

1. Obtain the obligations register and assess completeness against the organization's jurisdictions, sectors, data types, and contract portfolio.
2. Confirm each entry states the specific requirement rather than only naming the law or regulation.
3. Verify each obligation is mapped to how the organization meets it, naming a control, process, or accepted gap.
4. Check currency. Identify regulatory changes in the period and confirm the register reflects them.
5. Confirm someone owns the monitoring of legal and regulatory change, and ask how they do it.
6. Sample obligations and test compliance in practice rather than accepting the register's status.
7. Check contractual obligations specifically, since these are usually the weakest part of the register.

EVIDENCE TO COLLECT

- Legal and regulatory obligations register with owner and approach per entry
- Contractual security obligations extracted from customer agreements
- Evidence of horizon scanning or legal update subscriptions
- Register revision history showing responses to regulatory change
- Compliance evidence for sampled obligations
- Legal counsel engagement records

HOW TO DOCUMENT IT

Record the register's completeness test by naming specific obligations you identified that are absent, with their source. For sampled obligations, record the register's stated compliance position against what you observed. Note the date of the last register update alongside any regulatory changes that postdate it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization does not maintain a current record of its legal and contractual security obligations, and a stated number of requirements identified during this review were not tracked anywhere. Name the most significant. Where a specific obligation is unmet, state it plainly and identify the potential consequence.

A.5.32 Intellectual property rights

WHAT THE CONTROL ASKS FOR

Implement appropriate procedures to protect intellectual property rights. This works in both directions: protecting the organization's own intellectual property, and ensuring the organization complies with the rights of others, particularly in software licensing and third-party content.

WHY IT EXISTS

Software licence non-compliance carries real financial and legal consequences and is frequently discovered through audits initiated by vendors. In the other direction, an organization that does not identify and protect its own intellectual property will lose it through ordinary staff turnover without ever noticing.

HOW TO AUDIT IT

1. Confirm procedures exist covering both directions: protection of own intellectual property and compliance with others' rights.
2. Reconcile software installations against licence entitlements and identify shortfalls and unused surplus.
3. Check controls preventing unauthorized software installation.
4. Review open source licence compliance, particularly obligations attached to licences that require disclosure or attribution when software is distributed.
5. Verify the organization has identified its own intellectual property and applied protection, including through employment and contractor agreements.
6. Check contractor and supplier agreements assign intellectual property appropriately, since default positions often leave ownership with the creator.
7. Confirm departing staff are reminded of continuing obligations.

EVIDENCE TO COLLECT

- Software asset management records reconciling installations to entitlements
- Licence agreements for significant software
- Open source licence inventory for distributed products
- Employment and contractor agreements containing intellectual property assignment
- Records of intellectual property identification
- Software installation controls configuration

HOW TO DOCUMENT IT

Present the licence reconciliation as counts of entitlements held, installations detected, and the variance in both directions. Over-deployment is a liability and under-deployment is wasted spend, and reporting both makes the finding useful to more than one audience. For open source, name the licence types found that carry distribution obligations.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization is running a stated number of software installations beyond its licence entitlements, creating financial exposure if the vendor audits. Give the estimated value if you can. For the other direction: contractor agreements do not assign intellectual property to the organization, meaning work product created by external staff may not belong to it.

A.5.33 Protection of records

WHAT THE CONTROL ASKS FOR

Protect records from loss, destruction, falsification, unauthorized access, and unauthorized release. Records here means the information the organization must retain, whether for legal, regulatory, contractual, or operational reasons. Protection must last for the full retention period.

WHY IT EXISTS

Records are the organization's memory and its evidence. Their integrity matters as much as their confidentiality, because a falsified or corrupted record is worse than a missing one. Long retention periods create their own problem, since media, formats, and systems do not survive decades without deliberate management.

HOW TO AUDIT IT

1. Obtain the retention schedule and confirm it covers record types with periods and a legal basis for each.
2. Verify retention periods are actually applied, both in retaining what must be kept and in disposing of what should not be kept.
3. Check integrity protection for records where falsification would matter, such as audit logs and financial records.
4. Assess long-term readability. For records retained beyond the life of their format or system, confirm a migration plan exists.
5. Verify access to records is restricted appropriately and that access is logged where sensitivity warrants.
6. Confirm disposal is secure and evidenced, and check that disposal actually occurs rather than data simply accumulating.
7. Test legal hold capability if litigation is a realistic prospect for the organization.

EVIDENCE TO COLLECT

- Retention schedule with periods and legal basis
- Evidence of retention enforcement in systems
- Disposal records and certificates
- Integrity controls for critical record types
- Format migration plans for long-retention records
- Access controls and access logs for record repositories
- Legal hold procedure

HOW TO DOCUMENT IT

Record retention testing in both directions with specific examples: records that should have been disposed of and were not, and records that should have been retained and were not. Both are findings and they have different causes. Note the oldest data found in systems where retention limits supposedly apply.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization retains personal data well beyond the periods its own schedule allows, increasing both regulatory exposure and the volume of information at risk in any breach. Give the oldest data found and its age. Over-retention is usually a larger and easier finding to evidence than under-retention.

A.5.34 Privacy and protection of personally identifiable information

WHAT THE CONTROL ASKS FOR

Identify and meet the requirements for privacy and protection of **personally identifiable information** according to applicable laws, regulations, and contractual requirements. Personally identifiable information, usually shortened to PII, is any information that can identify a living individual either on its own or combined with other information available.

WHY IT EXISTS

Privacy law carries the largest financial penalties in the security field and applies based on where the individuals are, not where the organization is. Privacy requirements also differ from security requirements in important ways: they constrain what you may collect and how long you may keep it, which are not security questions at all.

HOW TO AUDIT IT

1. Confirm the organization has identified which privacy laws apply, based on where its data subjects are located.
2. Verify a record of processing activities or equivalent exists, identifying what personal data is held, why, on what legal basis, and for how long.
3. Check that data subject rights can actually be exercised, and test the process end to end if a real request exists.
4. Verify privacy impact assessment is performed for higher-risk processing, and sample completed assessments.
5. Check cross-border transfer arrangements and the mechanism relied on for each.
6. Confirm consent, where relied on, is collected in a way that meets the applicable standard and can be evidenced and withdrawn.
7. Test data minimization by sampling a system and assessing whether the data collected is necessary for the stated purpose.
8. Verify processor agreements exist where third parties handle personal data on the organization's behalf.

EVIDENCE TO COLLECT

- Record of processing activities
- Applicable privacy law analysis by jurisdiction
- Data subject request log with response times
- Completed privacy impact assessments
- Cross-border transfer mechanisms and documentation
- Consent records and withdrawal mechanism evidence
- Data processing agreements with third parties
- Retention configuration for personal data

HOW TO DOCUMENT IT

Record data subject request response times against the applicable statutory deadline, since this is directly measurable and directly penalizable. For the minimization test, list the data fields collected against the stated purpose and identify those that serve no purpose. Note any processing with no identified legal basis, which is a definitive finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization processes personal data for which it cannot identify a lawful basis,

and holds a stated number of data categories that serve no current business purpose. Where response times are the issue, state the average and maximum time to respond to data subject requests against the statutory deadline. Regulatory penalty exposure should be named explicitly for this control.

A.5.35 Independent review of information security

WHAT THE CONTROL ASKS FOR

Review the organization's approach to managing information security independently, at planned intervals and when significant changes occur. Independent means the reviewer is not responsible for what they are reviewing. This covers the approach as a whole, including policies, processes, and controls.

WHY IT EXISTS

People cannot reliably find their own blind spots. The security function assessing its own adequacy will produce a report shaped by its own assumptions. Independent review is what surfaces the problems that the organization has stopped being able to see, which are usually the ones that have been there longest.

HOW TO AUDIT IT

1. Confirm independent reviews occur at defined intervals and that the last one happened on schedule.
2. Test independence rigorously. A review by internal audit is independent; a review by the security team's own manager is not. Consultants who also implement the organization's controls are not independent for those controls.
3. Check scope. Confirm the review covered the approach to security management, not only technical testing. A penetration test is not an independent review of the approach.
4. Verify findings were reported to management at an appropriate level.
5. Track findings from the previous review through to closure and check how many remain open.
6. Confirm reviews were also triggered by significant change, not only by the calendar.
7. Assess reviewer competence for the scope undertaken.

EVIDENCE TO COLLECT

- Independent review reports with scope, method, and findings
- Reviewer independence evidence, including reporting lines or engagement terms
- Reviewer competence and qualification records
- Management reporting evidence with dates
- Action tracking for prior review findings
- Trigger records for change-driven reviews

HOW TO DOCUMENT IT

State the reviewer's relationship to the reviewed function explicitly, including reporting lines, since independence claims are commonly overstated. Record prior findings and their current status with the age of each open item. Note whether the review scope covered the management approach or only technical testing, since substituting the latter for the former is the most common failure of this control.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's only independent assessment of its security is technical penetration testing, so its overall approach to managing security has never been reviewed by anyone outside the function responsible for it. If findings are the issue: a stated number of findings from the previous independent review remain open, the oldest for a stated period.

A.5.36 Compliance with policies, rules and standards for information security

WHAT THE CONTROL ASKS FOR

Regularly review compliance with the organization's own security policy, topic-specific policies, rules, and standards. This is internal compliance checking: confirming that what the organization requires of itself is actually being done.

WHY IT EXISTS

Policies drift out of practice quietly. Nobody announces that they have stopped following a requirement; it simply becomes inconvenient and then becomes normal. Regular compliance checking is what detects that drift while it is still small, and it also distinguishes controls that never worked from controls that stopped working.

HOW TO AUDIT IT

1. Confirm a compliance checking programme exists with defined scope, frequency, and responsible parties.
2. Verify checks cover the policies that matter, not only those that are easy to check automatically.
3. Assess who performs the checks. Managers checking their own areas is acceptable for this control provided results are reported onward and verified.
4. Sample completed checks and verify the results are accurate by re-performing a subset yourself.
5. Check that non-compliance found is recorded, actioned, and followed up rather than noted and forgotten.
6. Look for patterns of repeated non-compliance in the same area, which indicates the requirement may be impractical rather than ignored.
7. Confirm results reach management with enough detail to act.

EVIDENCE TO COLLECT

- Compliance checking programme with scope and frequency
- Completed compliance check records with dates and performers
- Non-compliance records with actions and closure evidence
- Trend data showing repeated non-compliance
- Management reporting of compliance results
- Automated compliance monitoring configuration and output

HOW TO DOCUMENT IT

Record your re-performance of a sampled check with the result the organization reported and the result you obtained. Discrepancy here is significant because it undermines the reliability of the whole programme. Present repeated non-compliance by area across periods, and note where the requirement itself may be the problem rather than the behavior.

EXECUTIVE SUMMARY TREATMENT

Suggested language: compliance with the organization's own security policies is not checked, so requirements have quietly stopped being followed with no mechanism to detect it. Give an example you found. Where checking exists but is unreliable, state that reported compliance results could not be reproduced on re-performance, which is a more serious finding than absence.

A.5.37 Documented operating procedures

WHAT THE CONTROL ASKS FOR

Document the operating procedures for information processing facilities and make them available to the people who need them. This means the practical, step-by-step instructions for running and maintaining systems, as distinct from policies which state requirements.

WHY IT EXISTS

Undocumented procedures live in individual heads, which creates both a continuity risk and a consistency risk. Two administrators performing the same task differently produce configuration drift that nobody planned. During an incident or an absence, undocumented procedures are simply unavailable.

HOW TO AUDIT IT

1. Identify the critical operational procedures and check which are documented.
2. Test usability rather than existence. Ask whether someone competent but unfamiliar with the specific system could follow the procedure, and if possible have them attempt it.
3. Check currency by comparing procedures to the systems as currently configured. Procedures referencing decommissioned systems or superseded interfaces are not maintained.
4. Verify availability to those who need them, including during an outage of the systems that host them.
5. Look for single points of knowledge by asking how many people can perform each critical procedure.
6. Confirm procedures are updated when systems change, by comparing recent change records to procedure revision dates.
7. Check access control on procedures, since operational procedures often contain sensitive configuration detail.

EVIDENCE TO COLLECT

- Inventory of operational procedures against critical systems
- Sampled procedures with revision dates
- Change records for comparison against procedure updates
- Evidence of availability during outage, such as offline copies
- Knowledge coverage information showing how many staff can perform each procedure
- Access controls on the procedure repository

HOW TO DOCUMENT IT

Record the single point of knowledge analysis as a table of critical procedure and number of capable staff. Rows showing one are the finding, and they are immediately understood by any audience. Compare recent significant changes against procedure revision dates to evidence maintenance failures with specific dates rather than a general assertion.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of critical operational procedures can be performed by only one person and are not documented, so the organization would be unable to operate or recover the affected systems if that person were unavailable. Name the systems. This is a continuity argument that executives act on faster than most security findings.

Annex A.6: People Controls

Eight controls covering the human lifecycle: who you let in, what you tell them, what you require of them, and what happens when they leave. This is the smallest theme and the one most often assessed superficially, usually because the evidence sits with human resources rather than with security and the two functions do not audit each other.

Two patterns recur across every control in this theme. The first is that contractors, agency staff, and third-party personnel are handled by a different process than employees, and that process is almost always weaker. Whenever you sample here, sample both populations separately and report them separately; a blended figure will hide the problem every time.

The second is that internal role changes are treated as nothing happening, when in reality they combine the risks of a departure and an arrival with none of the controls of either. Test movers deliberately.

Quick reference: A.6 People

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.6.1	Screening	Screening policy with check levels mapped to role sensitivity
A.6.2	Terms and conditions of employment	Standard employment agreement template with security clauses
A.6.3 cyb	Information security awareness, education and training	Training programme structure showing general and role-specific streams
A.6.4	Disciplinary process	Disciplinary policy or procedure covering security violations
A.6.5	Responsibilities after termination or change of employment	Employment agreement clauses on continuing obligations
A.6.6	Confidentiality or non-disclosure agreements	Register of confidentiality and non-disclosure agreements
A.6.7 cyb	Remote working	Remote working policy and supporting guidance
A.6.8 cyb	Information security event reporting	Reporting mechanism description and access routes

A.6.1 Screening

WHAT THE CONTROL ASKS FOR

Carry out background verification checks on all candidates before they join, and on an ongoing basis where appropriate. Checks must be proportionate to the sensitivity of the role, must comply with applicable laws and ethics, and must reflect the classification of information the person will access.

WHY IT EXISTS

Screening reduces the chance of deliberately placing a hostile or unsuitable person into a position of trust. It matters most for roles with privileged access, where a single individual can cause disproportionate harm. The proportionality requirement exists because screening is intrusive and should not exceed what the role justifies.

HOW TO AUDIT IT

1. Obtain the screening policy and confirm check levels vary by role sensitivity rather than applying one standard universally.
2. Sample recent hires across role types and verify the required checks were completed before access was granted, comparing check completion dates to start dates.
3. Include contractors, temporary staff, and third-party personnel. These are the most commonly unscreened population and often hold significant access.
4. Verify screening for privileged and sensitive roles specifically, and check whether it is deeper than for general roles.
5. Check whether internal moves into sensitive roles trigger re-screening, which is frequently omitted.
6. Confirm ongoing or periodic re-screening where the organization's risk warrants it, and verify it happens.
7. Confirm legal compliance, including consent and data protection treatment of screening results, and appropriate handling of adverse findings.

EVIDENCE TO COLLECT

- Screening policy with check levels mapped to role sensitivity
- Screening records for sampled hires with completion dates
- Start dates and access grant dates for comparison
- Contractor and third-party screening evidence or supplier attestations
- Internal transfer records into sensitive roles
- Re-screening records where applicable
- Consent records and screening result retention arrangements

HOW TO DOCUMENT IT

Present sampled personnel in a table of role, required check level, check completion date, start date, and access grant date. Any row where access preceded screening is a finding, and the gap in days quantifies it. Report contractors separately from employees, since pass rates almost always differ and a blended figure conceals the real exposure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of people were given access to sensitive systems before their background checks were completed, and contractors in privileged roles are not screened at all. Give counts and name the access involved. The contractor gap is the version of this finding that most often surprises leadership.

A.6.2 Terms and conditions of employment

WHAT THE CONTROL ASKS FOR

Employment agreements must state the responsibilities of both the individual and the organization for information security. This includes obligations that continue after employment ends. The same applies to contractor and third-party personnel agreements.

WHY IT EXISTS

Contractual obligation is what makes security requirements enforceable against an individual. Without it, disciplinary action for a security breach is difficult to sustain and post-employment obligations are effectively unenforceable. This is the legal foundation beneath A.6.4 and A.6.5.

HOW TO AUDIT IT

1. Sample employment agreements across staff types and check for explicit security responsibilities.
2. Confirm confidentiality obligations are present and that they survive termination, with a defined duration or an unlimited term as appropriate.
3. Check that the agreement references the security policies, so that policy requirements carry contractual force.
4. Verify contractor and third-party personnel agreements carry equivalent obligations. This is usually the gap.
5. Confirm agreements are signed and retained, and check retention against the population.
6. Check that agreements were updated when significant new obligations arose, and how existing staff were bound to them.
7. Verify the organization's own obligations to staff are stated where relevant, such as on monitoring and privacy.

EVIDENCE TO COLLECT

- Standard employment agreement template with security clauses
- Signed agreements for sampled personnel
- Contractor and agency personnel agreement templates and signed copies
- Policy acknowledgement records linking policies to contractual obligation
- Records of contractual updates and re-acknowledgement
- Legal review of the security clauses

HOW TO DOCUMENT IT

Record the specific clause references containing security obligations for each sampled agreement type, so the workpaper can be verified without re-reading contracts. Where obligations are absent for a category of worker, name the category and give the headcount, since the size of the exposed population is what determines significance.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of contractors with access to company systems have no contractual security or confidentiality obligation, meaning the organization has no legal recourse if they misuse the information they hold. Give the headcount and describe the access.

A.6.3 Information security awareness, education and training

WHAT THE CONTROL ASKS FOR

Provide personnel and relevant interested parties with appropriate awareness, education, and training on security, updated regularly in line with policies, topic-specific policies, and procedures, and relevant to their job function. Training must be role-relevant, not uniform.

WHY IT EXISTS

This is the operational counterpart to Clause 7.3. General awareness reduces the broad attack surface, but the roles that can cause the most damage, such as developers, administrators, and finance staff, need training specific to their exposure. Generic annual training for a developer does not address the risks a developer actually creates.

HOW TO AUDIT IT

1. Confirm the programme includes role-specific content beyond general awareness, and identify which roles receive it.
2. Verify content is current and reflects the threats the organization actually faces, including recent incidents.
3. Check completion across the full population including contractors, computing the rate yourself from a complete population list.
4. Check timing for new starters relative to access grant.
5. Assess effectiveness rather than completion, using knowledge assessments, phishing simulation results, or incident reporting rates.
6. Verify high-risk roles receive proportionate depth: secure development training for developers, privileged access training for administrators, social engineering training for finance and support staff.
7. Confirm refresher frequency and that content changes between iterations rather than repeating identically.

EVIDENCE TO COLLECT

- Training programme structure showing general and role-specific streams
- Content with revision dates
- Completion records reconciled to full population
- New starter completion timing against access grant dates
- Assessment scores or phishing simulation results across periods
- Role-specific training records for developers, administrators, and finance staff
- Evidence of content updates driven by incidents or threat intelligence

HOW TO DOCUMENT IT

Report completion by population segment rather than as a single figure, since the aggregate almost always hides a segment near zero. Present effectiveness measures across multiple periods to show whether they are improving. Where role-specific training is absent, name the roles and describe the specific risk that is consequently unaddressed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff in the roles that can cause the most damage receive the same general training as everyone else, so developers, administrators, and finance staff are not trained on the risks specific to their work. Support this with phishing simulation results by department if you have them, since a high failure rate in finance is a directly actionable finding.

A.6.4 Disciplinary process

WHAT THE CONTROL ASKS FOR

Have a formal, communicated disciplinary process for taking action against personnel and other interested parties who commit a security policy violation. The process must exist, be known in advance, and be applied consistently.

WHY IT EXISTS

Requirements with no consequence for breach are advisory. The communication requirement is as important as the process itself, because deterrence depends on people knowing the consequence exists. Consistency matters because selectively enforced rules are legally risky and destroy the credibility of the whole policy set.

HOW TO AUDIT IT

1. Confirm a formal disciplinary process exists and covers security violations specifically rather than only general misconduct.
2. Verify it has been communicated, and test whether staff are aware that security violations carry consequences.
3. Check equivalent arrangements for contractors and third parties, where the mechanism is contractual rather than disciplinary.
4. Review actual cases where security violations occurred and determine what action followed.
5. Assess consistency across the cases you find. Different outcomes for similar violations at different seniority levels is a significant finding.
6. Verify the process includes appropriate safeguards: investigation, evidence, and the opportunity to respond.
7. Check that the process is actually invoked, since a documented process never used is not implemented.

EVIDENCE TO COLLECT

- Disciplinary policy or procedure covering security violations
- Communication evidence, such as inclusion in awareness content and handbooks
- Records of security violations identified in the period
- Records of action taken in each case
- Contractual remedy provisions for non-employees
- Investigation procedures and evidence handling arrangements

HOW TO DOCUMENT IT

List identified violations against the action taken, with the role level of the individual involved. Anonymize where necessary but preserve seniority, because the consistency question is the one that matters and it cannot be assessed without it. Where violations occurred with no action, state that plainly with the date and nature of each.

EXECUTIVE SUMMARY TREATMENT

Handle with care since it touches individuals. Suggested language: security policy violations have occurred with no consequence, and the disciplinary process has never been applied to a security matter, which undermines the enforceability of every security requirement. Where consistency is the issue, describe the pattern without identifying individuals.

A.6.5 Responsibilities after termination or change of employment

WHAT THE CONTROL ASKS FOR

Define, enforce, and communicate the security responsibilities that remain in force after employment ends or changes. These typically include confidentiality obligations, non-disclosure, and the return of information. The responsibilities must be communicated to the individual at the point of departure or change.

WHY IT EXISTS

Knowledge does not leave when the person does. Confidentiality obligations that were agreed at hiring are often forgotten by the time someone leaves years later. Reminding people of continuing obligations at the point of departure both reinforces them and creates evidence that the individual was informed, which matters if enforcement is ever needed.

HOW TO AUDIT IT

1. Confirm continuing obligations are defined and are contained in the employment agreement, linking to A.6.2.
2. Verify the offboarding process includes explicit communication of continuing obligations, with acknowledgement.
3. Sample recent leavers and check for acknowledgement records.
4. Include internal role changes, where obligations relating to the previous role may continue and are almost never addressed.
5. Check contractors and third-party personnel, whose offboarding often happens outside any managed process.
6. Verify the organization knows what information each departing person held, which requires the asset and access records to be accurate.
7. Check whether exit discussions cover security, and whether any concerns raised are recorded and acted on.

EVIDENCE TO COLLECT

- Employment agreement clauses on continuing obligations
- Offboarding checklist including obligation communication
- Signed acknowledgements from recent leavers
- Internal transfer records with obligation communication
- Contractor termination records
- Exit interview records where security matters were raised

HOW TO DOCUMENT IT

Present sampled leavers with acknowledgement status and date. Report internal movers and contractors separately, since both routinely show zero coverage while employee leavers show high coverage. Note whether the organization could state what information each sampled leaver had access to, because an inability to answer that is a finding against A.5.16 and A.5.18 as well.

EXECUTIVE SUMMARY TREATMENT

Suggested language: departing staff are not reminded of their continuing confidentiality obligations, and the organization holds no record that they were informed, which would weaken any attempt to enforce those obligations. Give the coverage figures for leavers, movers, and contractors separately.

A.6.6 Confidentiality or non-disclosure agreements

WHAT THE CONTROL ASKS FOR

Identify, document, regularly review, and have signed the confidentiality or non-disclosure agreements that reflect the organization's needs for protecting information. This applies to personnel and to external parties.

WHY IT EXISTS

Confidentiality agreements are the mechanism that makes information legally protected when it is shared. They matter most with parties who are not employees, where no other relationship creates the obligation. The review requirement exists because agreements written years ago may not cover the information types or sharing methods now in use.

HOW TO AUDIT IT

1. Confirm the organization has identified where confidentiality agreements are required and maintains a record of those in place.
2. Sample agreements and check they define the protected information with enough specificity to be enforceable.
3. Verify duration is appropriate. Agreements expiring while the information remains sensitive provide protection that runs out.
4. Check permitted disclosure exceptions and return or destruction obligations.
5. Confirm agreements are signed by an authorized party on both sides and are retained.
6. Verify agreements are in place before information is shared, by comparing signature dates to disclosure dates for a sample.
7. Check the review cycle and confirm templates have been reviewed against current information types and sharing arrangements.

EVIDENCE TO COLLECT

- Register of confidentiality and non-disclosure agreements
- Signed agreements for sampled parties
- Standard templates with last review date
- Evidence of signature timing relative to information sharing
- Legal review records for the templates
- Return or destruction confirmations for ended relationships

HOW TO DOCUMENT IT

Record the signature date against the first disclosure date for each sampled relationship, since information shared before an agreement was signed is the most common and most consequential finding here. Note expiry dates against the expected sensitivity duration of the information covered. Record any party with whom sensitive information is shared with no agreement at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: sensitive information was shared with a stated number of external parties before any confidentiality agreement was in place, and in a stated number of cases no agreement exists at all. Name the most significant relationship. Executives respond to this because the exposure is legal and the fix is administrative.

A.6.7 Remote working

WHAT THE CONTROL ASKS FOR

Implement security measures for personnel working remotely, to protect information accessed, processed, or stored outside the organization's premises. This covers home working, working while travelling, and any other work performed away from organizational sites.

WHY IT EXISTS

Remote work moves organizational information into environments the organization does not control, with networks it did not configure and physical surroundings it cannot see. The controls that depend on the office environment stop applying, and the ones that remain have to compensate. For most organizations this is now the normal working mode rather than an exception.

HOW TO AUDIT IT

1. Obtain the remote working policy and confirm it covers the practical realities: home networks, public networks, physical security of devices and screens, family and household access, and printing.
2. Verify technical controls appropriate to the risk, such as device encryption, endpoint protection, and secure connectivity, and confirm they are enforced rather than optional.
3. Check how devices are managed remotely, including patching, configuration enforcement, and remote wipe capability.
4. Confirm personal device use is either prohibited or properly controlled, and test which is actually happening rather than which is stated.
5. Check handling of physical documents outside the office, including secure disposal, which is usually unaddressed.
6. Verify that remote access itself is protected, with multi-factor authentication and appropriate session controls.
7. Check international remote working, where data location and legal jurisdiction issues arise, and confirm any approval process is applied.

EVIDENCE TO COLLECT

- Remote working policy and supporting guidance
- Device encryption status report across the estate
- Endpoint management enrollment and compliance reporting
- Remote access configuration including authentication requirements
- Personal device policy and evidence of what is actually connecting
- Approvals for working from other countries
- Secure disposal arrangements for remote workers

HOW TO DOCUMENT IT

Report device encryption and endpoint management coverage as measured percentages from system reports, not from policy statements, and identify the unmanaged devices individually. Where personal devices are connecting despite a prohibition, give the count and the access they hold. Note whether physical document handling and disposal outside the office is addressed at all.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices holding company information are not encrypted or centrally managed, meaning the organization cannot secure or erase them if they are lost. Give the count and percentage. This is one of the clearest and most easily evidenced findings available and the remediation path

is unambiguous.

A.6.8 Information security event reporting

WHAT THE CONTROL ASKS FOR

Provide a mechanism for personnel to report observed or suspected security events in a timely manner, and make sure they know about it and know how to use it. The mechanism must be accessible and the reporting culture must not discourage use.

WHY IT EXISTS

Staff detect a substantial share of incidents, often before any technology does. But they only report if reporting is easy and safe. Organizations that treat reports as admissions of fault train their staff into silence, which converts small incidents into large ones through delay. This is the cheapest detection capability most organizations have and the most easily broken.

HOW TO AUDIT IT

1. Confirm reporting mechanisms exist and are available through the channels staff actually use, including when their normal systems are unavailable.
2. Test awareness. Ask staff how they would report a suspected phishing email or a lost device, and whether they know what happens next.
3. Check reporting volume. Very low volumes indicate the mechanism is unknown, difficult, or discouraged, not that nothing is happening.
4. Assess the response experience. Ask staff who have reported what happened afterward. Reports that vanish without acknowledgement suppress future reporting.
5. Verify there is no penalty for good-faith reports that turn out to be false alarms, and check whether that is stated explicitly.
6. Confirm contractors and third parties can report, since they often have no route into internal channels.
7. Check whether reporting is possible anonymously where the report concerns colleagues or management.

EVIDENCE TO COLLECT

- Reporting mechanism description and access routes
- Reporting volume statistics across periods and by department
- Awareness content covering how and when to report
- Sample reports with acknowledgement and outcome records
- Statement on treatment of good-faith false reports
- Anonymous reporting route, if available
- Contractor reporting arrangements

HOW TO DOCUMENT IT

Report volume trends by period and by department, since a department reporting nothing is usually a department that has learned not to. Record staff interview responses on both how to report and what happened when they did. The second question is the one that reveals whether the culture supports the mechanism.

EXECUTIVE SUMMARY TREATMENT

Suggested language: staff report security concerns at a rate far below what the organization's size would predict, and those who have reported received no response, so the organization's largest detection capability is being actively discouraged. Give the volume figures. Framing staff as a detection capability rather than a risk changes how this recommendation is received.

Annex A.7: Physical Controls

Fourteen controls covering the physical layer: perimeters, entry, equipment, media, utilities, and disposal. This theme is audited badly more often than any other, because it is the only one where the evidence is not a document. You cannot test a physical control from a desk, and a walkthrough performed during business hours with an escort will show you a building behaving unusually well.

Three practices make the difference here. Walk the site outside core hours. Record date, time, and precise location for every observation, because physical findings are disputed more often than any other kind and vague notes will not survive challenge. And get written authorization before any test that involves you personally defeating a control, including tailgating and badge-free movement.

Note also that physical findings translate into logical consequences, and the strongest versions of these findings state both: an unlocked comms cabinet is a physical observation, but a live network port inside it is an entry point to everything the network reaches.

Quick reference: A.7 Physical

Navigation: every reference and title below links to its full entry. Links shown in **orange** with a **cyb** or **ai** marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are **blue**.

Ref	Title	Primary evidence
A.7.1	Physical security perimeters	Site plans with defined perimeters marked
A.7.2	Physical entry	Physical access authorization records and approval basis
A.7.3	Securing offices, rooms and facilities	Floor plans showing sensitive room locations and construction detail
A.7.4cyb	Physical security monitoring	Monitoring coverage plan with camera positions and alarm zones
A.7.5	Protecting against physical and environmental threats	Site-specific physical and environmental threat assessments
A.7.6	Working in secure areas	Secure area working rules and their display at entry points
A.7.7	Clear desk and clear screen	Clear desk and clear screen policy
A.7.8cyb	Equipment siting and protection	Equipment location records for critical assets
A.7.9cyb	Security of assets off-premises	Inventory of off-premises assets with assigned holders
A.7.10cyb	Storage media	Media handling procedures by classification level
A.7.11	Supporting utilities	Utility protection inventory: uninterruptible supplies, generators, cooling units
A.7.12cyb	Cabling security	Cable route documentation and infrastructure diagrams
A.7.13	Equipment maintenance	Maintenance schedules and completed maintenance records

Ref	Title	Primary evidence
A.7.14 CVB	Secure disposal or re-use of equipment	Disposal and sanitization procedures by media type

A.7.1 Physical security perimeters

WHAT THE CONTROL ASKS FOR

Define security perimeters and use them to protect areas containing information and other associated assets. A perimeter is a physical boundary such as a wall, fence, or controlled entrance that separates what is protected from what is not. Perimeters should be layered, so that reaching sensitive areas requires passing through more than one boundary.

WHY IT EXISTS

Physical access defeats most logical controls. Someone standing at a server has options that no remote attacker has. Layering matters because a single perimeter fails completely the moment it is breached, whereas layers force an intruder to defeat several independent measures and give you time to notice.

HOW TO AUDIT IT

1. Walk the perimeter yourself. Documentation will not show you the propped fire door, the gap in the fence, or the window that does not lock.
2. Map the layers between a public space and the most sensitive area, and count how many boundaries must be crossed. One is a finding.
3. Test each boundary for actual integrity: doors that close and latch, walls that extend above suspended ceilings and below raised floors, and windows that resist opening.
4. Check secondary and emergency exits, which are commonly alarmed but not monitored, or monitored but never responded to.
5. Observe at a shift change or during a delivery, when perimeters are routinely defeated by convenience.
6. Confirm the perimeter definition is documented and matches what you observed.
7. For shared or multi-tenant buildings, examine what separates your space from neighbouring tenants, including above the ceiling line.

EVIDENCE TO COLLECT

- Site plans with defined perimeters marked
- Walkthrough observations with date, time, location, and photographs where permitted
- Door and alarm configuration records
- Building lease or shared-facility agreements defining responsibility for perimeter integrity
- Alarm activation logs and response records
- Construction details for walls in sensitive areas

HOW TO DOCUMENT IT

Record walkthrough observations with date, time, and precise location, because physical findings are disputed more often than any other kind and vague notes will not survive. Draw or annotate a simple layer diagram showing what you crossed to reach the most sensitive area. Note every boundary you defeated without authorization and how.

EXECUTIVE SUMMARY TREATMENT

Suggested language: an unaccompanied person can reach the room containing the organization's servers by passing a single door, which was found propped open during this review. State the date and time you observed it. Physical findings are unusually persuasive to executives because they require no technical explanation.

A.7.2 Physical entry

WHAT THE CONTROL ASKS FOR

Protect secure areas by appropriate entry controls and access points. This covers how people are authorized to enter, how their identity is confirmed, how visitors and deliveries are handled, and how entry is recorded.

WHY IT EXISTS

A perimeter with an uncontrolled door is not a perimeter. Entry control is where the theoretical boundary becomes real. Visitor and delivery handling matters disproportionately because those are the routes a social engineer will use, and they are the routes staff are most reluctant to challenge.

HOW TO AUDIT IT

1. Review the access authorization process: who approves entry to each area, on what basis, and how often the list is reviewed.
2. Pull the access list for the most sensitive area and assess whether every holder still needs it. Long lists here are common and almost always excessive.
3. Test tailgating by observing entry points during busy periods. Count how many people enter on a single credential presentation.
4. Examine visitor management: identification checks, escort requirements, badge return, and whether the visitor log is complete and legible.
5. Test the challenge culture. Move through the site without a visible badge and record whether anyone challenges you, with a documented authorization for this test in advance.
6. Check delivery and loading areas, which frequently bypass the main entry controls entirely.
7. Verify access is revoked promptly on departure, reconciling the physical access list to the leaver list.

EVIDENCE TO COLLECT

- Physical access authorization records and approval basis
- Access lists per secure area with holder and justification
- Access system event logs for the period
- Visitor log with identification, escort, and badge return records
- Leaver list reconciled against physical access revocation dates
- Observation records from tailgating and challenge testing

HOW TO DOCUMENT IT

Record the tailgating observation quantitatively: entries observed, credential presentations, and the difference. Record challenge testing with the route walked, duration, number of staff passed, and number of challenges received. Obtain and retain written authorization before performing either test. Present the leaver reconciliation as a count with the oldest unrevoked credential.

EXECUTIVE SUMMARY TREATMENT

Suggested language: during this review an unbadged person moved through a stated number of areas over a stated period without being challenged, and a stated number of former employees retain active building access. Give the numbers and the oldest revocation gap. Both are immediately understood and neither requires technical context.

A.7.3 Securing offices, rooms and facilities

WHAT THE CONTROL ASKS FOR

Design and apply physical security to offices, rooms, and facilities. This covers how sensitive spaces are constructed and configured: whether they are identifiable from outside, whether their contents are visible, and whether their construction actually resists entry.

WHY IT EXISTS

Signposting a server room tells an intruder exactly where to go. Visibility through windows lets information be collected without any entry at all. This control addresses the design decisions that either help or hinder an attacker before any entry control is tested.

HOW TO AUDIT IT

1. Check whether sensitive facilities are identified by external signage, directory listings, or public-facing floor plans.
2. Assess visibility from outside: windows into sensitive areas, screens visible from public spaces, and whiteboards visible through glass.
3. Examine construction of sensitive rooms, including whether walls are slab to slab rather than stopping at the ceiling tiles.
4. Check that sensitive areas are not co-located with facilities that require third-party access, such as cleaning stores or building plant.
5. Review environmental protections appropriate to the space, including fire detection and suppression suitable for equipment.
6. Confirm rooms are secured when unoccupied, and test this by visiting outside working hours if possible.
7. Check key and credential management for these rooms, including who holds master keys.

EVIDENCE TO COLLECT

- Floor plans showing sensitive room locations and construction detail
- Photographs of signage and external visibility, where permitted
- Construction specifications for sensitive rooms
- Key register including master key holders
- Out-of-hours observation records
- Fire detection and suppression certification

HOW TO DOCUMENT IT

Photograph or precisely describe signage and sightlines, since these findings are entirely visual and a written assertion without detail is weak. Record who holds master keys and whether that list has ever been reviewed. Note the ceiling construction check explicitly, since it is the single most common physical weakness and is invisible without looking.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the room containing the organization's core systems is identified by signage visible from a public area, and the walls do not extend above the suspended ceiling, so the room can be entered from the adjacent corridor without passing its door. Physical detail of this kind produces faster remediation decisions than most findings.

A.7.4 Physical security monitoring

WHAT THE CONTROL ASKS FOR

Continuously monitor premises for unauthorized physical access. This control was new in 2022. Monitoring may use guards, intruder alarms, video surveillance, or a combination, but it must be continuous and someone must be positioned to act on what it detects.

WHY IT EXISTS

Detection without response is theatre. Cameras that record but are never watched provide after-the-fact investigation, not prevention. The word continuously is doing real work in this control: monitoring that stops outside business hours leaves the site unmonitored during precisely the period when unauthorized entry is most likely.

HOW TO AUDIT IT

1. Identify the monitoring measures in place and confirm coverage across the whole site and across all hours.
2. Establish who responds to a detection, how quickly, and what they are authorized to do. Ask the person who would actually receive the alert.
3. Test an alarm if permitted and measure the response. An untested alarm system has an unknown response time.
4. Check camera coverage against a floor plan for blind spots, particularly at entry points and in sensitive areas.
5. Verify recording retention is long enough to be useful, and compare it to the organization's typical detection delay.
6. Confirm monitoring records are reviewed, not merely retained, and look for evidence of anything found through review.
7. Check that monitoring itself is protected, since a recorder in an unsecured room can be removed by the intruder it recorded.

EVIDENCE TO COLLECT

- Monitoring coverage plan with camera positions and alarm zones
- Response procedures with named responders and target response times
- Alarm test records with measured response
- Recording retention configuration and verification that recordings exist for a past date
- Review records showing monitoring output examined
- Physical protection of monitoring equipment
- Privacy assessment covering surveillance of staff

HOW TO DOCUMENT IT

Verify that recordings genuinely exist by requesting footage from a specific past date and time rather than accepting the stated retention period. Systems frequently fail silently and nobody discovers it until footage is needed. Record the alarm test with the time triggered and the time a response occurred.

EXECUTIVE SUMMARY TREATMENT

Suggested language: video surveillance is in place but recordings for the period requested during this review could not be produced, so the organization has no ability to investigate a physical security incident. Alternatively: the site is unmonitored outside business hours. Both are concrete and the remediation is straightforward.

A.7.5 Protecting against physical and environmental threats

WHAT THE CONTROL ASKS FOR

Design and implement protection against physical and environmental threats, including natural hazards and threats arising from human activity or infrastructure. This means identifying what could physically damage or disrupt your facilities and putting proportionate protection in place.

WHY IT EXISTS

Environmental events destroy information as effectively as attackers do, and they are more likely for most organizations. The threats are also highly location-specific: flood risk, seismic activity, proximity to industrial sites or transport corridors. Generic protection misses the specific threat that will actually occur.

HOW TO AUDIT IT

1. Confirm a threat assessment exists for each site, covering natural and human-caused hazards specific to that location.
2. Check the assessment against independent sources such as flood maps and local hazard information, rather than accepting it at face value.
3. Verify protections are proportionate to the assessed threats, and specifically check whether identified threats have corresponding measures.
4. Examine the location of critical equipment relative to hazards: server rooms below ground level in flood zones, or beneath water pipes and plant rooms.
5. Check fire detection and suppression appropriate to the equipment protected, including whether suppression would itself damage equipment.
6. Review environmental monitoring for temperature, humidity, and water, and confirm alerts reach someone who will act.
7. Confirm the assessment is reviewed periodically and after any relevant local change.

EVIDENCE TO COLLECT

- Site-specific physical and environmental threat assessments
- Independent hazard data for comparison
- Protection measures mapped to identified threats
- Fire detection and suppression certification and test records
- Environmental monitoring configuration and alert routing
- Records of environmental incidents and their handling
- Equipment siting documentation relative to identified hazards

HOW TO DOCUMENT IT

Map identified threats against implemented protections in a table; unmatched threats are the finding. Record the physical location of critical equipment relative to hazards specifically, including anything above it, since water damage from plumbing above a server room is the single most common realization of this risk. Note when the assessment was last reviewed.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's primary server room sits below a water supply with no leak detection, and the site's assessed flood risk has not been reflected in any protective measure. Name the hazard and the asset exposed. This category of finding is often remediated quickly because the cost is low and the consequence is easy to picture.

A.7.6 Working in secure areas

WHAT THE CONTROL ASKS FOR

Design and apply security measures for working in secure areas. This covers the rules that apply once someone is inside: supervision requirements, restrictions on recording devices, unaccompanied working, and awareness of what happens in the space.

WHY IT EXISTS

Entry control determines who gets in; this control determines what they can do once inside. People with legitimate access still create risk, whether through error, through observation of things they did not need to see, or through deliberate action while unobserved. Unaccompanied working in sensitive areas removes the most effective control available, which is another person watching.

HOW TO AUDIT IT

1. Obtain the rules for working in secure areas and confirm they cover supervision, recording devices, and unaccompanied access.
2. Verify staff working in those areas know the rules, by asking rather than by checking acknowledgement records.
3. Check whether third parties such as maintenance engineers and cleaners are escorted, and test this by reviewing access logs against escort records.
4. Examine unaccompanied access permissions and whether they are justified individually.
5. Check restrictions on recording devices and whether they are enforced or merely stated. Enforcement is rare and its absence should be recorded honestly.
6. Confirm the rules are visible at the point of entry, since rules held only in a policy document will not be recalled at the door.
7. Review any work performed in secure areas in the period and check compliance for a sample.

EVIDENCE TO COLLECT

- Secure area working rules and their display at entry points
- Escort requirements and completed escort records
- Access logs for secure areas, reconciled against escort records
- Unaccompanied access authorizations with individual justification
- Third-party and maintenance visit records
- Awareness evidence for staff with secure area access

HOW TO DOCUMENT IT

Reconcile secure area access log entries against escort records and report the count of visits by escort-required parties with no corresponding escort record. This reconciliation is precise, easily performed, and difficult to dispute. Record what staff told you about the rules against what the rules actually say.

EXECUTIVE SUMMARY TREATMENT

Suggested language: maintenance contractors work unescorted in the room containing the organization's core systems, and a stated number of such visits in the period have no escort record. Contractor access to sensitive physical space is a pattern executives recognize from other risk domains and act on readily.

A.7.7 Clear desk and clear screen

WHAT THE CONTROL ASKS FOR

Define and enforce clear desk rules for papers and removable storage media, and clear screen rules for information processing facilities. In practice: sensitive material is not left visible on desks, and screens are locked when unattended.

WHY IT EXISTS

This is the control that addresses the information sitting in plain sight. Cleaners, contractors, visitors, and colleagues without need to know all pass through workspaces. An unlocked screen belonging to a privileged user is a complete authentication bypass requiring no skill at all.

HOW TO AUDIT IT

1. Perform an unannounced walkthrough outside core hours, ideally in the evening, and record what is visible.
2. Count and categorize what you find: unattended sensitive documents, unlocked screens, written credentials, and removable media left out.
3. Check meeting rooms, printers, and shared spaces, which are consistently worse than individual desks.
4. Verify automatic screen locking is configured and enforced technically, and check the timeout period.
5. Check secure storage availability. If lockable storage is insufficient, staff cannot comply and the finding belongs to facilities, not to the individuals.
6. Examine printer areas for uncollected output and check whether secure print release is in use.
7. Repeat the walkthrough on a second date to establish whether what you found is typical or exceptional.

EVIDENCE TO COLLECT

- Clear desk and clear screen policy
- Walkthrough records with date, time, area, and itemized observations
- Screen lock configuration and timeout settings across the estate
- Secure storage provision assessed against headcount
- Secure print configuration and uncollected output observations
- Prior walkthrough results for trend comparison

HOW TO DOCUMENT IT

Record observations by area with counts by category, and repeat on a second date so you can state whether the result is representative. Photograph where permitted and where the finding is significant. Note secure storage availability alongside the findings, because a compliance failure caused by insufficient lockers is a different problem with a different owner.

EXECUTIVE SUMMARY TREATMENT

Suggested language: an evening walkthrough found a stated number of unlocked workstations and a stated number of documents containing a named category of sensitive information left visible in open areas accessible to cleaning and contractor staff. Give the counts and the date. This is among the easiest findings to evidence and among the hardest to argue with.

A.7.8 Equipment siting and protection

WHAT THE CONTROL ASKS FOR

Site equipment securely and protect it. This covers where equipment is physically placed and what protects it there, including protection from environmental conditions, from unauthorized access, and from observation.

WHY IT EXISTS

Equipment in the wrong place is exposed regardless of how well it is configured. A server in an open office, a network switch in an unlocked cupboard, or a screen facing a window each create exposure that no logical control addresses. Siting decisions are made once and rarely revisited, so they persist for years.

HOW TO AUDIT IT

1. Physically locate critical equipment and assess its siting rather than relying on documentation.
2. Check network equipment specifically, including switches and access points in corridors, cupboards, and public areas, which are routinely unsecured.
3. Assess screen positioning relative to windows and public sightlines in areas handling sensitive information.
4. Verify environmental conditions where equipment sits, including cooling, and check for equipment in unsuitable spaces such as cupboards without ventilation.
5. Check physical access to ports and interfaces on accessible equipment, since an exposed network port is an entry point.
6. Review protection against power disturbance for critical equipment.
7. Identify equipment sited outside controlled areas and confirm the risk was assessed.

EVIDENCE TO COLLECT

- Equipment location records for critical assets
- Walkthrough observations covering network equipment locations
- Environmental conditions in equipment spaces, including temperature records
- Power protection arrangements and test records
- Photographs of siting issues where permitted
- Risk assessments for equipment sited outside controlled areas

HOW TO DOCUMENT IT

Record specific locations with enough precision that someone can find the equipment from your notes alone. Network equipment in unsecured locations is the finding most often produced by this control, so record each instance individually rather than summarizing. Note accessible physical ports separately, since these have a direct logical consequence.

EXECUTIVE SUMMARY TREATMENT

Suggested language: network equipment providing connectivity to the organization's internal systems is located in unsecured areas accessible to visitors and contractors, with live network ports exposed. Give locations and counts. The link between a physical finding and a logical consequence is what makes this land.

A.7.9 Security of assets off-premises

WHAT THE CONTROL ASKS FOR

Protect assets that are located away from the organization's premises. This covers laptops and mobile devices in transit and at home, equipment at customer or supplier sites, and anything else that leaves organizational control.

WHY IT EXISTS

Off-premises assets have none of the physical protection the site provides and are lost or stolen at a meaningful rate. The organization's exposure is determined entirely by what is on the device and how it is protected, since it will not get the device back. This control has grown substantially in importance as the proportion of assets that live off-site has grown.

HOW TO AUDIT IT

1. Establish which assets are routinely off-premises and whether the organization knows where they are.
2. Verify device encryption coverage from system reporting rather than from policy, and identify unencrypted devices individually.
3. Check remote wipe capability and confirm it has been tested rather than assumed.
4. Review the loss and theft reporting process and examine actual cases from the period, including how quickly they were reported and what was done.
5. Check protection during transit, including rules on leaving equipment in vehicles and in public places.
6. Verify insurance or replacement arrangements do not substitute for data protection, since replacing hardware does not address data exposure.
7. Check equipment at third-party sites and confirm responsibility for its protection is agreed.

EVIDENCE TO COLLECT

- Inventory of off-premises assets with assigned holders
- Encryption status report across the mobile estate
- Remote wipe capability configuration and test evidence
- Loss and theft incident records with reporting and response timelines
- Rules covering equipment in transit
- Agreements covering equipment at third-party locations

HOW TO DOCUMENT IT

Report encryption coverage as a measured percentage with the unencrypted devices listed individually by holder and data access. For each loss in the period, record the interval between loss and report, and between report and remote wipe, since these intervals define the actual exposure window.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of laptops holding company information are not encrypted, and in the losses recorded this period the average time between loss and any protective action was a stated number of days. The combination of coverage gap and response delay is what quantifies the exposure.

A.7.10 Storage media

WHAT THE CONTROL ASKS FOR

Manage storage media through their whole life: acquisition, use, transport, and disposal, in line with the organization's classification scheme and handling requirements. Storage media includes removable drives, memory cards, backup tapes, optical media, and the drives inside retired equipment.

WHY IT EXISTS

Media concentrates large volumes of information in small, portable, easily lost objects. Media also survives the systems that created it, which means a tape or drive found years later still holds whatever was written to it. Transport is the highest-risk phase because the media is outside every control the organization has.

HOW TO AUDIT IT

1. Identify what media types are actually in use, including personally owned removable media if it is permitted or simply not prevented.
2. Check whether removable media use is controlled technically, and test whether the control works rather than accepting the configuration.
3. Verify encryption of media holding classified information, and confirm it is enforced rather than optional.
4. Review media inventory and tracking for media that is formally managed, such as backup tapes.
5. Examine transport arrangements, including courier selection, tracking, and whether media is encrypted in transit.
6. Check storage conditions and access control for media held on site.
7. Trace a sample of media through to disposal and verify the disposal record exists, linking to A.7.14.

EVIDENCE TO COLLECT

- Media handling procedures by classification level
- Removable media control configuration and test results
- Media inventory with location and content classification
- Encryption configuration for media
- Transport records including courier and tracking evidence
- Disposal records reconciled to the media inventory

HOW TO DOCUMENT IT

Test removable media control practically by attempting to write a file to an unauthorized device, with prior authorization, and record the result. Configuration review alone frequently reports controls that are not actually enforced. Reconcile the media inventory to disposal records and list any media that cannot be accounted for.

EXECUTIVE SUMMARY TREATMENT

Suggested language: removable media use is unrestricted, so any workstation can copy the data it can reach onto a device that leaves the building unrecorded. If accountability is the issue, state the number of backup media that cannot be located and the data they hold.

A.7.11 Supporting utilities

WHAT THE CONTROL ASKS FOR

Protect information processing facilities from power failures and other disruptions caused by failures in supporting utilities. Supporting utilities include electricity, telecommunications, water, heating and ventilation, and air conditioning.

WHY IT EXISTS

Utility failure causes outage regardless of how well the technology is built, and abrupt power loss corrupts data as well as interrupting service. Cooling failure in particular damages equipment within a short period. These are availability and integrity risks that sit entirely outside the information technology function's usual attention.

HOW TO AUDIT IT

1. Identify the utilities critical to information processing and confirm protection exists for each.
2. Check power protection: uninterruptible supply capacity, generator provision where warranted, and fuel arrangements.
3. Verify testing rather than existence. Confirm uninterruptible supplies are load tested and generators are run under load, with dated records.
4. Check battery age against expected life, since batteries degrade silently and fail when first genuinely needed.
5. Review cooling capacity and redundancy, and check for single points of failure such as one air conditioning unit serving a full equipment room.
6. Confirm monitoring and alerting exists for utility status and that alerts reach someone who will act out of hours.
7. Check telecommunications resilience, including whether diverse routes are genuinely diverse rather than sharing a duct.

EVIDENCE TO COLLECT

- Utility protection inventory: uninterruptible supplies, generators, cooling units
- Load test records with dates and measured runtime
- Battery installation dates and replacement schedule
- Cooling capacity assessment and redundancy configuration
- Utility monitoring and alert configuration
- Telecommunications route diversity evidence from the provider
- Maintenance contracts and completed maintenance records

HOW TO DOCUMENT IT

Record the date of the last load test for each protective measure and the measured runtime against the required runtime. Untested protection should be recorded as unverified rather than as present. Note battery age against rated life, since this converts a future failure into a present finding.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the uninterruptible power supply protecting the organization's core systems has never been load tested and its batteries are past their rated life, so the protection is assumed rather than demonstrated. If cooling is the issue, state that a single unit serves the equipment room and its failure would cause equipment damage within a stated period.

A.7.12 Cabling security

WHAT THE CONTROL ASKS FOR

Protect cables carrying power, data, and supporting information services from interception, interference, and damage. This covers routing, physical protection, labelling, and separation of power and data cabling.

WHY IT EXISTS

Cables are the physical layer of every network and they are frequently the least protected part of it. An accessible cable can be tapped or cut. Poor cable management also causes outages through accidental disconnection, which is a far more common realization of this risk than deliberate interception.

HOW TO AUDIT IT

1. Trace cable routes for critical connections and identify where they pass through uncontrolled or public areas.
2. Inspect patch panels and comms cabinets for physical security, and check whether cabinets are locked and who holds keys.
3. Check labelling adequacy. Unlabelled cabling causes outages during maintenance and prevents rapid fault isolation.
4. Verify separation of power and data cabling to limit interference.
5. Look for accessible network ports in public or semi-public areas and confirm whether unused ports are disabled.
6. Check cable protection where physical damage is likely, such as floor crossings and areas with vehicle or trolley traffic.
7. For high-sensitivity environments, check whether additional protection such as conduit or armoured cable was considered.

EVIDENCE TO COLLECT

- Cable route documentation and infrastructure diagrams
- Comms cabinet inspection observations with lock status
- Port configuration showing which unused ports are disabled
- Labelling standard and observed compliance
- Photographs of cable routing issues where permitted
- Key register for comms cabinets

HOW TO DOCUMENT IT

Record specific cabinet and cable locations with their observed condition. Report unused enabled ports in accessible areas as a count with locations, since each one is a physical entry point to the network and the finding is directly actionable. Note whether cabinets were locked at the time of observation rather than whether locks exist.

EXECUTIVE SUMMARY TREATMENT

Suggested language: comms cabinets containing network infrastructure are unlocked and located in areas accessible to visitors, and a stated number of live network ports in public areas remain enabled. Physical access to the network is a consequence executives grasp without technical explanation.

A.7.13 Equipment maintenance

WHAT THE CONTROL ASKS FOR

Maintain equipment correctly to ensure the availability, integrity, and confidentiality of information. This covers maintenance schedules, who performs maintenance, and how information is protected while maintenance is carried out.

WHY IT EXISTS

Maintenance is a routine, scheduled opportunity for an outsider to have physical access to equipment holding information. It is also the point at which equipment leaves the site for repair, frequently with its storage intact. Maintenance failures also cause the outages that maintenance was supposed to prevent.

HOW TO AUDIT IT

1. Confirm maintenance schedules exist for critical equipment and that maintenance is performed on schedule.
2. Check who performs maintenance and whether third-party engineers are screened, escorted, and subject to confidentiality obligations.
3. Verify what happens to information when equipment is removed for repair. Sending a failed drive to a vendor with data intact is a common and serious gap.
4. Check whether maintenance is performed remotely, and if so how that access is controlled and logged.
5. Review warranty and support arrangements against the criticality of the equipment they cover.
6. Confirm equipment is checked before return to service after maintenance.
7. Look for equipment past end of support, which cannot be maintained or patched and should appear on the risk register.

EVIDENCE TO COLLECT

- Maintenance schedules and completed maintenance records
- Third-party engineer screening, escort, and confidentiality evidence
- Procedures for equipment removed from site for repair
- Records of equipment sent for repair with data handling actions taken
- Remote maintenance access configuration and logs
- End of support inventory with risk register entries

HOW TO DOCUMENT IT

Record the specific handling of storage media in equipment sent off-site for repair, with examples from the period. This is the highest-risk element of the control and is frequently unaddressed. Present end of support equipment as a list with the support expiry date for each and whether it appears on the risk register.

EXECUTIVE SUMMARY TREATMENT

Suggested language: equipment containing company information is sent to third parties for repair without removing or erasing its storage, so data has left the organization's control with no record of what it contained. If end of support is the issue, give the count of unsupported systems and what they do.

A.7.14 Secure disposal or re-use of equipment

WHAT THE CONTROL ASKS FOR

Verify that equipment containing storage media has had all sensitive information and licensed software removed or securely overwritten before disposal or re-use. The word verify is the operative one: the control requires confirmation, not just an instruction to erase.

WHY IT EXISTS

Disposed equipment leaves organizational control permanently. Research repeatedly finds recoverable data on second-hand drives, and standard deletion does not remove data. Re-use within the organization matters too, since a laptop passed from a finance user to a new starter may carry its predecessor's data with it.

HOW TO AUDIT IT

1. Obtain the disposal procedure and confirm it specifies a sanitization method appropriate to the media type. Methods suitable for magnetic drives do not necessarily work on solid state drives.
2. Verify the verification step exists and is performed by someone other than the person who performed the erasure.
3. Reconcile the asset inventory to disposal records and identify equipment that disappeared without a disposal record.
4. For third-party disposal, check the provider's certification, the chain of custody from collection to destruction, and whether certificates identify individual assets by serial number.
5. Check the re-use path specifically, since it is usually less controlled than disposal and is often handled informally.
6. Examine equipment awaiting disposal and confirm it is secured while it waits, as this staging area is frequently unprotected.
7. Sample a disposed or re-used device if any remain accessible and check for residual data.

EVIDENCE TO COLLECT

- Disposal and sanitization procedures by media type
- Disposal records reconciled to the asset inventory
- Destruction certificates identifying assets by serial number
- Third-party disposal provider certification and contract
- Chain of custody records from collection to destruction
- Re-use records showing sanitization before reassignment
- Physical security of the disposal staging area

HOW TO DOCUMENT IT

The inventory to disposal reconciliation is the core test: report assets acquired, assets in service, assets disposed of with records, and the unexplained difference. Check that destruction certificates list serial numbers rather than quantities, because a certificate for a number of items proves nothing about which items. Record the condition and security of the staging area.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices have left the asset inventory with no disposal record, so the organization cannot demonstrate that the information they held was destroyed. Give the count. Where certificates lack serial numbers, note that disposal cannot be traced to specific assets, which means the certificates provide no assurance about any particular device.

Annex A.8: Technological Controls

Thirty-four controls, the technical core of Annex A, and the theme most organizations prepare hardest for. That preparation is usually shallow in a specific way: the configuration is demonstrated and the operation is not. A control that is correctly configured and never performed will pass a documentation review and fail in an incident.

Wherever possible in this theme, extract the data yourself rather than accepting a report. Pull the permissions, generate a test event and trace it, compare a live system against its own baseline, query for data that should have been deleted. Compliance dashboards in this domain are consistently generous, and the difference between the dashboard and the extract is frequently the entire finding.

Three controls in this theme carry disproportionate weight and are worth testing first if time is short: whether backups can be reached and deleted from production (A.8.13), what an ordinary workstation can actually reach across the network (A.8.22), and how much production change happens outside the change process (A.8.32). Each answers a question about how bad a single compromise would be, which is the question the executive summary is ultimately reporting on.

Quick reference: A.8 Technological

Navigation: every reference and title below links to its full entry. Links shown in [orange](#) with a [cyb](#) or [ai](#) marker denote controls whose subject matter is specifically cybersecurity (CYB) or that are direct attachment points for AI system governance (AI). All others are [blue](#).

Ref	Title	Primary evidence
A.8.1 cyb	User endpoint devices	Endpoint management enrollment report against the asset inventory
A.8.2 cyb	Privileged access rights	Privileged account inventory across all systems with owners and justifications
A.8.3 cyb	Information access restriction	Permission exports for sampled repositories
A.8.4 cyb	Access to source code	Repository inventory with access lists
A.8.5 cyb	Secure authentication	Authentication configuration per system
A.8.6 cyb	Capacity management	Capacity monitoring configuration with thresholds and alert routing
A.8.7 cyb	Protection against malware	Malware protection coverage and update status reports
A.8.8 cyb	Management of technical vulnerabilities	Vulnerability information sources and coverage
A.8.9 cyb	Configuration management	Secure configuration baselines per technology with their source
A.8.10 cyb	Information deletion	Deletion requirements derived from retention schedules and obligations
A.8.11 cyb/ai	Data masking	Inventory of non-production environments and the data they contain
A.8.12 cyb	Data leakage prevention	Channel inventory with coverage status

Ref	Title	Primary evidence
A.8.13 CVB	Information backup	Backup policy with scope, frequency, and retention
A.8.14 CVB	Redundancy of information processing facilities	Availability requirements per service with business sign-off
A.8.15 CVB	Logging	Logging configuration per system and event type
A.8.16 CVB	Monitoring activities	Monitoring coverage and detection rule inventory
A.8.17 CVB	Clock synchronization	Approved time source definition
A.8.18 CVB	Use of privileged utility programs	Inventory of privileged utilities and the systems they are installed on
A.8.19 CVB	Installation of software on operational systems	Software installation procedures and the approved software list
A.8.20 CVB	Networks security	Current network diagrams and their verification against live configuration
A.8.21 CVB	Security of network services	Network service inventory with security requirements per service
A.8.22 CVB	Segregation of networks	Network segmentation design and its rationale
A.8.23 CVB	Web filtering	Filtering configuration with categories and actions
A.8.24 CVB	Use of cryptography	Cryptography policy with approved algorithms and applications
A.8.25 CVB/AI	Secure development life cycle	Documented development lifecycle with security activities per stage
A.8.26 CVB	Application security requirements	Requirements definition method or template
A.8.27 CVB	Secure system architecture and engineering principles	Documented engineering principles with review dates
A.8.28 CVB	Secure coding	Secure coding standards per language and framework
A.8.29 CVB	Security testing in development and acceptance	Security testing requirements per lifecycle stage
A.8.30 CVB	Outsourced development	Register of outsourced development engagements
A.8.31 CVB	Separation of development, test and production environments	Environment inventory with infrastructure and network separation detail
A.8.32 CVB	Change management	Change management procedure including emergency provisions
A.8.33 CVB/AI	Test information	Test data sources and selection records
A.8.34 CVB	Protection of information systems during audit testing	Audit and assurance planning procedure

A.8.1 User endpoint devices

WHAT THE CONTROL ASKS FOR

Protect the information stored on, processed by, or accessible through user endpoint devices. Endpoint devices means laptops, desktops, phones, and tablets used by staff. This covers configuration, protection, and the rules governing their use.

WHY IT EXISTS

Endpoints are where users meet data, and they are the most common point of initial compromise. They also leave the building routinely. An endpoint is simultaneously the least controlled environment in the estate and the one with the broadest access to information.

HOW TO AUDIT IT

1. Establish the endpoint population from management tooling and compare it to the asset inventory and to what is actually connecting.
2. Verify a defined secure configuration exists and check actual compliance from management reporting rather than from the standard document.
3. Check the essentials individually: disk encryption, endpoint protection, host firewall, automatic screen lock, and patch currency, reporting coverage for each.
4. Identify unmanaged devices with access to organizational information, including personally owned devices, and quantify what they can reach.
5. Check administrative rights on endpoints. Local administrator access held by ordinary users substantially increases the impact of any compromise.
6. Verify devices unable to meet the standard, such as legacy or specialist systems, are identified, isolated, and on the risk register.
7. Check the process for handling a compromised endpoint, including isolation capability, and confirm it has been used or tested.

EVIDENCE TO COLLECT

- Endpoint management enrollment report against the asset inventory
- Secure configuration baseline and compliance reporting by control
- Encryption, endpoint protection, and patch status reports with dates
- Local administrator rights report
- List of unmanaged or non-compliant devices with the access they hold
- Isolation capability evidence and any use of it

HOW TO DOCUMENT IT

Report each protective measure as a separate coverage percentage rather than a combined compliance score, because a single score hides which specific control is missing on which devices. List non-compliant devices individually with their user and data access. Record the local administrator count as a proportion of total users.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of devices with access to company information are not centrally managed, so the organization cannot verify their configuration, apply updates to them, or erase them if lost. Give the count and percentage. If administrative rights are the issue, state the proportion of staff holding local administrator access and what that means for the impact of any single compromise.

A.8.2 Privileged access rights

WHAT THE CONTROL ASKS FOR

Restrict and manage the allocation and use of privileged access rights. Privileged access means rights beyond those of a normal user, typically administrative rights that allow configuration change, access to others' data, or control over security controls themselves.

WHY IT EXISTS

Privileged accounts are the primary objective of almost every intrusion, because they convert a foothold into full control. They are also the accounts whose misuse is hardest to detect, since a privileged user can often modify the very logs that would record their activity.

HOW TO AUDIT IT

1. Obtain a complete inventory of privileged accounts across all systems, not just the primary directory, and verify completeness independently.
2. Confirm each privileged account has an identified individual owner and a documented justification.
3. Check whether privileged access is separated from daily-use accounts. Administrators browsing the web from an administrative account is a significant and common finding.
4. Verify additional authentication requirements apply to privileged access, and identify any exemptions.
5. Check whether privileged access is time-bound or granted on request rather than standing, and if standing, whether that was a considered decision.
6. Verify privileged activity is logged to a location the privileged user cannot alter, and confirm the logs are reviewed.
7. Review the frequency and rigour of privileged access recertification, and check what it actually revoked.
8. Examine shared privileged accounts and how individual accountability is achieved for them.

EVIDENCE TO COLLECT

- Privileged account inventory across all systems with owners and justifications
- Separation evidence between administrative and standard accounts
- Authentication configuration for privileged access including exemptions
- Privileged session logs and evidence of review
- Log integrity protection configuration
- Recertification records with revocation counts
- Shared account register with accountability arrangements

HOW TO DOCUMENT IT

Build the privileged inventory yourself from system exports rather than accepting a maintained list, and report the difference between the two. Present privileged accounts as a ratio to total users per system. Record whether privileged logs are written somewhere outside the administrator's control, since without that the entire logging control is unreliable for exactly the users who matter most.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of accounts hold administrative control over the organization's systems, which is a stated proportion of all users, and their activity is logged to systems those same accounts can modify. Both halves matter: the excess and the absence of independent oversight.

A.8.3 Information access restriction

WHAT THE CONTROL ASKS FOR

Restrict access to information and other associated assets in accordance with the established access control policy. Where A.5.15 sets the rules, this control is about their technical enforcement at the level of the information itself.

WHY IT EXISTS

Access rules that exist only in policy are enforced by user restraint. Technical restriction is what makes them real. This control matters most for the large shared repositories where information accumulates and permissions are set once and never revisited.

HOW TO AUDIT IT

1. Sample information repositories, particularly shared drives and collaboration platforms, and examine who can actually reach them.
2. Look specifically for repositories open to all staff, which is the default failure mode of collaboration platforms.
3. Test whether restriction matches classification by taking a sample of classified information and checking who can access it.
4. Check for over-broad permissions granted to groups whose membership has since expanded well beyond the original intent.
5. Verify restriction applies to data at rest in databases and file stores, not just to the applications in front of them.
6. Check external sharing configuration on collaboration platforms and identify anything shared publicly or by open link.
7. Test dynamic and inherited permissions, where access granted at a parent level cascades further than intended.

EVIDENCE TO COLLECT

- Permission exports for sampled repositories
- External and public sharing reports from collaboration platforms
- Classification records for sampled information
- Group membership listings for groups holding broad access
- Database and file store access configuration
- Records of permission review for repositories

HOW TO DOCUMENT IT

Report the number of repositories accessible to all staff alongside what they contain, since the combination is what makes the finding significant. For external sharing, list items shared publicly with their classification, because a single publicly shared sensitive file is a more compelling finding than a general statement about configuration.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of documents containing a named category of sensitive information are shared publicly by open link and are accessible to anyone with the address, and a stated number of internal repositories holding confidential material are open to all staff. Specific examples carry this finding; general configuration observations do not.

A.8.4 Access to source code

WHAT THE CONTROL ASKS FOR

Appropriately manage read and write access to source code, development tools, and software libraries. This covers who can see code, who can change it, and how those permissions are governed.

WHY IT EXISTS

Source code reveals how a system works, including its weaknesses, and it frequently contains embedded credentials and infrastructure detail. Write access to code is effectively write access to production for anything that deploys automatically. Compromise of a code repository has been the route into a large number of significant breaches.

HOW TO AUDIT IT

1. Inventory the code repositories and check that all are known, including those created by individual teams outside the central platform.
2. Review read access and assess whether the population is justified, particularly for repositories containing sensitive logic or infrastructure definitions.
3. Examine write access and check whether direct commits to protected branches are prevented.
4. Verify code review is required before merge and confirm it is enforced technically rather than by convention.
5. Check for secrets in repositories, including full history, and confirm any found have been rotated rather than merely removed from current files.
6. Review access held by former staff and contractors, particularly on platforms where accounts are personal rather than organizational.
7. Check build and deployment pipeline permissions, since these frequently hold broader access than the code itself.
8. Verify repository backup and the ability to recover from malicious change.

EVIDENCE TO COLLECT

- Repository inventory with access lists
- Branch protection and merge requirement configuration
- Code review records for a sample of merged changes
- Secret scanning results covering full commit history
- Access reconciliation against current staff and contractor lists
- Pipeline service account permissions
- Repository backup evidence

HOW TO DOCUMENT IT

Reconcile repository access against the current personnel list and report accounts belonging to departed individuals, with the access each holds. Record whether secret scanning covers history or only current state, since the difference is substantial and is frequently misunderstood. Note any repository where branch protection is absent.

EXECUTIVE SUMMARY TREATMENT

Suggested language: former contractors retain write access to the repositories containing the organization's production code, and valid production credentials remain in the repository history. Give counts and confirm whether the credentials are still live, since that determines the urgency.

A.8.5 Secure authentication

WHAT THE CONTROL ASKS FOR

Implement secure authentication technologies and procedures based on the access restrictions and the access control policy. This covers how users prove identity: the mechanisms, their strength, and their configuration.

WHY IT EXISTS

Authentication is the gate through which all access passes. Credential compromise remains the leading initial access vector, and the primary defence against it is multi-factor authentication. Authentication strength should be proportionate to what the access permits, which means uniform authentication across a system with widely varying access is either excessive or inadequate.

HOW TO AUDIT IT

1. Map the authentication mechanisms in use across systems and identify any that rely on a password alone.
2. Verify multi-factor authentication coverage and enumerate exceptions with justifications, checking whether exceptions correlate with privilege.
3. Assess the strength of the second factor. Not all factors are equivalent, and some are vulnerable to interception or to prompt fatigue.
4. Check authentication for remote access, administrative interfaces, and third-party access, which are the highest-value targets.
5. Review account lockout, rate limiting, and protection against credential stuffing.
6. Check session management: timeout, re-authentication for sensitive operations, and session termination on logout.
7. Verify authentication failures are logged and that repeated failures generate an alert someone acts on.
8. Check legacy authentication protocols that bypass modern controls and confirm whether they are disabled.

EVIDENCE TO COLLECT

- Authentication configuration per system
- Multi-factor coverage report with exception list and privilege level per exception
- Session and lockout policy configuration
- Legacy protocol status
- Authentication failure logs and alert configuration
- Third-party and remote access authentication evidence

HOW TO DOCUMENT IT

List multi-factor exceptions individually with the privilege level of each exempt account, since the correlation between exemption and privilege is usually the finding. Record legacy authentication protocol status explicitly, because these silently bypass otherwise sound controls and their presence is easy to miss.

EXECUTIVE SUMMARY TREATMENT

Suggested language: administrative and remote access to the organization's systems can be obtained with a password alone for a stated number of accounts, and legacy authentication protocols that bypass multi-factor requirements remain enabled. Both are precise, both are fixable, and both map directly to how breaches actually begin.

A.8.6 Capacity management

WHAT THE CONTROL ASKS FOR

Monitor and adjust the use of resources in line with current and expected capacity requirements. Resources means processing, storage, network, and the human capacity needed to operate them.

WHY IT EXISTS

Capacity exhaustion causes outage, which is an availability failure and therefore a security failure under the standard's definition. Capacity limits also cause security controls to be disabled under pressure, such as logging switched off because storage filled, which is how a capacity problem becomes a detection problem.

HOW TO AUDIT IT

1. Confirm capacity is monitored across processing, storage, and network, with defined thresholds and alerting.
2. Check whether forecasting exists, using growth trends rather than reacting to alerts at the point of exhaustion.
3. Look specifically at logging and monitoring storage, since these fill quietly and their exhaustion disables detection.
4. Review capacity-related incidents in the period and identify whether they were predictable.
5. Check whether capacity constraints have caused security controls to be reduced or disabled, and whether that was decided or simply happened.
6. Verify that capacity for security functions is included in planning, such as processing headroom for scanning and inspection.
7. Confirm human capacity is considered, linking to Clause 7.1 where operational capacity is constrained by staffing.

EVIDENCE TO COLLECT

- Capacity monitoring configuration with thresholds and alert routing
- Capacity trend and forecast reporting
- Log storage capacity and retention configuration
- Capacity-related incident records
- Records of security controls reduced due to capacity
- Capacity planning documentation

HOW TO DOCUMENT IT

Record log storage capacity against actual retention achieved, since organizations frequently state a retention period that their storage cannot deliver and the difference is only visible when you check. Note any instance where a security control was reduced for capacity reasons, including who decided and whether it was ever restored.

EXECUTIVE SUMMARY TREATMENT

Suggested language: log storage capacity supports a materially shorter retention period than the organization's stated policy, so security logs are being deleted earlier than intended and earlier than an investigation would require. Give both figures. This connects a capacity issue to a detection consequence, which is what makes it worth executive attention.

A.8.7 Protection against malware

WHAT THE CONTROL ASKS FOR

Implement protection against malware, supported by appropriate user awareness. Malware means software intended to cause harm, including ransomware, and the control covers prevention, detection, and the user behaviour that determines exposure.

WHY IT EXISTS

Ransomware remains the most financially damaging category of attack for most organizations, and it usually arrives through ordinary user activity. Technical protection and user awareness are both required because neither is sufficient alone: technical controls miss novel threats, and users cannot detect what is designed to be undetectable.

HOW TO AUDIT IT

1. Verify malware protection coverage across the estate, including servers and non-standard systems, from tooling reports rather than from policy.
2. Check that protection is current, examining update status across the estate and identifying stale agents.
3. Confirm protection cannot be disabled by ordinary users, and test this if permitted.
4. Review detections in the period, what they were, and what response followed. Detections with no recorded response indicate the alerts are not being handled.
5. Check protection at the points of entry: email, web, and removable media.
6. Verify that ransomware-specific considerations are addressed, particularly backup isolation, since backups are targeted first in most ransomware events.
7. Confirm user awareness content covers malware delivery methods currently in use, and check the interval since it was last updated.
8. Check systems that cannot run protection agents and confirm they are identified, compensated for, and on the risk register.

EVIDENCE TO COLLECT

- Malware protection coverage and update status reports
- Configuration showing tamper protection
- Detection records with response actions and dates
- Email and web filtering configuration
- Backup isolation evidence, including whether backups are reachable from the production network
- Awareness content with revision dates
- List of systems without protection and their compensating measures

HOW TO DOCUMENT IT

Report coverage and currency as separate figures, since a fully deployed agent that has not updated for months provides little protection and a combined figure conceals this. Record the backup isolation assessment specifically, stating whether backups can be reached and deleted from a compromised production environment, because that single fact largely determines ransomware survivability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's backups are reachable and deletable from the production network, so a ransomware event that reaches production would also destroy the means of recovery. This is frequently the most consequential finding in an entire engagement and should be stated first if present. Otherwise: a stated number of systems have no malware protection or have not received updates for a stated period.

A.8.8 Management of technical vulnerabilities

WHAT THE CONTROL ASKS FOR

Obtain information about technical vulnerabilities in the systems in use, evaluate the organization's exposure, and take appropriate measures. This is the full vulnerability management cycle: awareness, assessment, prioritization, remediation, and verification.

WHY IT EXISTS

Exploitation of known, unpatched vulnerabilities is among the most common causes of breach, and the window between disclosure and exploitation has been shortening. The control requires evaluation of exposure rather than blanket patching, because organizations cannot patch everything immediately and must therefore prioritize deliberately rather than by whatever is easiest.

HOW TO AUDIT IT

1. Confirm vulnerability information sources cover everything in use, including operating systems, applications, libraries, network devices, and cloud services.
2. Verify scanning coverage against the asset inventory and identify assets never scanned. Unknown assets are unscanned assets, linking to A.5.9.
3. Check that identified vulnerabilities are evaluated for actual exposure rather than accepted at the scanner's severity rating.
4. Review remediation timescales against the organization's own defined targets and measure actual performance.
5. Age the open vulnerabilities by severity and report the oldest critical item, which is usually the most revealing single number.
6. Verify remediation is confirmed by rescanning rather than by the closure of a ticket.
7. Check the exception process for vulnerabilities that cannot be remediated, and confirm exceptions are time-bound, approved, and compensated.
8. Check authenticated scanning is used where possible, since unauthenticated scanning substantially understates exposure.

EVIDENCE TO COLLECT

- Vulnerability information sources and coverage
- Scan coverage report reconciled to the asset inventory
- Remediation targets by severity and measured performance against them
- Open vulnerability aging report by severity
- Rescan verification evidence
- Exception register with approvals, expiry dates, and compensating measures
- Scanner configuration showing authentication status

HOW TO DOCUMENT IT

The aging report is the core evidence: present open vulnerabilities by severity band against the organization's own remediation target, with the age of the oldest item in each band. Using their own targets rather than an external standard makes the finding much harder to dispute. Record scan coverage as a percentage of known assets and note that unknown assets are excluded from that figure entirely.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of vulnerabilities rated critical remain unremediated beyond the organization's own target timeframe, the oldest for a stated number of days, and a stated proportion of

systems are not scanned at all. The two figures together describe both known and unknown exposure, which is a more complete picture than either alone.

A.8.9 Configuration management

WHAT THE CONTROL ASKS FOR

Establish, document, implement, monitor, and review the configurations of hardware, software, services, and networks, including security configurations. This control was consolidated in the 2022 revision and covers the whole configuration lifecycle.

WHY IT EXISTS

Misconfiguration is a leading cause of breach, particularly in cloud environments where a single setting can expose data publicly. Configuration also drifts continuously as changes accumulate, so a system that was secure at deployment may not be secure now. Monitoring for drift is what distinguishes this control from a one-time hardening exercise.

HOW TO AUDIT IT

1. Confirm documented secure baselines exist for each significant technology type, and check whether they derive from a recognized benchmark or were invented locally.
2. Verify baselines are applied at deployment, by checking recently deployed systems against the baseline.
3. Check for drift monitoring and confirm it operates continuously rather than periodically.
4. Sample live systems and compare their configuration to the baseline yourself, since reported compliance is frequently generous.
5. Examine cloud configuration specifically against a recognized benchmark, since this is where misconfiguration is most consequential and most common.
6. Check default credentials and default settings on network devices and appliances, which are frequently left unchanged.
7. Verify configuration changes are controlled, linking to A.8.32, and that unauthorized changes are detected.
8. Confirm baselines are reviewed and updated as guidance changes.

EVIDENCE TO COLLECT

- Secure configuration baselines per technology with their source
- Deployment records showing baseline application
- Drift monitoring configuration and detected drift reports
- Independent configuration extracts from sampled live systems
- Cloud benchmark assessment results
- Default credential audit results
- Baseline revision history

HOW TO DOCUMENT IT

Perform your own comparison of at least one live system against its baseline and record each deviation, since this is far more reliable than the compliance dashboard. Report cloud benchmark results by control family with pass rates. Record any default credentials found individually, because each one is a complete authentication bypass.

EXECUTIVE SUMMARY TREATMENT

Suggested language: independent testing found a stated number of deviations from the organization's own security configuration standard on sampled systems, including a stated number of devices still using default credentials. The phrase deviation from the organization's own standard is deliberate; it removes the argument about whether the standard was appropriate.

A.8.10 Information deletion

WHAT THE CONTROL ASKS FOR

Delete information stored in systems, devices, or any other storage media when it is no longer required. This control was new in 2022. It covers both routine deletion at the end of retention and deletion on request, and it requires that deletion actually removes the information.

WHY IT EXISTS

Information that is retained beyond need is pure liability: it can be breached, it can be subject to legal discovery, and in the case of personal data it can be a regulatory violation simply by existing. Deletion is also harder than it appears, since copies proliferate into backups, caches, archives, and test environments.

HOW TO AUDIT IT

1. Confirm deletion requirements are defined, deriving from retention schedules, legal obligations, and contractual terms.
2. Verify deletion actually occurs. Sample data types past their retention period and check whether they are still present.
3. Check whether deletion reaches all copies, including backups, archives, test environments, and analytics platforms.
4. Review the deletion method and confirm it is appropriate to the storage technology and to the sensitivity of the data.
5. Check the process for deletion on request, including personal data erasure requests, and test it end to end if a real case exists.
6. Verify deletion is evidenced, since an unrecorded deletion cannot be demonstrated to a regulator or a customer.
7. Check the interaction with legal hold, confirming that data under hold is preserved and that holds are released when they expire.

EVIDENCE TO COLLECT

- Deletion requirements derived from retention schedules and obligations
- Evidence of automated deletion configuration in systems
- Sample queries demonstrating the presence or absence of expired data
- Backup and archive deletion arrangements
- Deletion request records with completion evidence
- Legal hold register with application and release records

HOW TO DOCUMENT IT

Test deletion by querying for data that should no longer exist rather than by reviewing the deletion procedure, and record the oldest record found in each sampled category against its retention limit. Address backups explicitly, since deletion from production with retention in backup is the most common partial implementation and organizations frequently believe it satisfies the requirement.

EXECUTIVE SUMMARY TREATMENT

Suggested language: personal data that should have been deleted under the organization's own retention schedule remains in production systems, the oldest exceeding its retention period by a stated number of years, and is also present in backups from which it is not removed. State the regulatory exposure directly where personal data is involved.

A.8.11 Data masking

WHAT THE CONTROL ASKS FOR

Use data masking in line with the access control policy and other relevant requirements, taking account of applicable legislation. This control was new in 2022. Masking means replacing, obscuring, or removing identifying or sensitive elements of data so that it can be used without exposing what it contains. Related techniques include pseudonymization and anonymization.

WHY IT EXISTS

A great deal of data use does not require the real values. Development, testing, analytics, training, and support can often proceed with masked data, and doing so removes the exposure entirely rather than trying to control it. This is also the control that governs data used to build and test models, where real personal data frequently ends up without anyone deciding that it should.

HOW TO AUDIT IT

1. Identify where sensitive or personal data is used outside production, including development, test, training, analytics, and support environments.
2. Determine whether masking is applied and, where it is not, whether that was a documented decision.
3. Assess masking strength. Reversible or weak masking that permits re-identification through combination with other data does not achieve the objective.
4. Check whether masking is applied consistently, since partial masking across related fields frequently allows reconstruction.
5. Verify masking is applied at the point of extraction rather than after loading, since data copied unmasked has already been exposed.
6. Check masked environments for access controls, since teams often assume masked data needs none and the masking is not always as strong as assumed.
7. Where data is used to train or evaluate models, confirm the same requirements have been applied, as this use is frequently overlooked.

EVIDENCE TO COLLECT

- Inventory of non-production environments and the data they contain
- Masking configuration and the rules applied per field
- Evidence of masking effectiveness, such as sample extracts from a non-production environment
- Decisions and approvals where unmasked data is used outside production
- Access controls on non-production environments
- Records of data used for model development or evaluation

HOW TO DOCUMENT IT

Sample a non-production environment and inspect the actual data rather than the masking configuration; this is the only reliable way to establish what is really there. Record the specific sensitive fields found unmasked. Note any use of production data for model development separately, since it carries distinct legal exposure and is rarely covered by the organization's own controls.

EXECUTIVE SUMMARY TREATMENT

Suggested language: development and test environments contain unmasked production data including a named category of personal information, and those environments have materially weaker access controls than production. That combination, real data with reduced protection, is the substance of the finding.

A.8.12 Data leakage prevention

WHAT THE CONTROL ASKS FOR

Apply data leakage prevention measures to systems, networks, and other devices that process, store, or transmit sensitive information. This control was new in 2022. It covers detecting and preventing unauthorized disclosure, whether deliberate or accidental.

WHY IT EXISTS

Most data loss is accidental: the wrong recipient, the wrong attachment, the wrong sharing setting. Deliberate exfiltration by insiders is less common but more damaging. Prevention measures address both, and they are the only control that operates at the point where information is about to leave.

HOW TO AUDIT IT

1. Identify the channels through which sensitive information could leave: email, web upload, removable media, cloud sync, printing, and messaging platforms.
2. Determine which channels have prevention or detection measures and which do not.
3. Check whether the measures are configured against actual sensitive data types, and confirm the rules reflect real classifications rather than generic patterns.
4. Assess whether measures block or merely alert, and if only alert, whether anyone acts on the alerts.
5. Review alerts generated in the period, the proportion investigated, and what was found.
6. Check for tuning. Very high alert volumes indicate the measures are generating noise and will be ignored.
7. Verify measures cover the endpoint as well as the network, since network measures do not see traffic from devices working remotely.
8. Confirm any monitoring of staff activity has been assessed for legal and privacy compliance.

EVIDENCE TO COLLECT

- Channel inventory with coverage status
- Prevention rule configuration and the data types it targets
- Alert volumes and investigation records for the period
- Examples of prevented or detected incidents
- Endpoint coverage evidence
- Legal and privacy assessment of monitoring

HOW TO DOCUMENT IT

List channels against coverage in a table, since the uncovered channels are the finding and the gap is usually obvious once laid out. Report alert volume against investigation rate, because a large gap between the two means the control produces data nobody uses. Note whether coverage extends to remote working, since that is where most work now happens.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has no capability to detect sensitive information leaving through a named channel, and of the alerts generated by the measures that do exist, a stated proportion were never reviewed. The second half matters because it shows the gap is not solved by purchasing more tooling.

A.8.13 Information backup

WHAT THE CONTROL ASKS FOR

Maintain and regularly test backup copies of information, software, and systems, in line with an agreed backup policy. Both halves matter: backups must be taken, and they must be tested by actually restoring from them.

WHY IT EXISTS

Backup is the last line of defence against ransomware, destructive attack, hardware failure, and human error. It is also the control most frequently assumed to work and least frequently verified. Backups that have never been restored have an unknown success rate, and the discovery that they do not work always happens at the worst moment.

HOW TO AUDIT IT

1. Confirm the backup policy defines what is backed up, how often, how long copies are kept, and where they are stored.
2. Verify coverage against the asset inventory and identify systems and data with no backup.
3. Check backup success and failure records for the period and confirm failures were investigated rather than tolerated.
4. Verify restoration testing occurs, and distinguish rigorously between backup completion and restoration testing. Organizations routinely present the first as evidence of the second.
5. Review restoration test scope and realism. Restoring one file does not demonstrate the ability to restore a service.
6. Check backup isolation. Confirm whether backups can be reached, encrypted, or deleted from the production environment, which is the decisive question for ransomware.
7. Verify backup encryption and access control, since backups contain everything and are frequently protected less well than production.
8. Check offline or immutable copies exist for the most critical data.

EVIDENCE TO COLLECT

- Backup policy with scope, frequency, and retention
- Backup coverage reconciled to the asset inventory
- Backup job success and failure reports for the period
- Restoration test records with dates, scope, and measured outcomes
- Backup network isolation and immutability configuration
- Backup encryption and access control evidence

HOW TO DOCUMENT IT

Record the date and scope of the last successful restoration test for each critical system; blank entries are the finding and they are usually numerous. Document backup isolation as a specific technical assessment: whether production credentials can reach the backup system, and whether backups can be deleted from production. State plainly where backup completion is being offered as evidence of restoration capability.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization has never tested restoration for a stated number of its critical systems, and its backups can be reached and deleted using credentials available in the production environment. Together these mean recovery capability is both unproven and destroyable. If the control is sound, say so; a working backup regime is worth stating positively.

A.8.14 Redundancy of information processing facilities

WHAT THE CONTROL ASKS FOR

Implement information processing facilities with sufficient redundancy to meet availability requirements. Redundancy means duplicate capability that can take over when the primary fails, sized according to what the business actually requires.

WHY IT EXISTS

Availability is one of the three properties the standard protects. Redundancy is how availability requirements are met technically. The requirement is tied to stated availability needs, which means redundancy that exceeds or falls short of documented requirements is a finding in either direction, though falling short is far more common.

HOW TO AUDIT IT

1. Obtain the availability requirements per service and confirm they were set by the business.
2. Map the redundancy actually implemented against those requirements and identify shortfalls.
3. Look for single points of failure, examining shared dependencies that defeat apparent redundancy: shared power, shared network paths, shared authentication, shared management planes.
4. Verify failover has been tested, with dates and measured results. Untested failover frequently does not work.
5. Check whether failover is automatic or manual, and if manual, whether the procedure is documented and the people are trained.
6. Confirm the redundant capability is maintained to the same standard as the primary, including patching and configuration.
7. Check capacity of the redundant environment, since reduced-capacity failover may not meet requirements under real load.

EVIDENCE TO COLLECT

- Availability requirements per service with business sign-off
- Architecture documentation showing redundancy and dependencies
- Failover test records with dates and measured outcomes
- Single point of failure analysis
- Configuration and patch status of redundant components
- Capacity comparison between primary and redundant environments

HOW TO DOCUMENT IT

Trace shared dependencies yourself rather than accepting architecture diagrams, since apparent redundancy frequently collapses onto a shared component that the diagram does not show. Record the date and result of the last failover test per service, and note where redundancy exists but has never been exercised.

EXECUTIVE SUMMARY TREATMENT

Suggested language: services described as redundant share a single dependency whose failure would take all of them down simultaneously, and failover has never been tested. Name the shared dependency. The gap between believed and actual resilience is the message.

A.8.15 Logging

WHAT THE CONTROL ASKS FOR

Produce, store, protect, and analyse logs recording activities, exceptions, faults, and other relevant events. Logging is the record of what happened; without it, nothing can be investigated, detected, or proven.

WHY IT EXISTS

Logs are the only evidence of past activity. Their absence makes incidents uninvestigable and makes it impossible to establish scope, which in a breach determines notification obligations. Log protection matters because an attacker's first action after gaining privilege is frequently to alter or delete the record of how they arrived.

HOW TO AUDIT IT

1. Establish what is logged across the estate and check for gaps, particularly on systems holding sensitive data and on security controls themselves.
2. Verify the logged content is sufficient to reconstruct events: who, what, when, from where, and outcome.
3. Check that privileged activity, authentication events, and access to sensitive data are logged specifically.
4. Verify log protection, confirming logs are written to a location the originating system's administrators cannot alter.
5. Check retention against both investigative need and any regulatory requirement, comparing it to the organization's typical detection delay.
6. Confirm time synchronization across log sources, linking to A.8.17, since unsynchronized logs cannot be correlated.
7. Verify logs are analysed, not merely stored, linking to A.8.16.
8. Check log completeness by generating a test event, with authorization, and confirming it appears.

EVIDENCE TO COLLECT

- Logging configuration per system and event type
- Central log platform coverage against the asset inventory
- Log protection and integrity configuration
- Retention configuration and evidence that logs exist for a past date
- Time synchronization status across sources
- Test event evidence showing end to end capture

HOW TO DOCUMENT IT

Generate a test event and trace it to the central platform, recording each step; this verifies the pipeline in a way that configuration review cannot. Record log coverage against the asset inventory as a percentage and identify uncovered systems individually, prioritizing those holding sensitive data. Note retention against the organization's own average detection time.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of systems, including those holding a named category of sensitive data, produce no centrally retained logs, so activity on them cannot be investigated. If retention is the issue, state that logs are kept for a shorter period than the organization's average time to detect an incident, meaning the evidence is gone before the incident is found.

A.8.16 Monitoring activities

WHAT THE CONTROL ASKS FOR

Monitor networks, systems, and applications for anomalous behaviour and take appropriate action to evaluate potential security incidents. Where A.8.15 requires the record, this control requires someone to look at it and act.

WHY IT EXISTS

Logs nobody examines detect nothing. Monitoring is the organization's detection capability, and detection time is the variable that most determines the eventual cost of a breach. The requirement to take appropriate action is what separates monitoring from collection.

HOW TO AUDIT IT

1. Establish what is actually monitored and confirm the coverage matches the risk, rather than matching what happened to be easy to instrument.
2. Check detection rules and confirm they reflect the threats the organization actually faces, linking to A.5.7.
3. Verify monitoring coverage across hours. Detection that operates only during business hours leaves the majority of the week uncovered.
4. Review alert volumes, triage rates, and outcomes. Alerts generated but not triaged indicate a capacity or tuning problem.
5. Measure detection performance using real examples: how incidents in the period were actually detected, and whether monitoring or an external party found them.
6. Check false positive rates and tuning activity, since untuned monitoring is abandoned in practice regardless of what the process says.
7. Verify escalation from monitoring to incident response is defined and works, tracing a real example.
8. Check that monitoring covers cloud and remote endpoints, not just the traditional network.

EVIDENCE TO COLLECT

- Monitoring coverage and detection rule inventory
- Alert volume, triage, and outcome statistics for the period
- Rota or service arrangements covering out of hours
- Incident records showing the detection source for each
- Tuning records and false positive trends
- Escalation records tracing a detection through to response

HOW TO DOCUMENT IT

Categorize incidents in the period by how they were detected: internal monitoring, staff report, customer report, or external notification. The proportion detected internally is the single most useful measure of this control and it is rarely calculated by the organization itself. Report alert volume against triage rate with the gap stated explicitly.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of the incidents recorded this period were identified by someone outside the organization rather than by its own monitoring, and outside business hours there is no capability to detect or respond at all. The externally-detected proportion is a figure executives immediately understand.

A.8.17 Clock synchronization

WHAT THE CONTROL ASKS FOR

Synchronize the clocks of information processing systems to approved time sources. A short control with a narrow requirement: everything that produces a timestamp should agree on what time it is.

WHY IT EXISTS

Correlation across systems depends entirely on comparable timestamps. During an investigation, unsynchronized clocks make it impossible to establish the sequence of events across systems, which is exactly what an investigation needs to determine. Timestamps also carry evidential weight, and inconsistent time undermines it.

HOW TO AUDIT IT

1. Confirm approved time sources are defined and are appropriate, and check whether they are reliable and traceable.
2. Verify synchronization configuration across system types, including network devices, cloud workloads, and appliances, not just servers.
3. Check actual synchronization status rather than configuration, since agents fail silently and drift accumulates unnoticed.
4. Compare timestamps for the same event across multiple systems if you can generate one, which demonstrates the real state directly.
5. Confirm time zone handling is consistent, since logs recorded in local time across multiple regions create the same correlation problem as drift.
6. Check that synchronization failure is monitored and alerts someone.

EVIDENCE TO COLLECT

- Approved time source definition
- Synchronization configuration across system types
- Current synchronization status report showing offset per system
- Time zone configuration for log sources
- Monitoring and alerting for synchronization failure

HOW TO DOCUMENT IT

Report actual measured offsets rather than configuration status, and list systems exceeding an acceptable threshold. Where you generated a test event, record the timestamp recorded by each system. Note time zone inconsistency separately from drift, since the two have different fixes.

EXECUTIVE SUMMARY TREATMENT

Rarely an executive item on its own, but worth including where it undermines investigation. Suggested language: system clocks differ by up to a stated amount, so events across systems cannot be reliably sequenced during an investigation. Attach it to a logging or monitoring finding rather than reporting it alone.

A.8.18 Use of privileged utility programs

WHAT THE CONTROL ASKS FOR

Restrict and tightly control the use of utility programs capable of overriding system and application controls. These are tools that operate below or around normal application logic: direct database editors, disk and memory tools, debuggers, and administrative scripting environments.

WHY IT EXISTS

These tools bypass the controls the organization relies on. A database utility can change a record without any application-level check, approval, or audit trail. Their legitimate uses are real but narrow, and the gap between the harm they can do and the attention they usually receive is wide.

HOW TO AUDIT IT

1. Identify the utility programs present across the estate that can override controls.
2. Check who can execute them, and whether that access is restricted to the small population that genuinely needs it.
3. Verify their use is logged and that the logs are reviewed, since these are precisely the actions least likely to be visible elsewhere.
4. Check whether use requires prior authorization for sensitive operations, particularly direct data modification in production.
5. Look for utilities installed on systems where they are not needed, which is common on servers built from a general-purpose image.
6. Check whether application-level controls can be bypassed through these tools without detection, and test this if permitted.
7. Verify segregation, linking to A.5.3, so that the person using such a tool is not also the person reviewing its use.

EVIDENCE TO COLLECT

- Inventory of privileged utilities and the systems they are installed on
- Access lists for utility execution
- Usage logs and evidence of review
- Authorization records for sensitive utility operations
- Configuration showing removal or restriction on systems that do not need them

HOW TO DOCUMENT IT

Record who can perform direct data modification in production and whether any record of such modification would exist. That question is usually more revealing than the utility inventory itself. List systems carrying utilities they do not need, since removal is a straightforward remediation.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of staff can modify production data directly, bypassing every application control and approval step, and such changes leave no record. The absence of a record is the part that matters, since it means the exposure cannot be assessed retrospectively.

A.8.19 Installation of software on operational systems

WHAT THE CONTROL ASKS FOR

Implement procedures and measures to securely manage software installation on operational systems. This covers what software may be installed, who may install it, and how installation is controlled and recorded.

WHY IT EXISTS

Unmanaged software brings vulnerabilities the organization does not know it has, licensing liability it did not agree to, and in some cases deliberately malicious functionality. Operational systems in particular should change only through controlled processes, because unrecorded change makes both troubleshooting and investigation unreliable.

HOW TO AUDIT IT

1. Confirm procedures define what software is permitted and how installation is authorized.
2. Check technical enforcement. Determine whether ordinary users can install software and test this if permitted.
3. Verify installation on servers and other operational systems follows change control, linking to A.8.32.
4. Review installed software inventories against the approved list and identify unapproved software, quantifying it.
5. Check that software sources are verified, including package integrity and signature validation.
6. Confirm rollback capability exists for installations that cause problems.
7. Check whether unsupported or end of life software is present and whether it appears on the risk register.

EVIDENCE TO COLLECT

- Software installation procedures and the approved software list
- Installed software inventory across the estate
- Application control or allow-listing configuration
- Change records for operational system software installations
- Source verification and signature checking evidence
- End of life software inventory

HOW TO DOCUMENT IT

Compare the installed software inventory against the approved list and report the count of unapproved packages, with the most significant named individually. Record whether users hold the ability to install, since that determines whether the finding is about process or about enforcement. Note end of life software with its support expiry date.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of unapproved software packages are installed across the estate, including a stated number that are no longer supported and can no longer receive security updates. Naming a specific unsupported package with a widely known vulnerability makes this immediate.

A.8.20 Networks security

WHAT THE CONTROL ASKS FOR

Manage and control networks and network devices to protect information in systems and applications. This is the general network security control covering design, configuration, and operation.

WHY IT EXISTS

The network determines what can reach what. A flat network means any compromised device can reach everything, which converts a minor foothold into a full compromise. Network control is the primary mechanism limiting how far an intruder can move after they arrive.

HOW TO AUDIT IT

1. Obtain current network documentation and test its accuracy against the live environment, since network diagrams are frequently years out of date.
2. Review network device configuration against a hardened baseline, checking management interfaces, default credentials, and unnecessary services.
3. Check management of network devices: how administrative access is obtained, from where, and with what authentication.
4. Verify network device configurations are backed up and that changes are controlled and recorded.
5. Check wireless network security, including separation of guest access from internal networks and the authentication in use.
6. Look for unmanaged network devices, including access points and switches installed by teams outside the network function.
7. Verify that connections to external parties are identified, documented, and controlled.
8. Check whether network device firmware is maintained, as this is frequently neglected relative to server patching.

EVIDENCE TO COLLECT

- Current network diagrams and their verification against live configuration
- Network device configuration extracts
- Management access configuration for network devices
- Configuration backup and change records
- Wireless configuration including guest separation
- External connection register
- Network device firmware versions against current releases

HOW TO DOCUMENT IT

Verify network documentation against reality for at least one segment and record the discrepancies, since inaccurate diagrams undermine every architectural assertion the organization makes. List network devices running outdated firmware with their versions and the age of the current release. Record wireless guest separation as tested rather than as configured.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the organization's network documentation does not reflect its actual network, and network devices are running firmware that is a stated period out of date. If separation is the issue, state that guest wireless access reaches internal systems, which is a finding that requires no elaboration.

A.8.21 Security of network services

WHAT THE CONTROL ASKS FOR

Identify, implement, and monitor the security mechanisms, service levels, and requirements of network services. This applies to services provided internally and those obtained from providers, and it requires that the security properties of each service are known and agreed.

WHY IT EXISTS

Network services are frequently obtained from third parties whose security properties are assumed rather than established. Connectivity providers, content delivery, and managed network services all carry security implications, and if the requirements are not agreed in advance there is nothing to hold the provider to.

HOW TO AUDIT IT

1. Inventory the network services in use, internal and external, and confirm each has identified security requirements.
2. For provided services, check whether security mechanisms and service levels are documented in the agreement, linking to A.5.20.
3. Verify the security mechanisms in place actually match what was agreed, rather than accepting the provider's description.
4. Check monitoring of service security and performance against the agreed levels, and look for evidence of action where levels were missed.
5. Confirm the organization knows what a provider can see of its traffic, and whether that is acceptable.
6. Check the arrangements for provider access into the organization's environment, if any.
7. Verify that service changes by the provider are notified and assessed.

EVIDENCE TO COLLECT

- Network service inventory with security requirements per service
- Provider agreements containing security mechanisms and service levels
- Monitoring reports against agreed levels
- Records of provider changes and their assessment
- Provider access arrangements and their controls
- Evidence verifying implemented mechanisms

HOW TO DOCUMENT IT

Record the agreed security mechanism against the observed mechanism for each sampled service, since the two diverge more often than expected. Note what each provider can observe of the organization's traffic, because this is frequently unconsidered and occasionally significant.

EXECUTIVE SUMMARY TREATMENT

Suggested language: the security properties of the organization's network services are assumed rather than agreed, and a named provider has visibility of traffic that the organization has never assessed. Provider visibility is the version of this finding that most often prompts action.

A.8.22 Segregation of networks

WHAT THE CONTROL ASKS FOR

Segregate groups of information services, users, and information systems within the organization's networks. Segregation means dividing the network so that traffic between segments is controlled rather than free.

WHY IT EXISTS

Segregation limits lateral movement, which is the phase of an intrusion where a small compromise becomes a large one. It is the single most effective architectural control against the spread of ransomware. A flat network means the compromise of one workstation is functionally the compromise of everything that workstation can reach, which in a flat network is everything.

HOW TO AUDIT IT

1. Establish how the network is segmented and against what principle: by sensitivity, by function, by environment, or not at all.
2. Verify segmentation is enforced by controls rather than by addressing convention, since separate address ranges with no filtering between them provide no segregation.
3. Test the controls between segments by examining rule sets, looking for permissive rules that defeat the intent.
4. Check that the most sensitive environments are segregated most strongly, and specifically examine whether ordinary user workstations can reach servers, management interfaces, and backup infrastructure directly.
5. Examine management network separation, since flat management access is a common and severe weakness.
6. Check segregation between production and non-production environments, linking to A.8.31.
7. Verify that segregation is maintained for remote and cloud-connected users, who frequently bypass it entirely.
8. Review rule sets for accumulated permissive entries and check when they were last reviewed.

EVIDENCE TO COLLECT

- Network segmentation design and its rationale
- Firewall and access control rule sets between segments
- Rule review records with dates and removals
- Test evidence showing what a workstation can reach
- Management network configuration
- Remote access path documentation showing which segment it lands in

HOW TO DOCUMENT IT

Establish what an ordinary workstation can actually reach, by rule set analysis or by testing with authorization, and record it as a list of reachable sensitive destinations. This single result describes the practical value of the segmentation better than any diagram. Report permissive rules with their age and last review date.

EXECUTIVE SUMMARY TREATMENT

Suggested language: an ordinary user workstation can reach the organization's servers, management interfaces, and backup infrastructure directly, so the compromise of any single workstation would give an attacker a direct path to everything that matters. This is among the most consequential architectural findings available and it should be stated in those terms.

A.8.23 Web filtering

WHAT THE CONTROL ASKS FOR

Manage access to external websites to reduce exposure to malicious content. This control was new in 2022. It covers blocking or restricting access to sites known or likely to host malicious content, and it may also cover categories of site restricted for other reasons.

WHY IT EXISTS

The web remains a primary delivery route for malware and for credential phishing. Filtering removes a large volume of exposure at low cost, before any endpoint control is tested. It also provides a record of where users attempted to go, which is useful during investigation.

HOW TO AUDIT IT

1. Confirm filtering is in place and identify what it blocks: known malicious sites, newly registered domains, uncategorized sites, and any policy-based categories.
2. Verify coverage extends to remote and mobile users rather than only to office traffic, since most work now occurs outside the network perimeter.
3. Check whether encrypted traffic is inspected or bypasses filtering, since unfiltered encrypted traffic substantially reduces the control's value.
4. Review the bypass and exception process and check who holds exemptions, and why.
5. Examine blocked event records and confirm that patterns suggesting compromise are escalated rather than merely counted.
6. Verify filtering categories are reviewed and that blocking does not create business friction severe enough to drive workarounds.
7. Confirm any monitoring of individual browsing has been assessed for legal and privacy compliance.

EVIDENCE TO COLLECT

- Filtering configuration with categories and actions
- Coverage evidence for remote and mobile users
- Encrypted traffic inspection configuration
- Exception and bypass list with justifications
- Blocked event records and escalation evidence
- Privacy assessment for browsing monitoring

HOW TO DOCUMENT IT

Record coverage separately for office, remote, and mobile users, since the differences are usually substantial and the aggregate figure is misleading. Note whether encrypted traffic is inspected, because filtering without it addresses a small and shrinking proportion of real traffic. List exemption holders and their roles.

EXECUTIVE SUMMARY TREATMENT

Suggested language: web filtering does not apply to staff working remotely, which is the majority of the organization's working time, so the protection exists only where it is least needed. The mismatch between where the control applies and where the work happens is the point.

A.8.24 Use of cryptography

WHAT THE CONTROL ASKS FOR

Define and implement rules for the effective use of cryptography, including cryptographic key management. Cryptography here means encryption and related techniques; key management means how keys are generated, distributed, stored, rotated, and destroyed.

WHY IT EXISTS

Encryption is only as good as its key management. A perfectly implemented algorithm protecting data with a key stored beside it provides no protection at all. Key management is where cryptographic implementations fail in practice, and it is the part organizations most often have not thought through.

HOW TO AUDIT IT

1. Obtain the cryptography policy and confirm it defines approved algorithms, key lengths, and where cryptography must be applied.
2. Check the policy against current guidance, since algorithms and key lengths considered adequate previously may not be now.
3. Verify actual implementation against the policy by examining configurations, including protocol versions and cipher suites in use.
4. Examine key management in detail: generation, storage, access, rotation, and destruction, for each significant key type.
5. Check who can access keys and whether that access is separated from access to the data the keys protect.
6. Verify key rotation occurs at the defined interval and check evidence rather than intention.
7. Check certificate management, including inventory, expiry tracking, and the process when a certificate expires unexpectedly.
8. Confirm arrangements for key recovery and for the consequences of key loss.

EVIDENCE TO COLLECT

- Cryptography policy with approved algorithms and applications
- Configuration evidence showing protocols and cipher suites in use
- Key management procedures per key type
- Key storage arrangements and access lists
- Key rotation records with dates
- Certificate inventory with expiry dates
- Key recovery arrangements

HOW TO DOCUMENT IT

Record where keys are stored relative to the data they protect, and who can access both. That relationship determines whether the encryption provides real protection and it is frequently not documented anywhere. Report certificates by expiry date and identify any expiring within the coming period, since expiry causes outage and is entirely preventable.

EXECUTIVE SUMMARY TREATMENT

Suggested language: encryption keys are stored in the same environment as the data they protect and are accessible to the same administrators, so the encryption provides no protection against the compromise of that environment. If certificates are the issue, give the count expiring within a stated period and the services they support.

A.8.25 Secure development life cycle

WHAT THE CONTROL ASKS FOR

Establish and apply rules for the secure development of software and systems. This means security is built into the development process at every stage rather than tested for at the end.

WHY IT EXISTS

Security defects introduced during development are cheapest to fix at the point of introduction and most expensive to fix in production. A development process without security stages will produce vulnerabilities at a predictable rate, and testing at the end finds only a fraction of them.

HOW TO AUDIT IT

1. Obtain the development lifecycle definition and identify the security activities at each stage.
2. Verify the security activities actually occur by sampling recent development work and looking for their outputs.
3. Check that the rules apply to all development, including work by contractors, work in business units outside the development function, and low-code or configuration-based development.
4. Verify developers are trained in secure development, linking to A.6.3, and check the currency of that training.
5. Check whether security requirements are defined at the start rather than derived at the end, linking to A.8.26.
6. Examine how security defects found in production are fed back into the development process.
7. Confirm the lifecycle covers maintenance and change, not only new development.
8. Check whether security activities are enforced by the pipeline or rely on developer discretion.

EVIDENCE TO COLLECT

- Documented development lifecycle with security activities per stage
- Evidence of security activities for sampled development work
- Developer secure development training records
- Pipeline configuration showing enforced security gates
- Defect feedback records from production to development
- Coverage evidence including contractor and business-unit development

HOW TO DOCUMENT IT

Sample recent development work and record which security activities produced evidence and which did not, by stage. This shows where the lifecycle breaks down rather than concluding that it does. Note whether security gates are enforced by tooling or depend on individuals, since the latter degrades under delivery pressure without anyone deciding it should.

EXECUTIVE SUMMARY TREATMENT

Suggested language: security activities in the development process depend on individual discretion rather than being enforced, and sampled work showed a stated proportion proceeding to production with those activities skipped. If training is the gap: developers building the organization's software have received no secure development training.

A.8.26 Application security requirements

WHAT THE CONTROL ASKS FOR

Identify, specify, and approve security requirements when developing or acquiring applications. The requirements must be established before the application is built or bought, and they must be approved by someone accountable.

WHY IT EXISTS

Requirements determine what gets built. Security not stated as a requirement will not be delivered, and adding it afterwards means rework or acceptance of the gap. This applies as much to acquired applications as to developed ones, since the point of purchase is the last moment at which security properties can be negotiated.

HOW TO AUDIT IT

1. Confirm a defined method exists for establishing application security requirements, and check whether it is risk-based or a fixed checklist.
2. Sample recent applications, both developed and acquired, and verify requirements were defined before development or purchase.
3. Check that requirements cover the substance: authentication, authorization, data protection, logging, input handling, and error handling.
4. Verify requirements were approved by an accountable party rather than assembled by the development team alone.
5. Check whether delivered applications were verified against their requirements, and what happened where they were not met.
6. For acquired applications, check whether security requirements formed part of the selection criteria and the resulting contract.
7. Examine whether requirements reflect the sensitivity of the data the application handles.

EVIDENCE TO COLLECT

- Requirements definition method or template
- Security requirements for sampled applications with dates
- Approval records for requirements
- Verification evidence showing delivery against requirements
- Procurement records showing security in selection criteria
- Records of unmet requirements and their acceptance

HOW TO DOCUMENT IT

Compare the date requirements were defined to the date development began or the purchase was made, for each sampled application. Requirements defined afterwards are documentation rather than requirements, and the date comparison evidences this cleanly. Record unmet requirements and who accepted them.

EXECUTIVE SUMMARY TREATMENT

Suggested language: applications handling a named category of sensitive data were acquired without security requirements being defined or considered in selection, so the organization accepted whatever security properties the product happened to have. Name the applications and the data.

A.8.27 Secure system architecture and engineering principles

WHAT THE CONTROL ASKS FOR

Establish, document, maintain, and apply principles for engineering secure systems. Principles are the design rules applied consistently across systems, such as defence in depth, least privilege, failing securely, and minimizing attack surface.

WHY IT EXISTS

Principles produce consistency. Without them each system is designed according to whatever its architect knew at the time, which means security properties vary unpredictably across the estate. Principles also make review possible, since a design can be assessed against a stated standard rather than against individual opinion.

HOW TO AUDIT IT

1. Confirm engineering principles are documented, and assess whether they are specific enough to guide a design decision or are merely aspirational.
2. Check that principles are known to the people designing systems, by asking them rather than by checking distribution records.
3. Verify principles are applied by reviewing recent architectures against them.
4. Check whether architecture review occurs and whether it has ever rejected or changed a design.
5. Examine whether principles are maintained and updated as technology and threats change.
6. Check application to cloud and platform architectures specifically, since principles written for traditional infrastructure often do not translate.
7. Verify that deviations from principles are documented and approved rather than silently accepted.

EVIDENCE TO COLLECT

- Documented engineering principles with review dates
- Architecture documentation for recently designed systems
- Architecture review records including outcomes and changes required
- Deviation records with approvals
- Evidence principles are communicated to designers

HOW TO DOCUMENT IT

Assess sampled architectures against the stated principles and record the result per principle, which identifies which principles are real and which are decorative. Record whether architecture review has ever changed a design, since a review function that approves everything is not functioning.

EXECUTIVE SUMMARY TREATMENT

Usually a supporting finding rather than a headline. Suggested language: the organization's security engineering principles are not applied in practice, and architecture review has not resulted in any design change in the period reviewed. Pair it with the specific architectural weaknesses you found elsewhere, which are the evidence that principles are not working.

A.8.28 Secure coding

WHAT THE CONTROL ASKS FOR

Apply secure coding principles to software development. This covers coding standards, developer knowledge, tooling that detects insecure patterns, and review of code before it reaches production.

WHY IT EXISTS

Most application vulnerabilities originate in code, and the categories responsible are well known and largely preventable. Secure coding addresses defects at the point of creation, which is where they are cheapest to prevent and where prevention scales, since a developer who has learned the pattern stops producing it.

HOW TO AUDIT IT

1. Confirm secure coding standards exist and are specific to the languages and frameworks actually used.
2. Verify developers are aware of them and trained, and check the training covers the vulnerability classes relevant to what they build.
3. Check for automated analysis in the pipeline, including static analysis and dependency scanning, and confirm it runs on every change rather than periodically.
4. Verify findings from automated tooling are acted on. Tooling that reports into a queue nobody reviews provides no benefit.
5. Check code review practice, including whether security is part of the review and whether reviewers are equipped to assess it.
6. Examine whether builds fail on serious findings or merely warn, since warnings are routinely ignored under delivery pressure.
7. Review vulnerabilities found in production and assess whether secure coding practice would have prevented them.
8. Check third-party and contractor code is subject to the same standards.

EVIDENCE TO COLLECT

- Secure coding standards per language and framework
- Developer training records
- Pipeline configuration showing analysis tooling and failure thresholds
- Analysis findings with remediation status and age
- Code review records showing security consideration
- Production vulnerability records with root cause

HOW TO DOCUMENT IT

Report open static analysis findings by severity and age, which shows whether tooling output is being consumed or accumulated. Record whether the pipeline blocks on serious findings, since that single configuration setting largely determines whether the control operates. Trace production vulnerabilities back to whether tooling detected them and they were dismissed, or whether they were never detected.

EXECUTIVE SUMMARY TREATMENT

Suggested language: automated security analysis runs on the organization's code but its findings are not acted on, with a stated number of high severity issues open for an average of a stated period. Tooling purchased and ignored is a framing that produces action, because the investment has already been made.

A.8.29 Security testing in development and acceptance

WHAT THE CONTROL ASKS FOR

Define and implement security testing processes in the development lifecycle. Testing must occur during development and at acceptance, with defined criteria for what constitutes a pass.

WHY IT EXISTS

Testing is the verification step that confirms the security requirements were actually met. Without defined acceptance criteria, testing produces findings that are noted and then overridden by delivery pressure. The criteria are what give the test authority.

HOW TO AUDIT IT

1. Confirm security testing is defined as part of the lifecycle with the types of testing required at each stage.
2. Check acceptance criteria exist and are specific. Criteria stating that no critical issues remain are usable; criteria stating that security is satisfactory are not.
3. Sample recent releases and verify testing occurred, examining scope and results.
4. Check what happened where testing found issues. Releases proceeding with unresolved critical findings indicate the criteria are advisory.
5. Verify testing covers the areas that matter: authentication, authorization, input handling, and business logic, rather than only automated scanning.
6. Check independence of testing, since developers testing their own work find fewer issues.
7. Confirm penetration testing occurs at appropriate intervals for significant applications, and check that its findings are remediated and retested.
8. Check testing of changes, not only of new releases.

EVIDENCE TO COLLECT

- Security testing requirements per lifecycle stage
- Acceptance criteria with defined thresholds
- Test results for sampled releases
- Records of releases proceeding with open findings and who approved them
- Penetration test reports with remediation and retest evidence
- Tester independence evidence

HOW TO DOCUMENT IT

Record releases that proceeded with unresolved findings above the acceptance threshold, with the approver for each. This list demonstrates whether criteria function as criteria. For penetration tests, record findings against remediation status and note anything outstanding from prior tests, since repeat findings across tests are particularly damaging.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated number of releases proceeded to production with unresolved critical security findings, and findings from the previous penetration test remain open at the time of the next one. Repeat findings across successive tests are the strongest available evidence that testing is not driving remediation.

A.8.30 Outsourced development

WHAT THE CONTROL ASKS FOR

Direct, monitor, and review the activities related to outsourced system development. Where development is performed by an external party, the organization retains responsibility for the security of what is produced and must therefore exercise oversight.

WHY IT EXISTS

Outsourcing transfers the work but not the risk. Code produced externally enters the organization's environment with whatever properties it was built with. Without defined requirements and active oversight, the organization discovers those properties only after deployment, and often only after an incident.

HOW TO AUDIT IT

1. Identify all outsourced development, including work commissioned by business units outside the technology function.
2. Verify security requirements were specified in the contract, including coding standards, testing obligations, and the right to review.
3. Check that the organization exercises its oversight rights rather than merely holding them, and look for evidence of actual review.
4. Verify code produced externally is subject to the same testing and review as internal code before deployment.
5. Check intellectual property and code ownership, linking to A.5.32, and confirm the organization can maintain the code independently.
6. Examine the developer's access to organizational systems and data during development, and whether it was appropriate and time-bound.
7. Check arrangements for security support after delivery, including vulnerability disclosure and patching obligations.
8. Verify handover includes documentation sufficient for the organization to maintain and secure the software.

EVIDENCE TO COLLECT

- Register of outsourced development engagements
- Contracts containing security requirements and review rights
- Evidence of exercised oversight, such as review records and test results
- Security testing performed on delivered code
- Access records for external developers
- Post-delivery support and patching obligations
- Handover documentation

HOW TO DOCUMENT IT

Record whether delivered code received the same security testing as internally developed code, since this is the most common and most consequential gap. Note the access external developers held and whether it was revoked at the end of the engagement, linking to A.5.18. Record any engagement discovered outside the technology function.

EXECUTIVE SUMMARY TREATMENT

Suggested language: software developed by external parties enters production without the security testing applied to internally developed code, and external developers retain access to organizational systems after

their engagements ended. Both are specific, both are verifiable, and both have straightforward remediations.

A.8.31 Separation of development, test and production environments

WHAT THE CONTROL ASKS FOR

Separate development, testing, and production environments and secure them appropriately. Separation covers the systems themselves, the access to them, and the data they contain.

WHY IT EXISTS

Non-production environments are built for speed, not for security. They have weaker controls, broader access, and less monitoring. If they share infrastructure, credentials, or network paths with production, they become the easiest route into it. They also frequently contain production data, which extends the exposure of that data to everyone with development access.

HOW TO AUDIT IT

1. Confirm the environments are separated technically, and establish what separation actually exists: separate infrastructure, separate networks, separate credentials, or only separate naming.
2. Check whether credentials are shared across environments, since a shared account defeats separation regardless of network controls.
3. Verify access to production is restricted to a smaller population than access to development.
4. Check for production data in non-production environments, linking to A.8.11, and quantify what is there.
5. Examine network paths between environments and confirm they are controlled.
6. Check whether developers hold production access, and if so whether it is standing or granted on request.
7. Verify code and configuration move between environments through a controlled process rather than by manual copy.
8. Check that non-production environments are patched and maintained, since they are frequently neglected and then used as a foothold.

EVIDENCE TO COLLECT

- Environment inventory with infrastructure and network separation detail
- Access lists per environment
- Credential configuration showing whether accounts are shared
- Data inventory for non-production environments
- Network controls between environments
- Deployment process documentation
- Patch status for non-production systems

HOW TO DOCUMENT IT

Record the population with production access against the population with development access, and identify individuals holding both. Where production data exists in non-production, state the volume and the sensitivity, and record the access population for that environment, since that number is the real exposure figure.

EXECUTIVE SUMMARY TREATMENT

Suggested language: development environments contain production data including a named sensitive category, and are accessible to a stated number of people, which is substantially more than have access to production itself. The comparison between the two access populations is what makes this finding land.

A.8.32 Change management

WHAT THE CONTROL ASKS FOR

Subject changes to information processing facilities and information systems to change management procedures. This covers how changes are requested, assessed, approved, tested, implemented, and reviewed, including emergency changes.

WHY IT EXISTS

Change is the most common cause of both outage and of newly introduced vulnerability. Change management provides the point at which security consequences are considered before they are realized. It also produces the record that makes troubleshooting and investigation possible, since without it nobody can establish what changed.

HOW TO AUDIT IT

1. Obtain the change procedure and confirm it includes security assessment as a defined step rather than as an optional consideration.
2. Sample changes and verify each had the required assessment, approval, and testing, checking evidence rather than status fields.
3. Examine emergency changes specifically, including their volume, their retrospective approval, and whether a security review followed.
4. Look for unrecorded changes by comparing system configuration change logs to the change record, which frequently reveals a substantial volume of change outside the process.
5. Check whether changes are tested before implementation and whether rollback plans exist and have been validated.
6. Verify post-implementation review occurs for significant changes.
7. Check that changes to security controls themselves receive appropriate scrutiny, since these are the changes with the most direct security consequence.
8. Review the approval population and confirm approvers are independent of the requester.

EVIDENCE TO COLLECT

- Change management procedure including emergency provisions
- Change records for sampled changes with assessment and approval evidence
- Emergency change volume and retrospective review records
- System configuration change logs for comparison against change records
- Rollback plans and any evidence of their use
- Post-implementation review records

HOW TO DOCUMENT IT

Compare system-generated configuration change logs against the change record and report the volume of change occurring outside the process. This comparison is the highest-value test available for this control and organizations rarely perform it themselves. Report emergency changes as a proportion of total changes, since a high proportion means the emergency route has become the normal route.

EXECUTIVE SUMMARY TREATMENT

Suggested language: a stated proportion of changes to production systems occur outside the change management process entirely, and emergency changes, which bypass security assessment, account for a stated proportion of all recorded changes. Both figures are derived from the organization's own systems, which makes them difficult to dispute.

A.8.33 Test information

WHAT THE CONTROL ASKS FOR

Select, protect, and manage test information appropriately. Test information is the data used for testing systems, and the control requires deliberate decisions about what data is used, how it is protected, and how long it is kept.

WHY IT EXISTS

Using production data for testing is convenient and common, and it extends the exposure of that data to everyone with test access, in an environment with weaker controls. Test data also persists, accumulating in environments nobody reviews. Where data is used to build or evaluate models, the same issues apply with additional legal considerations about the purpose for which the data was collected.

HOW TO AUDIT IT

1. Establish what data is used for testing across environments and where it came from.
2. Verify that the use of production-derived data was a documented decision with a stated justification, rather than a default.
3. Check protection applied to test data, including masking and access control, linking to A.8.11.
4. Confirm authorization for the use of production data in testing, and check whether the data owner approved it.
5. Check retention. Test data frequently persists long after the testing that required it, accumulating in environments nobody monitors.
6. Verify test data is removed when no longer needed and that removal is evidenced.
7. Where personal data is involved, check the lawful basis for using it in testing, since the original collection purpose may not extend to it.
8. Check the same questions for data used in model development or evaluation, which is frequently governed by no process at all.

EVIDENCE TO COLLECT

- Test data sources and selection records
- Authorization for production data use with data owner approval
- Masking or protection applied to test data
- Access lists for environments holding test data
- Retention and deletion records for test data
- Lawful basis assessment where personal data is used

HOW TO DOCUMENT IT

Inspect actual test data rather than the stated policy, and record the sensitive fields present. Record how long test data has been in place, since accumulated historical test data is a common and easily evidenced finding. Note any data used for model development separately, along with whether any process governed it.

EXECUTIVE SUMMARY TREATMENT

Suggested language: production data containing a named sensitive category has been present in test environments for a stated period with no authorization from the data owner and no lawful basis recorded for its use. The combination of unauthorized use and extended retention is what elevates this above a technical observation.

A.8.34 Protection of information systems during audit testing

WHAT THE CONTROL ASKS FOR

Plan and agree audit tests and other assurance activities involving assessment of operational systems between the tester and appropriate management. The purpose is to ensure that testing does not itself disrupt or compromise the systems being tested.

WHY IT EXISTS

Audit and assurance activity touches live systems. Uncoordinated testing has caused outages, triggered incident responses, and in some cases damaged data. This control protects the organization from its own assurance activity, and it also protects the tester by establishing what was authorized before the work began.

HOW TO AUDIT IT

1. Confirm a process exists for planning and agreeing testing that touches operational systems.
2. Check that scope, timing, methods, and access are agreed in advance and recorded.
3. Verify appropriate management approval was obtained, at a level able to accept the operational risk.
4. Check that testing access is limited to what the test requires and is revoked afterwards.
5. Confirm testing activity is logged and that operational teams are informed, so that test activity is not mistaken for an attack.
6. Review whether any assurance activity in the period caused disruption, and what happened.
7. Check that the requirement applies to external testers as well as internal audit, including penetration testers.
8. Verify handling of any sensitive data the testing produces, including its retention and destruction.

EVIDENCE TO COLLECT

- Audit and assurance planning procedure
- Agreed test plans with scope, timing, and methods
- Management approval records
- Testing access grants with revocation evidence
- Notification records to operational teams
- Incident records where assurance activity caused disruption
- Data handling and destruction arrangements for test outputs

HOW TO DOCUMENT IT

Record the agreement and approval for the testing performed during this engagement as well, since the auditor is subject to this control and demonstrating compliance with it is good practice. Note any access granted for testing and confirm it was revoked, with the date.

EXECUTIVE SUMMARY TREATMENT

Rarely an executive item. Where it matters: assurance testing is performed on production systems without agreed scope or management approval, and access granted for testing is not revoked afterwards. Give the count of unrevoked testing accounts if any exist.

Glossary

Terms are listed alphabetically. Each is also indexed at the point of first use.

Annex A

The list of 93 reference controls attached to ISO/IEC 27001:2022, organized into four themes: organizational, people, physical, and technological. Annex A is a checklist to compare your own selected controls against, not a set of controls you are required to implement wholesale.

Asset owner

The individual accountable for a specific information asset through its life: its classification, who may access it, and what happens to it at the end. Must be a named person. A team or a department cannot own an asset in any way that produces accountability.

Certification body

An organization accredited to audit management systems and issue certificates. It is not a consultant and cannot design your system for you; doing both would compromise its independence.

Compensating measure

An alternative control used when the intended control is impractical, typically because the organization is too small. Usually takes the form of monitoring or independent after-the-fact review. It must be documented and it must actually operate.

Complementary user entity control

A control that a service provider's assurance report states the customer must implement for the provider's controls to be effective. Frequently overlooked, because the report is filed on receipt and the obligations inside it are never extracted.

Continual improvement

Making the management system progressively more suitable, adequate, and effective over time. Distinct from corrective action, which restores something that broke. Improvement raises the baseline.

Control

A measure that changes risk. It may be a technology, a process, a rule, a contractual term, or a person performing a task on a schedule. In ISO 27001 a control is not necessarily software and is frequently not technical at all.

Corrective action

Action taken to eliminate the cause of a nonconformity so it does not recur. Distinct from correction, which fixes the individual instance. Fixing the instance without addressing the cause guarantees the finding will return.

Documented information

The standard's umbrella term covering both documents, which state what is supposed to happen, and records, which evidence what did happen. When a clause requires documented information, work out which of the two it means before deciding whether you have it.

Effectiveness

The extent to which planned activities are realized and planned results achieved. Asking whether a control is effective is a different question from whether it is operating, and most measurement programmes only answer the second.

Interested party

Any person or organization that can affect, be affected by, or perceive itself to be affected by the organization's decisions or activities. Includes customers, regulators, employees, shareholders, suppliers, and sometimes the public.

ISMS

Information Security Management System. The coordinated set of policies, processes, people, and controls through which an organization manages information security. The word system here does not mean software.

Least privilege

The principle that an identity should hold only the access required for its current function, and no more. Erodes naturally over time as people change roles, which is why periodic access review exists.

Major nonconformity

The absence of a required element, a widespread failure, or a failure that puts the reliability of the management system in doubt. Normally blocks certification until resolved.

Minor nonconformity

An isolated lapse in a system that otherwise functions. Normally does not block certification, but a pattern of minors in the same area is treated as a major.

Need to know

The principle that access to specific information is granted only where the person's duties require it. Sits alongside least privilege; least privilege governs how much, need to know governs which.

Nonconformity

A failure to meet a requirement, whether that requirement comes from the standard, from the organization's own policies, or from a legal or contractual obligation.

Personally identifiable information

Any information that can identify a living individual, either on its own or in combination with other information reasonably available. Usually shortened to PII. The equivalent term in European law is personal data, and its scope is broader than most people assume.

Population

The complete set of items from which an audit sample is drawn. Getting the population right matters more than sample size; a perfect sample of an incomplete population tests nothing.

Residual risk

The risk that remains after controls are applied and working as intended. Must be formally accepted by the risk owner, not by the security function on their behalf.

Risk owner

The person with the authority and the accountability to decide what to do about a specific risk. Must be senior enough to actually make that decision and to fund the consequence of it.

Root cause

The underlying reason a failure occurred, as distinct from the failure itself. Human error is a symptom, not a root cause; the cause is whatever made the error likely or made it consequential.

Sampling

Testing a subset of a population and drawing a conclusion about the whole. Record the population, the sample size, and the selection method, or the conclusion cannot be defended.

Segregation of duties

Separating conflicting responsibilities so that no single individual can complete a sensitive process without independent involvement. Often abbreviated SoD.

Software bill of materials

A structured inventory of the components contained in a piece of software, including third-party and open source dependencies. Usually abbreviated SBOM. Without one, responding to a component vulnerability means searching rather than looking up.

Statement of Applicability

The document listing all 93 Annex A controls with, for each, whether the organization applies it and the justification for including or excluding it. Usually shortened to SoA. The document certification bodies examine most closely.

Test of design

An assessment of whether a control, as constructed, would achieve its purpose if it operated. Distinct from testing whether it actually operated, which is a test of operating effectiveness. A control can be well designed and never performed.

Test of operating effectiveness

An assessment of whether a control actually operated as intended over a period. Requires evidence of performance across the period, not a single point in time.

Threat intelligence

Analyzed information about threats: who might attack, why, and how. The analysis step is what distinguishes intelligence from a feed. Unanalyzed feeds produce alert fatigue rather than better defense.

Topic-specific policy

A narrower policy sitting beneath the overarching information security policy, covering a single area such as access control, cryptography, or acceptable use. The 2022 revision uses this term where earlier practice said sub-policy.

Walkthrough

Following a process end to end with the people who perform it, to understand how it actually works rather than how it is documented. Usually performed before testing, and frequently the point at which the real finding becomes visible.

Workpaper

The auditor's record of what was tested, how, what was found, and what was concluded. Written so that a reviewer can follow the reasoning without re-performing the work.

Index of Terms and Concepts

- Acceptable use of information and other
 - associated assets, 43
- Access control, 48
- Access rights, 51
- Access to source code, 103
- Actions to address risks and opportunities:
 - general, 11
- Addressing information security within supplier agreements, 53
- Annex A, 136
- Application security requirements, 126
- Assessment and decision on information security events, 58
- Asset owner, 136
- Authentication information, 50
- Awareness, 18
- Cabling security, 95
- Capacity management, 105
- Certification body, 136
- Change management, 133
- Classification of information, 45
- Clear desk and clear screen, 90
- Clock synchronization, 117
- Collection of evidence, 61
- Communication, 19
- Compensating measure, 136
- Competence, 17
- Complementary user entity control, 136
- Compliance with policies, rules and standards
 - for information security, 70
- Confidentiality or non-disclosure agreements, 78
- Configuration management, 109
- Contact with authorities, 38
- Contact with special interest groups, 39
- Continual improvement, 30, 136
- Control, 136
- Control of documented information, 22
- Corrective action, 136
- Creating and updating documented information, 21
- Data leakage prevention, 112
- Data masking, 111
- Determining the scope of the information
 - security management system, 6
- Disciplinary process, 76
- Documented information, 20, 136
- Documented information: general, 20
- Documented operating procedures, 71
- Effectiveness, 137
- Equipment maintenance, 96
- Equipment siting and protection, 91
- ICT readiness for business continuity, 63
- Identity management, 49
- Independent review of information security, 69
- Information access restriction, 102
- Information backup, 113
- Information deletion, 110
- Information security awareness, education and training, 75
- Information security during disruption, 62
- Information security event reporting, 81
- Information security for use of cloud services, 56
- Information security in project management, 41
- Information security in supplier relationships, 52
- Information security incident management
 - planning and preparation, 57
- Information security management system, 7
- Information security objectives and planning to achieve them, 14
- Information security risk assessment, 12
- Information security risk treatment, 13
- Information security roles and responsibilities, 35
- Information transfer, 47
- Installation of software on operational systems, 119
- Intellectual property rights, 65
- Interested party, 137
- Internal audit, 27

- Inventory of information and other associated assets, 42
- ISMS, 6, 137
- Labelling of information, 46
- Leadership and commitment, 8
- Learning from information security incidents, 60
- Least privilege, 137
- Legal, statutory, regulatory and contractual requirements, 64
- Logging, 115
- Major nonconformity, 137
- Management of technical vulnerabilities, 107
- Management responsibilities, 37
- Management review, 29
- Managing information security in the ICT supply chain, 54
- Minor nonconformity, 137
- Monitoring activities, 116
- Monitoring, measurement, analysis and evaluation, 26
- Monitoring, review and change management of supplier services, 55
- Need to know, 137
- Networks security, 120
- Nonconformity, 137
- nonconformity, 31
- Nonconformity and corrective action, 31
- Operational planning and control, 23
- Organizational roles, responsibilities and authorities, 10
- Outsourced development, 130
- Performing information security risk assessment, 24
- Performing information security risk treatment, 25
- Personally identifiable information, 137
- personally identifiable information, 67
- Physical entry, 85
- Physical security monitoring, 87
- Physical security perimeters, 84
- Planning of changes, 15
- Policies for information security, 34
- Policy, 9
- Population, 137
- Privacy and protection of personally identifiable information, 67
- Privileged access rights, 101
- Protecting against physical and environmental threats, 88
- Protection against malware, 106
- Protection of information systems during audit testing, 135
- Protection of records, 66
- Redundancy of information processing facilities, 114
- Remote working, 79
- Residual risk, 137
- residual risk, 13
- Resources, 16
- Response to information security incidents, 59
- Responsibilities after termination or change of employment, 77
- Return of assets, 44
- Risk owner, 137
- risk owners, 12
- Root cause, 138
- Sampling, 138
- Screening, 73
- Secure authentication, 104
- Secure coding, 128
- Secure development life cycle, 125
- Secure disposal or re-use of equipment, 97
- Secure system architecture and engineering principles, 127
- Securing offices, rooms and facilities, 86
- Security of assets off-premises, 92
- Security of network services, 121
- Security testing in development and acceptance, 129
- Segregation of duties, 36, 138
- Segregation of networks, 122
- Separation of development, test and production environments, 132
- Software bill of materials, 138
- Statement of Applicability, 13, 138
- Storage media, 93
- Supporting utilities, 94
- Terms and conditions of employment, 74
- Test information, 134
- Test of design, 138

Test of operating effectiveness, [138](#)

Threat intelligence, [40](#), [138](#)

Topic-specific policy, [138](#)

Understanding the needs and expectations of
interested parties, [5](#)

Understanding the organization and its context,
[3](#)

Use of cryptography, [124](#)

Use of privileged utility programs, [118](#)

User endpoint devices, [100](#)

Walkthrough, [138](#)

Web filtering, [123](#)

Working in secure areas, [89](#)

Workpaper, [138](#)